



AWS Security Incident Response User Guide



Version August 27, 2026

Copyright © 2026 Amazon Web Services, Inc. and/or its affiliates. All rights reserved.

AWS Security Incident Response User Guide:

Copyright © 2026 Amazon Web Services, Inc. and/or its affiliates. All rights reserved.

Amazon's trademarks and trade dress may not be used in connection with any product or service that is not Amazon's, in any manner that is likely to cause confusion among customers, or in any manner that disparages or discredits Amazon. All other trademarks not owned by Amazon are the property of their respective owners, who may or may not be affiliated with, connected to, or sponsored by Amazon.

Table of Contents

What is AWS Security Incident Response?	1
How it works	2
Triage and deduplication	2
Log access	2
Suppression rules	3
Automated and human investigation	3
Continuous improvement	3
Proactive and reactive cases	4
Containment	4
Watchers and case sharing	4
Communication and case management	5
Monitored accounts	5
Integrations	5
APIs and self-service	5
Monthly reports	6
Preparedness	6
Service boundaries	6
Your responsibilities	7
Getting assistance	7
Supported Regions	8
Concepts and Terminology	10
Getting started	12
Sign up for an AWS account	12
Onboarding guide	12
Prepare for onboarding	12
Onboarding prerequisites	13
Step 1: Enable and configure	15
Step 2: Configure your incident response team	18
Step 3: Understand case types and management	18
Step 4: Integrate with your existing tools	22
Deploy containment and EC2 Triage roles	26
Enable Security Incident Response using the API/CLI	42
RACI Matrix	45
Proactive response and alert triaging	46
Understanding Automatic Archiving with Proactive Response	47

Validating your configuration	49
Before you validate	49
Step 1: Verify enrollment and membership	50
Step 2: Verify detection sources and triage	52
Step 3: Verify the automated finding pipeline	54
Step 4: Verify notifications and incident response team	55
Step 5: Verify containment readiness (optional)	57
Step 6: Confirm ongoing operation	58
Validation checklist	60
Billing verification	60
Troubleshooting	61
Related resources	62
User tasks	63
Security Incident Response dashboard	63
Managing my Incident Response Team	63
Communication Preferences	64
Account association to AWS Organizations	66
Monitoring and investigation	67
AI Investigative Agent	73
Contain	77
Eradicate	79
Recover	79
Monthly report	80
Cases	81
Create an AWS supported case	81
Create a self-managed case	85
Working with AWS Security Incident Response engineers	87
Responding to an AWS generated case	90
Managing Cases	90
Changing the case status	91
Changing the resolver	91
Action Items	91
Edit a case	92
Communications	92
Permissions	93
Attachments	93
Tags	94

Case activities	94
Closing a case	94
Cancel Membership	95
Tagging AWS Security Incident Response resources	97
Using AWS CloudShell	98
Obtaining IAM permissions for AWS CloudShell	98
Interacting with Security Incident Response using AWS CloudShell	99
CloudTrail logs	100
Security Incident Response information in CloudTrail	100
Understanding Security Incident Response log file entries	101
Managing accounts with AWS Organizations	104
Considerations and recommendations	104
Trusted access	105
Permissions required to designate a delegated Security Incident Response administrator account	107
Managing membership with organizational units (OUs)	109
Adding members to AWS Security Incident Response	110
Removing members from AWS Security Incident Response	110
.....	111
Managing events using EventBridge	111
Sending Security Incident Response events	112
Events detail reference	113
Case Events	115
Case Comment Events	118
Membership Events	121
Using AWS Security Incident Response Events	123
Tutorial: Sending Amazon Simple Notification Service alerts for Membership Updated events	124
Prerequisites	125
Tutorial: Create and subscribe to an Amazon SNS topic	125
Tutorial: Register an event rule	125
Tutorial: Test your rule	127
Alternate rule: Security Incident Response Case Updates	127
Troubleshooting	129
Issues	129
Errors	129
Support	130

Security	132
Data Protection in AWS Security Incident Response	132
Data encryption	133
Data collection and usage	134
Data residency and regional behavior	136
Data access and permissions	138
Inter-network traffic privacy	139
Traffic between service and on-premises clients and applications	139
Traffic between AWS resources in the same Region	139
Identity and Access Management	140
Authenticating with identities	141
How AWS Security Incident Response Works with IAM	144
Troubleshooting AWS Security Incident Response identity and access	151
Using service roles	152
Using service-linked roles	153
AWSServiceRoleForSecurityIncidentResponse	153
AWSServiceRoleForSecurityIncidentResponse_Triage	154
Supported regions for SLRs	156
Expected CreateServiceLinkedRole events	157
AWS Managed Policies	157
managed policy: AWSSecurityIncidentResponseServiceRolePolicy	158
managed policy: AWSSecurityIncidentResponseAdmin	159
managed policy: AWSSecurityIncidentResponseReadOnlyAccess	159
managed policy: AWSSecurityIncidentResponseCaseFullAccess	160
managed policy: AWSSecurityIncidentResponseTriageServiceRolePolicy	161
Updates for SLRs and managed policies	162
Incident response	166
Compliance validation	167
Services in scope	167
Healthcare compliance (HITRUST CSF)	168
HIPAA eligibility	169
Logging and monitoring in AWS Security Incident Response	169
Resilience	169
Infrastructure security	170
Configuration and vulnerability analysis	170
Cross-service confused deputy prevention	171
Service Quotas	172

AWS Security Incident Response	172
Document history	173

What is AWS Security Incident Response?

AWS Security Incident Response is a managed security service that monitors your AWS environment for threats, triages security findings on your behalf, and engages you only when action is required. When a genuine security incident occurs, the Security Incident Response Engineering team investigates, helps contain the threat, and provides guidance toward recovery.

AWS Security Incident Response covers the full incident lifecycle: detection, triage, investigation, containment, and recovery guidance. The service aligns with the NIST 800-61 Computer Security Incident Handling Guide, providing a consistent approach to security event management grounded in industry best practices. It works alongside other AWS Detection and Response services and integrates with your existing tools through Amazon EventBridge.

Topics

- [How it works](#)
- [Triage and deduplication](#)
- [Log access](#)
- [Suppression rules](#)
- [Automated and human investigation](#)
- [Continuous improvement](#)
- [Proactive and reactive cases](#)
- [Containment](#)
- [Watchers and case sharing](#)
- [Communication and case management](#)
- [Monitored accounts](#)
- [Integrations](#)
- [APIs and self-service](#)
- [Monthly reports](#)
- [Preparedness](#)
- [Service boundaries](#)
- [Your responsibilities](#)
- [Getting assistance](#)

- [Supported Regions](#)

How it works

AWS Security Incident Response doesn't generate security findings. It ingests findings from detection sources you already have (Amazon GuardDuty, third-party tools integrated through AWS Security Hub CSPM) and triages them on your behalf.

The service ingests all findings from configured sources but doesn't triage them all equally. An automated system evaluates whether each finding represents a genuine security threat and contains sufficient context for investigation. Findings that pass this evaluation proceed through a multi-stage triage process that combines automation, threat intelligence, and human expertise.

AWS Security Incident Response only triages threat detection findings. Security posture or compliance findings (such as misconfiguration alerts or benchmark violations) aren't triaged because they describe a state about your environment rather than an active threat requiring investigation.

Triage and deduplication

Triage and deduplication are at the core of the service. AWS Security Incident Response analyzes findings, correlates related signals, and eliminates duplicates so your team doesn't have to.

The service escalates to you only when your involvement is required. Across all customers, less than 1% of ingested findings result in a customer-facing escalation. When the service escalates, it means the finding requires your attention. There's no option to mute or suppress these notifications because each one represents a validated concern that requires action.

The triage process is dynamic. A finding evaluated as expected behavior today can be re-evaluated differently tomorrow if context changes. This is fundamentally different from a static suppression rule. AWS Security Incident Response prefers triage over suppression because it preserves the ability to detect evolving threats.

Log access

Security Incident Response accesses control plane logging only during an active investigation for the purpose of that investigation. Log data isn't provided to customers. Only summaries and conclusions are shared through case notes.

Suppression rules

In rare cases, when both you and the Security Incident Response Engineering team agree that a specific type of alert no longer needs monitoring, a suppression rule is deployed. Suppressed alerts aren't ingested or monitored in the future. You can see suppression rules in the GuardDuty or Security Hub CSPM console, and Security Incident Response notifies your Incident Response team when rules are created or modified. Changes are rolled back upon request.

Suppression rules are used sparingly because suppressed findings are permanently excluded from monitoring, whereas triaged findings remain under dynamic evaluation. Security Incident Response engineers always discuss this with you before implementing a rule.

Automated and human investigation

When automated triage can't determine that activity is expected, the AWS Security Incident Response Engineering team is engaged. This is a global, always-available team of security professionals with expertise in AWS and security incident response.

During an investigation, engineers analyze service metadata and threat intelligence, review insights from past findings in your environment, and apply incident response expertise. As part of a security investigation, Security Incident Response can also collect investigative data from within Amazon Elastic Compute Cloud instances using EC2 Triage (when enabled), without requiring direct access to the instance.

Continuous improvement

AWS Security Incident Response incorporates feedback and lessons learned from prior engagements to enhance detection capabilities, investigative processes, and triage accuracy. As the team investigates incidents across all customers, it develops responder-generated intelligence: indicators of compromise (IoCs), tactics, techniques, and procedures (TTPs), and associated patterns observed during investigations. This intelligence feeds back into the triage process, improving the ability to detect and respond to evolving threats over time.

The effectiveness of the service improves with your collaboration. By actively engaging and providing timely responses during investigations, you help the team understand your environment and expected behaviors, reduce false positive detections, and ensure rapid response to genuine incidents.

Proactive and reactive cases

AWS Security Incident Response provides two types of cases:

Proactive cases: Created automatically when the triage process identifies a genuine threat that requires your involvement. These cases carry a "[Proactive case]" prefix in their title. No manual configuration is required beyond enabling detection sources. When a proactive case is created, all configured stakeholders are notified automatically.

Reactive cases: Cases you create when you need assistance. There are two subtypes:

- **AWS-supported:** Escalated directly to Security Incident Response Engineering for investigation and guidance. These cases carry a 15-minute SLO for initial engagement. There's no limit on the number of reactive cases you can open.
- **Self-managed:** Kept internal to your organization for tracking and documentation. You can escalate a self-managed case to Security Incident Response Engineering at any time.

24/7 availability: Engineers respond to both proactive and reactive cases. AWS-supported reactive cases carry a 15-minute initial response SLO.

Both case types use the same data fields and case management portal.

Containment

When pre-authorized, Security Incident Response engineers execute containment actions on your behalf during active incidents. Supported containment actions include runbooks for compromised Amazon S3 buckets, Amazon EC2 instances, and IAM principals.

If you haven't pre-authorized containment, engineers provide manual guidance during investigations. For more information, see [Containment actions](#).

Watchers and case sharing

You can grant case visibility to external parties using watchers or IAM policies. This lets you include partners, risk and compliance teams, legal counsel, or subject matter experts in your investigations.

Watchers receive notifications for all updates to a specific case. Each case includes a pre-populated IAM policy scoped to that case, maintaining least-privilege access for third-party participants.

Communication and case management

All cases are managed through your Membership account, which centralizes communication for all organizational accounts in one place. Communication during an investigation may include acknowledgment of a security event, establishing a call bridge, analysis of artifacts, requests for confirmation of expected activity, and sharing of investigation results. Video calls are available during active security events.

Only you can close a case. AWS Security Incident Response can set a case to "Ready to Close" status, but final closure is always your action.

Monitored accounts

Only accounts enrolled in your membership are monitored and investigated. You choose coverage at the AWS organization or OU level during enablement. Accounts outside your configured scope aren't monitored. For more information, see [Step 1: Enable AWS Security Incident Response](#).

Integrations

AWS Security Incident Response integrates with your existing workflows through Amazon EventBridge. Every case lifecycle event is published to EventBridge, allowing you to build automations that connect to any tool or process you use.

Documented integration patterns are available for:

- Jira
- Slack
- ServiceNow

You can also build custom integrations for any other tool using the EventBridge events. For more information, see [EventBridge integration](#).

APIs and self-service

AWS Security Incident Response provides APIs that allow you to integrate the service into your own workflows, retrieve case information programmatically, and build customized security solutions on top of the service. For more information, see the [AWS Security Incident Response API Reference](#).

Monthly reports

AWS Security Incident Response delivers monthly reports summarizing activity across your accounts. These reports provide visibility into findings ingested, triage outcomes, and cases created. For more information, see [Monthly reports](#).

Preparedness

During onboarding, you configure your Incident Response team with designated individuals or groups who receive notifications when cases are created. Permission policies define what access team members have within a case. Setting this up in advance ensures rapid response when an incident occurs.

Service boundaries

AWS Security Incident Response isn't a detection service — it doesn't generate findings or replace GuardDuty, Security Hub CSPM, or third-party detection tools. It ingests and triages what those services produce. It isn't an alert aggregator — unlike services that pass all alerts through to you, it absorbs the vast majority of findings and only escalates the ones that require your action. It doesn't triage security posture findings — compliance and configuration findings are informational by nature and don't require threat investigation.

The following activities are also not covered:

Activity	Description
General security guidance	Proactive security assessments, architecture reviews, penetration testing, and vulnerability scanning.
Threat hunting	Proactive searching for threats that haven't generated a detection finding.
Forensic disk or endpoint analysis	Full disk imaging, memory analysis, or endpoint forensics. Engineers perform log-based investigation only.
Custom reporting	Reports outside the standard case notes format.
Legal and regulatory guidance	Guidance on breach notification, regulatory filings, or other legal obligations.

Activity	Description
Recovery and remediation execution	Running recovery or remediation actions on your resources. Engineers provide recommendations only.
Attribution	Identifying the specific threat actor or group behind an incident.

Your responsibilities

- **Respond to validation requests promptly:** When engineers contact you to validate information, respond in a timely manner. If you don't respond, the investigation might be placed on hold.
- **Designate a security contact:** Provide and maintain an up-to-date security contact who receives notifications during active investigations.
- **Enable logging:** Enable AWS CloudTrail, Amazon VPC Flow Logs, and other relevant logging. Comprehensive logging reduces investigation timelines.
- **Review and implement recommendations:** After receiving containment and remediation recommendations, implement them to resolve the event and prevent recurrence.

Getting assistance

If you have a request outside the scope of AWS Security Incident Response, see the following resources.

Need	Resource
Security posture assessments	AWS Professional Services
Compliance and audit	AWS Audit Manager , AWS Artifact
General security guidance	AWS Security Hub CSPM , AWS Trusted Advisor
DDoS protection	AWS Shield
AWS service-side event explanations	AWS Support

Supported Regions

AWS Security Incident Response supports the following language and region configurations:

- **Language:** AWS Security Incident Response provides dedicated English support. Japanese language support is limited to Japan Standard Time business hours and comes with specific restrictions:

Note

Japanese language support is provided on a best-effort basis during business hours (09:00-17:00, Monday-Friday, excluding holidays)

- **Supported AWS Regions:**

AWS Security Incident Response is available in a subset of AWS Regions. In these supported Regions, you create a membership, create and view cases, and access the dashboard.

- US East (Ohio)
- US West (Oregon)
- US East (Virginia)
- Europe (Frankfurt)
- Europe (Ireland)
- Europe (London)
- Europe (Milan)
- Europe (Paris)
- Europe (Spain)
- Europe (Stockholm)
- Europe (Zurich)
- Asia Pacific (Hong Kong)
- Asia Pacific (Hyderabad)
- Asia Pacific (Jakarta)
- Asia Pacific (Melbourne)
- Asia Pacific (Mumbai)

- Asia Pacific (Singapore)
- Asia Pacific (Sydney)
- Asia Pacific (Tokyo)
- Canada (Central)
- Middle East (Bahrain)
- Middle East (UAE)
- South America (São Paulo)
- Africa (Cape Town)

When you enable the monitoring and investigation feature, AWS Security Incident Response monitors Amazon GuardDuty findings from all active commercial AWS Regions. As a security best practice, AWS recommends enabling GuardDuty in all supported AWS Regions. This configuration allows GuardDuty to generate findings about unauthorized or unusual activity, even in AWS Regions where you don't actively deploy resources. By doing so, you enhance your overall security posture and maintain comprehensive threat detection coverage across your AWS environment.

 Note

Amazon GuardDuty reports findings for configured regions. If you don't enable the service in a specific AWS Region, then alerts aren't available.

Concepts and Terminology

The following terms and concepts are important for understanding the AWS Security Incident Response service and how it works.

Scope: AWS Security Incident Response aligns with the National Institute of Standards and Technology (NIST) 800-61 Computer Security Incident Handling Guide, providing a consistent approach to security event management as related to industry best practices.

Analysis: The detailed investigation and examination of a security event to understand its scope, impact, and root cause.

AWS Security Incident Response service portal: A self-service portal for you to initiate and manage security event cases. Ongoing communication and reporting facilitated through the ticketing system, automated notifications, and direct engagement with the service team.

Communication: The ongoing dialog and information sharing between the AWS Security Incident Response team and the customer during the incident response process.

Containment, Eradication, and Recovery: The prevention of additional unauthorized activity (containment), coupled with the removal of unauthorized resources and the original vulnerability (eradication), and recovering resources to get back to business as normal.

Continuous Improvement: AWS Security Incident Response incorporates feedback and lessons learned from prior engagements to enhance its detection capabilities, investigative processes, and remediation actions. AWS Security Incident Response also stays up-to-date with the latest security threats and best practices to address evolving security challenges.

Cybersecurity Event: An action that uses an information system or network to produce an adverse effect on the system, network, or information it contains.

Cybersecurity Incident: A violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices.

Security Incident Response engineers: A group of individuals who provide support during active security events. For AWS supported cases, this is the Security Incident Response engineers.

Incident Response Workflow: The defined sequence of steps and activities involved in the end-to-end management of a security event, aligned with the NIST 800-61 standard.

Investigative Tooling: AWS Security Incident Response tools and service-linked roles used to review the operational health of your account and resources.

Lessons Learned: The review and documentation of a security event response to identify areas for improvement and inform future incident response planning.

Monitoring and Investigation: AWS Security Incident Response rapidly reviews security alerts from Amazon GuardDuty, bringing to the forefront the most important alerts your team needs to analyze. It configures suppression rules based on the specifics of your environment to prevent unnecessary alerts.

Preparation: The activities undertaken to get an organization ready to effectively respond to and manage security events, such as developing incident response plans and testing procedures.

Reporting and Communication: The processes used to keep you informed throughout the incident response process, including automated notifications, call bridges, and the delivery of investigation artifacts. AWS Security Incident Response provides a single, centralized dashboard in the AWS Management Console to manage all your AWS Security Incident Response efforts.

Responder Generated Intelligence: indicators of compromise; tactics, techniques, and procedures; and associated patterns observed by AWS investigations.

Security Event Expertise: The specialized knowledge and skills required to effectively respond to and manage security events, particularly in the context of the AWS cloud.

Shared Responsibility Model: The division of security responsibilities between AWS and the customer, where AWS is responsible for security of the cloud, and the customer is responsible for security in the cloud.

Threat Intelligence: Internal and external data feeds containing details of unauthorized activity to help identify and respond to evolving security threats.

Ticketing System: A dedicated case management platform that allows you to onboard and manage security event cases, add attachments, and track the incident response lifecycle.

Triage: The initial assessment and prioritization of a security event to determine the appropriate response and next steps.

Workflow: The defined sequence of steps and activities involved in the end-to-end management of a security event.

Getting started

[Getting Started with AWS Security Incident Response](#)

Contents

- [Sign up for an AWS account](#)
- [Onboarding guide](#)
- [RACI matrix](#)
- [Proactive response and alert triaging](#)
- [Validating your AWS Security Incident Response configuration](#)

Sign up for an AWS account

To get started with AWS, you need an AWS account. For information about creating an AWS account, see [Getting started with an AWS account](#) in the *AWS Account Management Reference Guide*.

Onboarding guide

AWS Security Incident Response helps you prepare for, respond to, and recover from security events such as account takeovers, data breaches, and ransomware attacks. The service triages findings from Amazon GuardDuty and AWS Security Hub CSPM, escalates security events, and manages cases that require your attention. You also have access to the Security Incident Response Engineering team, who investigates impacted resources and provides guidance throughout the incident lifecycle.

For a full overview of the service, see [What is AWS Security Incident Response?](#)

Prepare for onboarding

AWS Security Incident Response recommends using a proof-of-concept (POC) approach when implementing AWS Security Incident Response. Before deployment, complete the following preparation steps with your internal teams and AWS account team.

- **Identify key stakeholders:** Map out the incident response decision-makers in your organization. Their involvement in policy updates and process changes is essential for a successful rollout.

- **Validate finding sources:** Confirm that all security finding sources are properly configured and deployed. GuardDuty and Security Hub CSPM are critical inputs for the service's auto-triage technology.
- **Determine account scope:** Decide whether AWS Security Incident Response will cover your entire AWS organization or specific organizational units (OUs). Defining this scope early makes implementation and scaling more straightforward.
- **Establish escalation protocols:** Update your existing escalation procedures to include AWS Security Incident Response. Communicate the updated protocols to all stakeholders and response personnel.
- **Collect points of contact and critical information:** Collecting customer information early ensures a smooth onboarding experience and enables timely outreach from the AWS Security Incident Response Engineering team when needed.

Onboarding prerequisites

The only required prerequisite is enabling [AWS Organizations](#) with **All Features** enabled. Consolidated billing alone is not sufficient.

Note

The AWS Identity and Access Management (IAM) principal used to sign in to the delegated administrator account during enablement must have AdministratorAccess permissions. Without these permissions, the enablement process fails.

Detection services

While not required, we strongly recommend enabling Amazon GuardDuty and AWS Security Hub CSPM across all accounts and active AWS Regions. These detection services provide the signal that AWS Security Incident Response monitors on your behalf. Without them, there are no findings to ingest and no data to triage proactively. It then becomes your responsibility to detect issues and raise them through a case. Additionally, the ability to investigate and assist is significantly reduced without detection tool data, since these tools are critical to understanding what's happening in your accounts.

We also strongly recommend enabling AWS CloudTrail logging across all accounts. During investigations, the Security Incident Response Engineering team relies on CloudTrail data to

analyze activity, trace actions, and identify anomalous patterns in your accounts. Without CloudTrail logs available, the ability to conduct thorough investigations is limited.

You don't need to enable GuardDuty or Security Hub CSPM before activating AWS Security Incident Response. You can enable these detection services at any time after onboarding, and AWS Security Incident Response begins ingesting findings as soon as they're available.

 Note

AWS Security Incident Response only triages threat detection findings. Security posture or compliance findings (such as misconfiguration alerts or benchmark violations) aren't triaged because they represent a state about your environment rather than an active threat requiring investigation.

GuardDuty and AWS Security Incident Response

We recommend enabling GuardDuty in all accounts and all AWS Regions, including Regions where you have no active workloads. Attackers commonly target unused Regions and dormant accounts to spin up expensive resources or gain lateral access without being detected. A common misconception is that you only need to monitor the Regions and production accounts you actively use. However, this is a key vector that attackers exploit.

GuardDuty doesn't incur charges in Regions with no activity, so enabling it everywhere carries no cost penalty for quiet Regions. If unauthorized activity occurs in an unused Region, GuardDuty gives immediate visibility to act on your behalf.

To enable GuardDuty across your organization, see [Setting up GuardDuty](#).

Third-party integration

You don't need to enable Security Hub CSPM standards or controls for AWS Security Incident Response. Security Hub CSPM is used only as a conduit to ingest findings from third-party endpoint detection and response (EDR) vendors. The controls and standards are optional from the AWS Security Incident Response perspective, though you can keep them enabled if they provide value for your own compliance and posture management needs.

When third-party findings are ingested through Security Hub CSPM, AWS Security Incident Response auto-triages them for proactive case creation. To set up a third-party EDR integration, follow the steps in the [Security Hub CSPM integrations documentation](#).

For supported third-party tools, see [Detect and analyze](#). If your third-party tool integrates with Security Hub CSPM but isn't listed, AWS Security Incident Response can still ingest those findings on a best-effort basis while support is evaluated. To discuss support for additional tools, open an AWS Support case or contact your TAM.

Findings created before onboarding

Important

AWS Security Incident Response can only ingest findings generated after you complete onboarding. Findings that were created before activation are not retroactively ingested. If you have existing findings you want investigated, raise them through a case after onboarding is complete.

Step 1: Enable and configure AWS Security Incident Response

The onboarding process takes approximately 10 to 15 minutes per AWS organization. For a walkthrough, see the [Getting Started video](#).

Note

You can also perform these steps using the API/AWS CLI. For instructions, see [Enable Security Incident Response and configure your incident response team using the API/CLI](#).

Before you begin

Confirm the following before you start:

- You have access to your AWS Organizations management account.
- Your AWS Organizations has **All Features** enabled. Consolidated billing alone isn't sufficient.
- Your service control policies (SCPs) don't block the creation of service-linked roles or prevent the use of AWS Security Incident Response actions. If your organization uses restrictive SCPs, verify that they allow the `security-ir:*` actions and the `iam:CreateServiceLinkedRole` action for the Security Incident Response service principal.
- You have identified which account to use as your central membership account. This is the account where you configure membership details, manage your incident response team, and create

and manage security cases. We recommend choosing an account that your incident responders already have access to, since they communicate with the Security Incident Response Engineering team and manage active cases. For guidance on structuring your security accounts, see [Security Reference Architecture](#) in *AWS Prescriptive Guidance*.

- You have sufficient IAM permissions to administer AWS Security Incident Response. For details, see [AWS Security Incident Response managed policies](#).

For guidance on preparing your environment with detection services (GuardDuty, Security Hub CSPM, CloudTrail) and third-party EDR integrations, see [Onboarding prerequisites](#).

Sign up and choose your membership account

1. Sign in to the AWS Management Console using your AWS Organizations management account, then open the [AWS Security Incident Response console](#) and choose **Sign up**.
2. Designate which account in your organization serves as the central membership account. You have two options:
 - **Use a delegated administrator account (recommended)** — Administrative tasks and case management are located in the delegated administrator account. We recommend using the same delegated administrator that you use for other AWS security and compliance services. Provide the 12-digit delegated administrator account ID, then sign in to that account to proceed. For more information, see [Considerations and recommendations](#).
 - **Use the currently signed-in account** — The current account becomes the central membership account. Individuals in your organization access the service through this account to create, access, and manage active and resolved cases.
3. After you choose an account, sign in to it to continue with the following configuration steps.

Configure membership details and account scope

After you sign in to your membership account, you configure how your membership is set up and which accounts it covers.

1. **Select your AWS Region.** Choose the Region where your membership and cases are stored. You can't change this after initial registration.

Note

AWS Security Incident Response still monitors findings from all [supported commercial AWS Regions](#).

2. **Define your account scope.** Choose to enable AWS Security Incident Response for your entire AWS organization or for specific organizational units (OUs). You can select coverage at the OU level, but not at the individual account level. Your choice determines how coverage behaves over time:
 - **Full organization:** Your membership covers all member accounts in the organization. Coverage updates automatically as you add or remove accounts.
 - **Specific OUs:** Your membership covers all accounts under the selected OUs, including accounts in sub-OUs. Coverage updates automatically as you add or remove accounts from those OUs.
- To learn more about best practices for organizing accounts into OUs, see [Organizing your AWS environment using multiple accounts](#).
3. **Provide your incident response contacts.** Supply a primary and secondary contact. These contacts are automatically included as part of your incident response team. At minimum, two contacts must exist for a membership.
 4. **Optional settings.** You can enter a name for the membership and define tags to help track AWS costs and search for resources.

Review service permissions and enable proactive response

Before completing signup, the console displays the permissions that AWS Security Incident Response requires. By signing up, you confirm that the service can:

- Create service-linked roles to access the OUs and accounts in your organization.
- Access and review logs (such as VPC Flow Logs, CloudTrail management events, and S3 CloudTrail events) to expedite investigation and response.
- Ingest alerts from Amazon GuardDuty and AWS Security Hub CSPM, apply suppression rules, and automatically escalate critical findings. This includes creating suppression filters and escalation cases in your accounts.

Select the confirmation checkbox to acknowledge these permissions, then choose **Sign up**. For more information on how proactive response works, see [Proactive response and alert triaging](#).

Configure containment actions

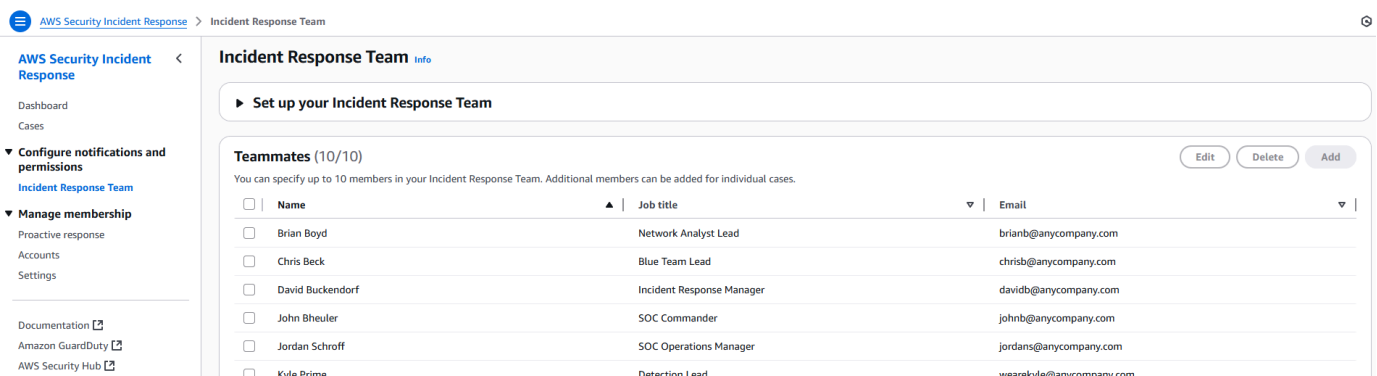
After you complete signup, you can optionally configure containment actions to pre-authorize Security Incident Response Engineering to act on your behalf during active incidents. For details on supported containment actions and how to configure them, see [Contain](#).

Step 2: Configure your incident response team

After you complete deployment, configure your incident response team to ensure proper notification and escalation during security events.

Configure your incident response team using the AWS Security Incident Response console

1. Open the AWS Security Incident Response console.
2. In the left navigation pane, choose **Incident Response Team**.
3. Add up to 10 team members. For each member, provide their name, title, and email address.



Your team can include organization leadership, legal counsel, managed detection and response (MDR) partners, cloud engineers, and other stakeholders who need to be notified during security events.

Step 3: Understand case types and management

AWS Security Incident Response provides two types of cases to manage security events: proactive cases that are automatically created when threats are detected, and reactive cases that you create when you need assistance from Security Incident Response Engineering. You can also grant case visibility to external parties such as partners, legal teams, or subject matter experts.

The following topics are discussed in this section:

- [Proactive cases](#)
- [Reactive cases](#)
- [Watchers](#)

Proactive cases

The auto-triage feature continuously reviews high-volume alerts to filter out noise and focus on critical, high-impact threats. When a potential threat is detected, the system escalates the finding to an Security Incident Response Engineering responder for investigation. If the finding is confirmed as a genuine threat, a proactive case is created in the case management portal and all configured stakeholders are notified automatically.

No manual configuration is required for proactive cases beyond enabling GuardDuty and integrating third-party security solutions with Security Hub CSPM. The service also integrates with an AI investigative agent that correlates data from multiple sources to accelerate investigations. This capability is currently available for reactive, AWS-supported cases.

Reactive cases

AWS Security Incident Response provides a subscription-based case management portal where your organization works directly with Security Incident Response Engineering. Security Incident Response Engineering assists with security investigations and active incidents with a **15-minute service level objective (SLO)**. There is no limit on the number of reactive cases you can open.

To create a case

1. Open the AWS Security Incident Response console.
2. Choose **Cases**, then choose **Create case**.
3. Choose a case type:
 - **AWS-supported**: Escalated directly to Security Incident Response Engineering for investigation and guidance (15-minute SLO).
 - **Self-managed**: Kept internal to your organization for tracking and documentation.
4. Complete all relevant fields. Include as much detail as possible to support an efficient investigation.

Both case types use the same data fields. You can escalate a self-managed case to Security Incident Response Engineering at any time by choosing **Get help from AWS** in the upper-right corner of the case.

☰ AWS Security Incident Response > Create case

Create case

Resolver Info

Select resolver

☒ **AWS-supported:** Resolve case with AWS
24/7 dedicated AWS security professionals from the AWS Customer Incident Response Team (CIRT).

☐ **Self-managed:** Resolve case with my own Incident Response Team
Respond and recover internally and/or with 3rd party security providers.

Case type Info

Select type of request

☒ Active security incident

☐ Investigation

Case overview

Title Info

Active Incident [2025-9-17]

☒ Generate title

Start date estimate Info

Identify the earliest date you observed activity in the impacted account(s).

2025/09/17 ⓘ

Date must be less than 5 years in the past.

For detailed instructions, see [Cases](#).

Watchers

You can grant case visibility to external parties using Watchers or IAM policies. These options let you include partners, risk and compliance teams, legal counsel, or subject matter experts in your investigations. Watchers receive notifications for all updates to a specific case. IAM policies provide direct console access with least-privilege permissions.

To add a watcher to a case

1. Open the AWS Security Incident Response console and choose **Cases**.
2. Open the case you want to share.
3. Choose the **Permissions** tab, then choose **Add**.

AWS Security Incident Response

Dashboard

Cases

▼ Configure notifications and permissions

Incident Response Team

▼ Manage membership

Proactive response

Accounts

Settings

Documentation

Amazon GuardDuty

AWS Security Hub

0928191969

EditActionsGet help from AWS

▼ Overview

Resolver
Self

arn:aws:security-incident-east-1:854725306385:cas:e/0928191969

Start date estimate
2025-07-15

Status
Detection & Analysis

Name
CIRT - Proactive Case - Customer Servers Compromised (CrowdStrike Finding)

Created at
2025-07-14T11:08:03-07:00

Incident start date (actual)
-

Actions

Type
Security Incident

Last updated
2 months ago

DetailsCommunicationsPermissionsAttachmentsTagsCase activities

Watchers (3/30)

RemoveAdd

Q Search

< 1 >

☐	Name	Job title	Email
☐	Jon "Application" Doe	Lead Application Architect	applicationSME@anycompany.com
☐	Legal Team	Corporate Lawyer	legalteam@anycompany.com
☐	Our MSSP Vendor	MSSP Vendor	msspVendor@mssp.com

► Incident response team (10)

All members of your Incident Response Team will also receive notifications for this case.

Go to Incident Response Team

4. Copy the pre-populated IAM policy and apply it to the appropriate IAM roles or users.

DetailsCommunicationsPermissionsAttachmentsTagsCase activities

Watchers (3/30)

RemoveAdd

Q Search

< 1 >

☐	Name	Job title	Email
☐	Jon "Application" Doe	Lead Application Architect	applicationSME@anycompany.com
☐	Legal Team	Corporate Lawyer	legalteam@anycompany.com
☐	Our MSSP Vendor	MSSP Vendor	msspVendor@mssp.com

► Incident response team (10)

All members of your Incident Response Team will also receive notifications for this case.

Go to Incident Response Team

Template case permission policy

Go to IAMCopy to clipboard

Use this sample policy in IAM to define permissions for this case.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "SecurityIncidentResponseCaseReadAccess",
      "Effect": "Allow",
      "Action": [
        "security-ir:GetCase",
        "security-ir:GetCaseAttachmentDownloadUrl",
        "security-ir:ListComments",
        "security-ir:ListCaseEdits",
        "security-ir:ListTagsForResource"
      ]
    }
  ]
}
```

Note

Each case includes a pre-populated IAM policy scoped to that specific case. This maintains least-privilege access for third-party MDR partners and investigation teams.

Step 4: Integrate with your existing tools

AWS Security Incident Response integrates with your existing security tools and workflows to streamline incident response operations. You can configure automatic finding ingestion from GuardDuty, set up event-driven workflows with EventBridge, connect to ITSM platforms like Jira and ServiceNow, and collaborate with your SIEM and MDR providers.

The following topics are discussed in this section:

- [GuardDuty findings and suppression rules](#)
- [Amazon EventBridge](#)
- [Jira, Slack, and ServiceNow integrations](#)
- [SIEM and external tooling](#)

GuardDuty findings and suppression rules

AWS Security Incident Response automatically ingests, triages, and responds to GuardDuty findings and Security Hub CSPM findings from third-party integrations. The auto-triage technology handles analysis as an added layer of detection and analysis. The service can create auto-archive rules in GuardDuty after escalating on a false-positive finding. Responders will always discuss this with you before implementing the rule.

To review GuardDuty suppression rules

1. Open the GuardDuty console.

The screenshot displays the AWS GuardDuty console interface. On the left, there is a navigation sidebar with sections for Summary, Findings, Protection plans, Accounts, Settings, and What's New. The main content area is titled 'Findings (198)' and includes a 'Create suppression rule' button. Below the title, there are filters for 'Saved rules' (Apply saved rules), 'Filter findings' (search bar), 'Status' (Current), and 'Threat type' (All findings). The findings are listed in a table with columns for Severity, Finding type, Resource, and Count. The table shows various findings, including 'Exfiltration_Findings', 'Demo-malware-scan', 'Malware-Findings', 'Port-Scanner-Findings', 'VPC_Flow_Based_findings', and 'Suppression rules'. The 'Suppression rules' section lists rules created by the AWS Security Incident Response, such as 'CIRT-Create-Suppression-Rule-DEMO1', 'CIRT-Create-Suppression-Rule-DEMO2', and 'CIRT-Create-Suppression-Rule-DEMO3'. The table also includes a 'Count' column showing the number of findings for each rule.

Severity	Finding type	Resource	Count
High	Execution:Runtime/MaliciousFileExecuted	EC2 Instance: i-0e25811f91da2a88e	103
Medium	Execution:Runtime/SuspiciousTool	EC2 Instance: i-0e25811f91da2a88e	87
Low	Discovery:IAMUser/AnomalousBehavior	Access Key: ASIA4OAMZF4IQA4UB2EB	90
High	Execution:EC2/MaliciousFile	EC2 Instance: i-0e25811f91da2a88e	1
Low	Policy:S3/BucketBlockPublicAccessDisabled	Access Key: ASIA4OAMZF4IQA4UB2EB	94
Low	Policy:S3/BucketBlockPublicAccessDisabled	Access Key: ASIA4OAMZF4IQA4UB2EB	95
Low	Discovery:IAMUser/AnomalousBehavior	Access Key: ASIA4OAMZF4IQA4UB2EB	693
High	Execution:EC2/MaliciousFile	EC2 Instance: i-0e25811f91da2a88e	1
High	Execution:EC2/MaliciousFile	EC2 Instance: i-0e25811f91da2a88e	1
Low	Discovery:IAMUser/AnomalousBehavior	Access Key: ASIA4OAMZF4IQA4UB2EB	150

2. Choose **Findings**.
3. In the navigation pane, choose **Suppression rules**. The **Suppression rules** page displays a list of all the suppression rules for your account.
4. To review or change the settings for a rule, choose the rule, and then choose **Update suppression rule** from the **Actions** menu.

 Note

Organizations using SIEM technology will see reduced GuardDuty finding volumes over time, which improves both AWS Security Incident Response efficiency and SIEM performance.

Amazon EventBridge

[Amazon EventBridge](#) enables event-driven workflows for AWS Security Incident Response. You can configure case activity to trigger downstream AWS services (Amazon Simple Notification Service, AWS Lambda, Amazon Simple Queue Service, AWS Step Functions) or external tools such as Jira, ServiceNow, Slack, and PagerDuty.

To configure an EventBridge rule for AWS Security Incident Response

1. Sign in to the delegated administrator account for AWS Security Incident Response.
2. Open the EventBridge console.
3. In the navigation pane, under **Buses**, choose **Rules**.
4. Choose **Create rule**, complete the rule details, then choose **Next**.
5. Under **AWS service**, select **AWS Security Incident Response** from the dropdown.
6. For **Event type**, select the event or API call you want to match. You can edit the pattern manually to include multiple events.
7. Choose **Next**.

Event pattern [Info](#)

Creation method

☐ Use schema
Use an Amazon EventBridge schema to generate the event pattern.

☒ **Use pattern form**
Use a template provided by EventBridge to create an event pattern.

☐ Custom pattern (JSON editor)
Write an event pattern in JSON.

Event source
AWS service or EventBridge partner as source

AWS services

AWS service
The name of the AWS service as the event source

AWS Security Incident Response

Event type
The type of events as the source of the matching pattern

Case Created

Event pattern
Event pattern, or filter to match the events

```

1 {
2   "source": ["aws.security-ir"],
3   "detail-type": ["Case Created"]
4 }
    
```

[Copy](#)
[Test pattern](#)
[Edit pattern](#)

[Cancel](#)
[Previous](#)
[Next](#)

- Select one or more targets for your events, such as Amazon SNS, AWS Lambda, an SSM document, or Step Functions. Configure cross-account targets if needed.

Target 1

Target types
Select an EventBridge event bus, EventBridge API destination (SaaS partner), or another AWS service as a target.

☐ EventBridge event bus
☐ EventBridge API destination
☒ **AWS service**

Select a target [Info](#)
Select target(s) to invoke when an event matches your event pattern or when schedule is triggered (limit of 5 targets per rule)

SNS topic

Target location

☒ **Target in this account**
☐ Target in another AWS account

Topic

SIR-Demo-SNS-from-EventBridge

Permissions

☒ Use execution role (recommended)

Execution role
EventBridge needs permission to send events to the target specified above. By continuing, you are allowing us to do so. [EventBridge and AWS Identity and Access Management](#)

☒ **Create a new role for this specific resource**
☐ Use existing role

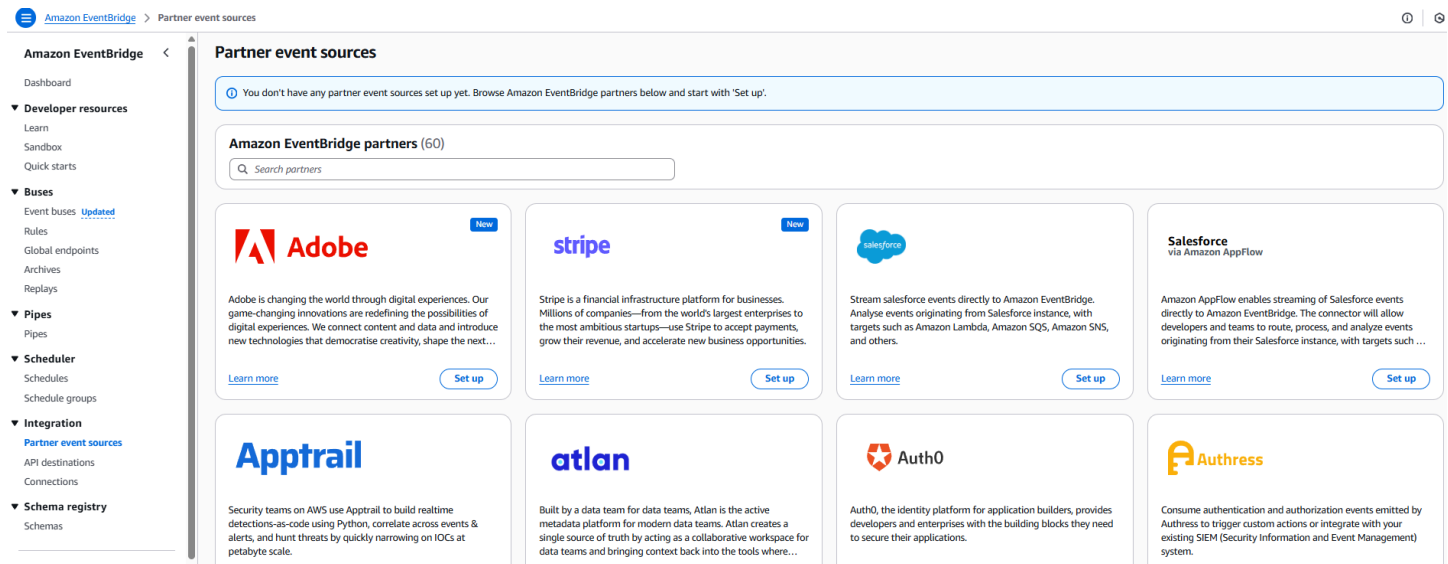
Role name

Amazon_EventBridge_Invoke_Sns_727705831

► **Additional settings**

- Review and create the rule.

To use pre-built partner integrations, check **Partner Event Sources** in the EventBridge console. Available partners include Atlassian (Jira), Datadog, New Relic, PagerDuty, Symantec, and Zendesk.



Jira, Slack, and ServiceNow integrations

AWS provides fully developed solutions for bi-directional integration with Jira, Slack, and ServiceNow. These integrations keep AWS Security Incident Response cases and your ITSM or ChatOps platforms in sync — updates in one system are automatically reflected in the other.

Benefits of integration

Integrating AWS Security Incident Response with your existing ITSM platform streamlines your security operations by centralizing incident tracking and response workflows. These pre-built solutions eliminate the need for custom development, allowing your security teams to maintain visibility across both AWS native and enterprise-wide incident management systems. By leveraging EventBridge for event-driven automation, updates flow seamlessly between platforms in real-time, helping make sure that security incidents are tracked consistently regardless of where they originate. This unified approach reduces context switching for security analysts, improves response times, and provides comprehensive audit trails across your entire incident response lifecycle.

For deployment instructions, see [AWS sample solutions for Jira, Slack, and ServiceNow](#).

SIEM and external tooling

AWS Security Incident Response doesn't directly ingest findings from your SIEM. However, when you open an AWS-supported case, Security Incident Response Engineering responders analyze and investigate SIEM findings in parallel with your team. Security Incident Response Engineering helps identify correlations across hybrid and multi-cloud environments and assists with scoping threat actor activity across providers.

Security Incident Response Engineering also collaborates directly with your MDR providers and third-party investigation teams to help establish effective coordination processes before an incident occurs.

Deploy containment and EC2 Triage roles

AWS Security Incident Response doesn't enable containment by default. To allow the service to take containment actions on your behalf during a security incident, you must deploy AWS Identity and Access Management roles to each account in your organization where you want containment capabilities. The recommended approach is to use AWS CloudFormation StackSets with service-managed permissions, which automatically deploys the roles to all current and future accounts in your organization.

Topics

- [Deploy the IAM roles with a StackSet](#)
- [Select a CloudFormation template for your containment roles](#)

Deploy the IAM roles with a StackSet

Prerequisites for deploying IAM roles with a StackSet

- You must have an active AWS Security Incident Response membership.
- You must have trusted access enabled between AWS CloudFormation StackSets and AWS Organizations. For more information, see [Enable trusted access with AWS Organizations](#) in the *AWS CloudFormation User Guide*.
- You must have permissions to create StackSets in the AWS Organizations management account or a delegated administrator account.

Create a StackSet for Security Incident Response containment roles

Use the following procedure to create a StackSet with service-managed permissions that deploys the containment roles to your organization accounts.

1. Sign in to the AWS Management Console and open the [AWS CloudFormation console](#).
2. In the navigation pane, choose **StackSets**, and then choose **Create StackSet**.
3. For **Permissions**, choose **Service-managed permissions**.

4. For **Template source**, choose **Upload a template file**. Upload the template file you chose from [Select a CloudFormation template for your containment roles](#).
5. Enter a StackSet name (for example, SIR-Containment-Roles) and optionally add a description.
6. On the **Configure StackSet options** page, keep the default settings and choose **Next**.
7. For **Deployment targets**, choose **Deploy to organization**. This helps make sure that the roles deploy to all current and future accounts in your organization.
8. For **Specify regions**, select one AWS Region. Because IAM roles are global resources, you only need to deploy the StackSet to a single Region.
9. Review the settings and select the acknowledgment check box that confirms AWS CloudFormation might create IAM resources with custom names. Choose **Submit**.

After the StackSet deployment completes, the containment roles are available in all accounts within your organization. For more information about managing StackSets, see [Update a StackSet with service-managed permissions](#) in the *AWS CloudFormation User Guide*.

Select a CloudFormation template for your containment roles

AWS Security Incident Response provides two AWS CloudFormation templates. Both templates create the same two AWS Identity and Access Management roles: `AWSSecurityIncidentResponseContainment` and `AWSSecurityIncidentResponseContainmentExecution`. The **Containment with EC2 Triage** template adds the `AWSSecurityIncidentResponseInvestigationPolicy` to the `AWSSecurityIncidentResponseContainment` role, which grants additional permissions for EC2 Triage. Choose the template that matches your security requirements:

- [Containment only](#): Creates the minimum required permissions for containment actions.
- [Containment with EC2 Triage](#): Includes all containment permissions plus additional permissions for EC2 Triage. This template enables AWS Security Incident Response to execute AWS Systems Manager Run Command on your Amazon Elastic Compute Cloud instances during security investigations.

Containment only

Use this template if you want the service to isolate compromised resources during an incident but don't need forensic data collection from running instances.

This template creates two IAM roles:

- **AWSecurityIncidentResponseContainment** – Assumed by AWS Security Incident Response to initiate containment automation workflows through AWS Systems Manager.
- **AWSecurityIncidentResponseContainmentExecution** – Assumed by AWS Systems Manager to execute the containment actions on your resources.

These roles enable three containment actions: isolating Amazon EC2 instances from network traffic, revoking IAM principal access, and restricting Amazon S3 bucket access.

```

AWSTemplateFormatVersion: '2010-09-09'
Description: 'Template for production SIR containment roles'

Resources:
  AWSecurityIncidentResponseContainment:
    Type: 'AWS::IAM::Role'
    Properties:
      RoleName: AWSecurityIncidentResponseContainment
      AssumeRolePolicyDocument:
        {
          'Version': '2012-10-17',
          'Statement':
            [
              {
                'Effect': 'Allow',
                'Principal': { 'Service': 'containment.security-ir.amazonaws.com' },
                'Action': 'sts:AssumeRole',
                'Condition': { 'StringEquals': { 'sts:ExternalId': !Sub
'${AWS::AccountId}' } } },
              {
                'Effect': 'Allow',
                'Principal': { 'Service': 'containment.security-ir.amazonaws.com' },
                'Action': 'sts:TagSession',
              },
            ],
        }
      Policies:
        - PolicyName: AWSecurityIncidentResponseContainmentPolicy
          PolicyDocument:
            {
              'Version': '2012-10-17',

```

```

    'Statement':
    [
        {
            'Effect': 'Allow',
            'Action': ['ssm:StartAutomationExecution'],
            'Resource':
            [
                !Sub 'arn:${AWS::Partition}:ssm:*::document/AWSSupport-
ContainEC2Instance',
                !Sub 'arn:${AWS::Partition}:ssm:*::document/AWSSupport-
ContainS3Resource',
                !Sub 'arn:${AWS::Partition}:ssm:*::document/AWSSupport-
ContainIAMPrincipal',
                !Sub 'arn:${AWS::Partition}:ssm:*:${AWS::AccountId}:automation-
execution/*',
            ],
        },
        {
            'Effect': 'Allow',
            'Action':
                ['ssm:DescribeInstanceInformation', 'ssm:GetAutomationExecution',
'ssm:ListCommandInvocations'],
            'Resource': '*',
        },
        {
            'Effect': 'Allow',
            'Action': ['iam:PassRole'],
            'Resource': !GetAtt
AWSSecurityIncidentResponseContainmentExecution.Arn,
            'Condition': { 'StringEquals': { 'iam:PassedToService':
'ssm.amazonaws.com' } },
        },
    ],
}

AWSSecurityIncidentResponseContainmentExecution:
  Type: 'AWS::IAM::Role'
  Properties:
    RoleName: AWSSecurityIncidentResponseContainmentExecution
    AssumeRolePolicyDocument:
      {
        'Version': '2012-10-17',
        'Statement':
          [{ 'Effect': 'Allow', 'Principal': { 'Service': 'ssm.amazonaws.com' } },
'Action': 'sts:AssumeRole' ]],

```

```

    }
ManagedPolicyArns:
  - !Sub arn:${AWS::Partition}:iam::aws:policy/SecurityAudit
Policies:
  - PolicyName: AWSSecurityIncidentResponseContainmentExecutionPolicy
    PolicyDocument:
      {
        'Version': '2012-10-17',
        'Statement':
          [
            {
              'Sid': 'AllowIAMContainment',
              'Effect': 'Allow',
              'Action':
                [
                  'iam:AttachRolePolicy',
                  'iam:AttachUserPolicy',
                  'iam:DeactivateMFADevice',
                  'iam>DeleteLoginProfile',
                  'iam>DeleteRolePolicy',
                  'iam>DeleteUserPolicy',
                  'iam:GetLoginProfile',
                  'iam:GetPolicy',
                  'iam:GetRole',
                  'iam:GetRolePolicy',
                  'iam:GetUser',
                  'iam:GetUserPolicy',
                  'iam>ListAccessKeys',
                  'iam>ListAttachedRolePolicies',
                  'iam>ListAttachedUserPolicies',
                  'iam>ListMfaDevices',
                  'iam>ListPolicies',
                  'iam>ListRolePolicies',
                  'iam>ListUserPolicies',
                  'iam>ListVirtualMFADevices',
                  'iam:PutRolePolicy',
                  'iam:PutUserPolicy',
                  'iam:TagMFADevice',
                  'iam:TagPolicy',
                  'iam:TagRole',
                  'iam:TagUser',
                  'iam:UntagMFADevice',
                  'iam:UntagPolicy',
                  'iam:UntagRole',
                ]
            }
          ]
      }

```

```

        'iam:UntagUser',
        'iam:UpdateAccessKey',
        'identitystore:CreateGroupMembership',
        'identitystore:DeleteGroupMembership',
        'identitystore:IsMemberInGroups',
        'identitystore:ListUsers',
        'identitystore:ListGroups',
        'identitystore:ListGroupMemberships',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowOrgListAccounts',
    'Effect': 'Allow',
    'Action': 'organizations:ListAccounts',
    'Resource': '*',
},
{
    'Sid': 'AllowSSOContainment',
    'Effect': 'Allow',
    'Action':
    [
        'sso:CreateAccountAssignment',
        'sso:DeleteAccountAssignment',
        'sso:DeleteInlinePolicyFromPermissionSet',
        'sso:GetInlinePolicyForPermissionSet',
        'sso:ListAccountAssignments',
        'sso:ListInstances',
        'sso:ListPermissionSets',
        'sso:ListPermissionSetsProvisionedToAccount',
        'sso:PutInlinePolicyToPermissionSet',
        'sso:TagResource',
        'sso:UntagResource',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowSSORead',
    'Effect': 'Allow',
    'Action': ['sso-directory:SearchUsers', 'sso-
directory:DescribeUser'],
    'Resource': '*',
},
{

```

```

        'Sid': 'AllowS3Read',
        'Effect': 'Allow',
        'Action':
        [
            's3:GetAccountPublicAccessBlock',
            's3:GetBucketAcl',
            's3:GetBucketLocation',
            's3:GetBucketOwnershipControls',
            's3:GetBucketPolicy',
            's3:GetBucketPolicyStatus',
            's3:GetBucketPublicAccessBlock',
            's3:GetBucketTagging',
            's3:GetEncryptionConfiguration',
            's3:GetObject',
            's3:GetObjectAcl',
            's3:GetObjectTagging',
            's3:GetReplicationConfiguration',
            's3:ListBucket',
            's3express:GetBucketPolicy',
        ],
        'Resource': '*',
    },
    {
        'Sid': 'AllowS3Write',
        'Effect': 'Allow',
        'Action':
        [
            's3:CreateBucket',
            's3>DeleteBucketPolicy',
            's3>DeleteObjectTagging',
            's3:PutAccountPublicAccessBlock',
            's3:PutBucketACL',
            's3:PutBucketOwnershipControls',
            's3:PutBucketPolicy',
            's3:PutBucketPublicAccessBlock',
            's3:PutBucketTagging',
            's3:PutBucketVersioning',
            's3:PutObject',
            's3:PutObjectAcl',
            's3express:CreateSession',
            's3express>DeleteBucketPolicy',
            's3express:PutBucketPolicy',
        ],
        'Resource': '*',
    }

```

```

    },
    {
      'Sid': 'AllowAutoScalingWrite',
      'Effect': 'Allow',
      'Action':
        [
          'autoscaling:CreateOrUpdateTags',
          'autoscaling:DeleteTags',
          'autoscaling:DescribeAutoScalingGroups',
          'autoscaling:DescribeAutoScalingInstances',
          'autoscaling:DescribeTags',
          'autoscaling:EnterStandby',
          'autoscaling:ExitStandby',
          'autoscaling:UpdateAutoScalingGroup',
        ],
      'Resource': '*',
    },
    {
      'Sid': 'AllowEC2Containment',
      'Effect': 'Allow',
      'Action':
        [
          'ec2:AuthorizeSecurityGroupEgress',
          'ec2:AuthorizeSecurityGroupIngress',
          'ec2:CopyImage',
          'ec2:CreateImage',
          'ec2:CreateSecurityGroup',
          'ec2:CreateSnapshot',
          'ec2:CreateTags',
          'ec2>DeleteSecurityGroup',
          'ec2>DeleteTags',
          'ec2:DescribeImages',
          'ec2:DescribeInstances',
          'ec2:DescribeSecurityGroups',
          'ec2:DescribeSnapshots',
          'ec2:DescribeTags',
          'ec2:ModifyNetworkInterfaceAttribute',
          'ec2:RevokeSecurityGroupEgress',
        ],
      'Resource': '*',
    },
    {
      'Sid': 'AllowKMSActions',
      'Effect': 'Allow',

```

```

        'Action':
        [
            'kms:CreateGrant',
            'kms:DescribeKey',
            'kms:GenerateDataKeyWithoutPlaintext',
            'kms:ReEncryptFrom',
            'kms:ReEncryptTo',
        ],
        'Resource': '*',
    },
    {
        'Sid': 'AllowSSMActions',
        'Effect': 'Allow',
        'Action': ['ssm:DescribeAutomationExecutions'],
        'Resource': '*',
    },
],
}

```

Containment with EC2 Triage

Use this template if you want both containment capabilities and the ability for AWS Security Incident Response engineers to investigate running instances during an incident.

This template creates everything included in the containment-only template and adds the `AWSecurityIncidentResponseInvestigationPolicy` to the `AWSecurityIncidentResponseContainment` role. This policy grants the following permissions:

- Describe Amazon EC2 instances and their status
- Retrieve instance profile information
- Verify Systems Manager Agent connectivity on target instances
- Execute `ssm:SendCommand` to run investigative commands on instances

EC2 Triage allows AWS Security Incident Response engineers to collect volatile forensic data from running Amazon EC2 instances during an active security incident. This data can include running processes, network connections, logged-in users, and other operating system artifacts that would be lost if the instance were terminated or stopped.

```
AWSTemplateFormatVersion: '2010-09-09'
```

Description: 'Template for AWS Security Incident Response containment roles'

Resources:

AWSecurityIncidentResponseContainment:

Type: 'AWS::IAM::Role'

Properties:

RoleName: AWSecurityIncidentResponseContainment

AssumeRolePolicyDocument:

```
{
  'Version': '2012-10-17',
  'Statement':
  [
    {
      'Effect': 'Allow',
      'Principal': { 'Service': 'containment.security-ir.amazonaws.com' },
      'Action': 'sts:AssumeRole',
      'Condition': { 'StringEquals': { 'sts:ExternalId': !Sub
'${AWS::AccountId}' } } },
    },
    {
      'Effect': 'Allow',
      'Principal': { 'Service': 'containment.security-ir.amazonaws.com' },
      'Action': 'sts:TagSession',
    },
  ],
}
```

Policies:

- PolicyName: AWSecurityIncidentResponseContainmentPolicy

PolicyDocument:

```
{
  'Version': '2012-10-17',
  'Statement':
  [
    {
      'Effect': 'Allow',
      'Action': ['ssm:StartAutomationExecution'],
      'Resource':
      [
        !Sub 'arn:${AWS::Partition}:ssm:*::document/AWSSupport-
ContainEC2Instance',
        !Sub 'arn:${AWS::Partition}:ssm:*::document/AWSSupport-
ContainS3Resource',
        !Sub 'arn:${AWS::Partition}:ssm:*::document/AWSSupport-
ContainIAMPrincipal',
```

```

        !Sub 'arn:${AWS::Partition}:ssm:*:${AWS::AccountId}:automation-
execution/*',
        ],
    },
    {
        'Effect': 'Allow',
        'Action':
            ['ssm:DescribeInstanceInformation', 'ssm:GetAutomationExecution',
'ssm:ListCommandInvocations'],
        'Resource': '*',
    },
    {
        'Effect': 'Allow',
        'Action': ['iam:PassRole'],
        'Resource': !GetAtt
AWSSecurityIncidentResponseContainmentExecution.Arn,
        'Condition': { 'StringEquals': { 'iam:PassedToService':
'ssm.amazonaws.com' } },
    },
],
}
- PolicyName: AWSSecurityIncidentResponseInvestigationPolicy
PolicyDocument:
{
    'Version': '2012-10-17',
    'Statement':
    [
        {
            'Effect': 'Allow',
            'Action': [
                'ec2:DescribeInstanceStatus',
                'ec2:DescribeInstances',
                'ec2:DescribeRouteTables',
                'ec2:DescribeSecurityGroupRules',
                'iam:GetInstanceProfile',
                'ssm:DescribeInstanceInformation',
                'ssm:GetCommandInvocation'
            ],
            'Resource': '*'
        },
        {
            'Effect': 'Allow',
            'Action': [
                'ssm:SendCommand'
            ],
            'Resource': '*'
        }
    ]
}

```

```

        ],
        'Resource': '*'
    }
]
}
AWSSecurityIncidentResponseContainmentExecution:
  Type: 'AWS::IAM::Role'
  Properties:
    RoleName: AWSSecurityIncidentResponseContainmentExecution
    AssumeRolePolicyDocument:
      {
        'Version': '2012-10-17',
        'Statement':
          [{ 'Effect': 'Allow', 'Principal': { 'Service': 'ssm.amazonaws.com' } },
'Action': 'sts:AssumeRole' ]],
      }
    ManagedPolicyArns:
      - !Sub arn:${AWS::Partition}:iam::aws:policy/SecurityAudit
    Policies:
      - PolicyName: AWSSecurityIncidentResponseContainmentExecutionPolicy
        PolicyDocument:
          {
            'Version': '2012-10-17',
            'Statement':
              [
                {
                  'Sid': 'AllowIAMContainment',
                  'Effect': 'Allow',
                  'Action':
                    [
                      'iam:AttachRolePolicy',
                      'iam:AttachUserPolicy',
                      'iam:DeactivateMFADevice',
                      'iam>DeleteLoginProfile',
                      'iam>DeleteRolePolicy',
                      'iam>DeleteUserPolicy',
                      'iam:GetLoginProfile',
                      'iam:GetPolicy',
                      'iam:GetRole',
                      'iam:GetRolePolicy',
                      'iam:GetUser',
                      'iam:GetUserPolicy',
                      'iam>ListAccessKeys',
                      'iam>ListAttachedRolePolicies',

```

```

        'iam:ListAttachedUserPolicies',
        'iam:ListMfaDevices',
        'iam:ListPolicies',
        'iam:ListRolePolicies',
        'iam:ListUserPolicies',
        'iam:ListVirtualMFADevices',
        'iam:PutRolePolicy',
        'iam:PutUserPolicy',
        'iam:TagMFADevice',
        'iam:TagPolicy',
        'iam:TagRole',
        'iam:TagUser',
        'iam:UntagMFADevice',
        'iam:UntagPolicy',
        'iam:UntagRole',
        'iam:UntagUser',
        'iam:UpdateAccessKey',
        'identitystore:CreateGroupMembership',
        'identitystore:DeleteGroupMembership',
        'identitystore:IsMemberInGroups',
        'identitystore:ListUsers',
        'identitystore:ListGroups',
        'identitystore:ListGroupMemberships',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowOrgListAccounts',
    'Effect': 'Allow',
    'Action': 'organizations:ListAccounts',
    'Resource': '*',
},
{
    'Sid': 'AllowSSOContainment',
    'Effect': 'Allow',
    'Action':
    [
        'sso:CreateAccountAssignment',
        'sso:DeleteAccountAssignment',
        'sso:DeleteInlinePolicyFromPermissionSet',
        'sso:GetInlinePolicyForPermissionSet',
        'sso:ListAccountAssignments',
        'sso:ListInstances',
        'sso:ListPermissionSets',
    ]
}

```

```

        'sso:ListPermissionSetsProvisionedToAccount',
        'sso:PutInlinePolicyToPermissionSet',
        'sso:TagResource',
        'sso:UntagResource',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowSSORead',
    'Effect': 'Allow',
    'Action': ['sso-directory:SearchUsers', 'sso-
directory:DescribeUser'],
    'Resource': '*',
},
{
    'Sid': 'AllowS3Read',
    'Effect': 'Allow',
    'Action':
    [
        's3:GetAccountPublicAccessBlock',
        's3:GetBucketAcl',
        's3:GetBucketLocation',
        's3:GetBucketOwnershipControls',
        's3:GetBucketPolicy',
        's3:GetBucketPolicyStatus',
        's3:GetBucketPublicAccessBlock',
        's3:GetBucketTagging',
        's3:GetEncryptionConfiguration',
        's3:GetObject',
        's3:GetObjectAcl',
        's3:GetObjectTagging',
        's3:GetReplicationConfiguration',
        's3:ListBucket',
        's3express:GetBucketPolicy',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowS3Write',
    'Effect': 'Allow',
    'Action':
    [
        's3:CreateBucket',
        's3:DeleteBucketPolicy',

```

```

        's3:DeleteObjectTagging',
        's3:PutAccountPublicAccessBlock',
        's3:PutBucketACL',
        's3:PutBucketOwnershipControls',
        's3:PutBucketPolicy',
        's3:PutBucketPublicAccessBlock',
        's3:PutBucketTagging',
        's3:PutBucketVersioning',
        's3:PutObject',
        's3:PutObjectAcl',
        's3express:CreateSession',
        's3express:DeleteBucketPolicy',
        's3express:PutBucketPolicy',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowAutoScalingWrite',
    'Effect': 'Allow',
    'Action':
    [
        'autoscaling:CreateOrUpdateTags',
        'autoscaling:DeleteTags',
        'autoscaling:DescribeAutoScalingGroups',
        'autoscaling:DescribeAutoScalingInstances',
        'autoscaling:DescribeTags',
        'autoscaling:EnterStandby',
        'autoscaling:ExitStandby',
        'autoscaling:UpdateAutoScalingGroup',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowEC2Containment',
    'Effect': 'Allow',
    'Action':
    [
        'ec2:AuthorizeSecurityGroupEgress',
        'ec2:AuthorizeSecurityGroupIngress',
        'ec2:CopyImage',
        'ec2:CreateImage',
        'ec2:CreateSecurityGroup',
        'ec2:CreateSnapshot',
        'ec2:CreateTags',
    ]
}

```

```

        'ec2:DeleteSecurityGroup',
        'ec2:DeleteTags',
        'ec2:DescribeImages',
        'ec2:DescribeInstances',
        'ec2:DescribeSecurityGroups',
        'ec2:DescribeSnapshots',
        'ec2:DescribeTags',
        'ec2:ModifyNetworkInterfaceAttribute',
        'ec2:RevokeSecurityGroupEgress',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowKMSActions',
    'Effect': 'Allow',
    'Action':
    [
        'kms:CreateGrant',
        'kms:DescribeKey',
        'kms:GenerateDataKeyWithoutPlaintext',
        'kms:ReEncryptFrom',
        'kms:ReEncryptTo',
    ],
    'Resource': '*',
},
{
    'Sid': 'AllowSSMActions',
    'Effect': 'Allow',
    'Action': ['ssm:DescribeAutomationExecutions'],
    'Resource': '*',
},
],
}

```

Instance prerequisites for EC2 Triage

For EC2 Triage to collect investigative data from an Amazon EC2 instance, the instance must meet the following requirements:

- The Systems Manager Agent (SSM Agent) must be installed and running on the instance. For more information, see [Working with SSM Agent](#) in the *AWS Systems Manager User Guide*.

- The instance must be managed by AWS Systems Manager. This requires the instance to have an IAM instance profile with the appropriate Systems Manager permissions and network connectivity to the Systems Manager endpoints. For more information, see [Setting up AWS Systems Manager](#) in the *AWS Systems Manager User Guide*.
- The instance must be running a supported operating system:
 - **Linux:**
 - Amazon Linux 2
 - Amazon Linux 2023
 - Ubuntu 18.04, 20.04, 22.04, 24.04
 - Red Hat Enterprise Linux (RHEL) 7.x, 8.x, 9.x
 - CentOS 7.x, 8.x
 - SUSE Linux Enterprise Server (SLES) 12.x, 15.x
 - Debian 10, 11, 12
 - **Windows:**
 - Windows Server 2012 R2
 - Windows Server 2016
 - Windows Server 2019
 - Windows Server 2022

Enable Security Incident Response and configure your incident response team using the API/CLI

This section provides steps to enable AWS Security Incident Response, designate a delegated administrator for AWS Security Incident Response, and configure your incident response team using the API/CLI.

As a manager of the Organizations, make sure that you read the [Considerations and recommendations](#) on how a delegated Security Incident Response administrator account operates. Before proceeding, ensure that you have [Permissions required to designate a delegated Security Incident Response administrator account](#).

Onboard with a delegated administrator using the API/CLI (recommended)

1. Create the `AWSServiceRoleForSecurityIncidentResponse_Triage` service-linked role in your AWS Organizations management account:

```
aws iam create-service-linked-role --aws-service-name "triage.security-ir.amazonaws.com"
```

2. (Optional) To verify that the role was created, run the following command:

```
aws iam get-role --role-name AWSServiceRoleForSecurityIncidentResponse_Triage
```

3. From your AWS Organizations management account, register the delegated administrator account for AWS Security Incident Response:

```
aws organizations register-delegated-administrator \  
  --account-id delegated-admin-account-id \  
  --service-principal security-ir.amazonaws.com
```

4. Enable AWS Security Incident Response service access for your organization:

```
aws organizations enable-aws-service-access \  
  --service-principal security-ir.amazonaws.com
```

5. Sign in to the delegated administrator account to create a membership and designate your incident response team. You must list at least two incident response team members.

```
aws security-ir create-membership \  
  --membership-name "membership-name" \  
  --incident-response-team '[  
    {  
      "name": "name",  
      "jobTitle": "job-title",  
      "email": "email@example.com",  
      "communicationPreferences": ["Case Created", "Case Closed"]  
    },  
    {  
      "name": "name",  
      "jobTitle": "job-title",  
      "email": "email@example.com",  
      "communicationPreferences": ["Case Created", "Case Closed"]  
    }  
  ]'
```

6. (Optional) Verify that the membership was created:

```
aws security-ir list-memberships
```

7. (Optional) Get the membership details:

```
aws security-ir get-membership \  
--membership-id membership-id
```

Onboard with a management account using the API/CLI

1. Enable AWS Security Incident Response service access for your organization:

```
aws organizations enable-aws-service-access \  
--service-principal security-ir.amazonaws.com
```

2. Sign in to the management account to create a membership and designate your incident response team. You must list at least two incident response team members.

```
aws security-ir create-membership \  
--membership-name "membership-name" \  
--incident-response-team '[  
  {  
    "name": "name",  
    "jobTitle": "job-title",  
    "email": "email@example.com",  
    "communicationPreferences": ["Case Created", "Case Closed"]  
  },  
  {  
    "name": "name",  
    "jobTitle": "job-title",  
    "email": "email@example.com",  
    "communicationPreferences": ["Case Created", "Case Closed"]  
  }  
]'
```

3. (Optional) Verify that the membership was created:

```
aws security-ir list-memberships
```

4. (Optional) Get the membership details:

```
aws security-ir get-membership \  

```

```
--membership-id membership-id
```

RACI matrix

The following RACI matrix defines roles and responsibilities across the Security Incident Response implementation process. RACI stands for Responsible (R), Accountable (A), Consulted (C), and Informed (I).

Activity	Customer	AWS Account Team	SIR Team
Pre-Onboarding			
Identify Key Stakeholders	R		I
Validate Finding Sources	R	C	I
[3rd Party EDR integration] Security Hub CSPM	R	C	I
GuardDuty Validation/Health Check	C	R	I
Determine Account Scope	R		
Establish Escalation Protocols	R	I	C
Enable AWS Organizations	R	C	
Associate accounts with AWS Organizations	R	I	
Select Delegated Administrator / Security Tooling Account	R	I	
Onboarding			
Setup membership details	R	I	
Walkthrough (Setup proactive response and alert triaging)	R	C	I

Activity	Customer	AWS Account Team	SIR Team
workflows; Deploy service-linked role to management account; Authorize containment actions)			
Post-Deployment Configuration			
Review operational integration capabilities	R	C	I
Submit Security Incident Response Reactive Cases	R		
Configure Amazon EventBridge integrations	R	C	C
Connect 3rd party tooling (Jira, ServiceNow, PagerDuty, Teams, etc.)	R	I	C
Service deep dive and demo	A	R	C

RACI Definitions:

- **Responsible (R)** - The party who performs the work to complete the task
- **Accountable (A)** - The party ultimately answerable for the correct completion of the task
- **Consulted (C)** - The party whose opinions are sought and with whom there is two-way communication
- **Informed (I)** - The party who is kept up-to-date on progress and with whom there is one-way communication

Proactive response and alert triaging

AWS Security Incident Response monitors and investigates threat alerts generated from Amazon GuardDuty and third-party threat detection tools using Security Hub CSPM integrations. AWS Security Incident Response automatically triages all supported alerts so your team can focus on the most critical issues.

 Important

AWS Security Incident Response doesn't require you to enable Amazon GuardDuty. However, the proactive response feature relies on receiving threat findings from detection services. If you don't have Amazon GuardDuty or Security Hub CSPM configured to ingest findings, AWS Security Incident Response won't have alerts to monitor and investigate, which limits the value of this feature.

AWS Security Incident Response monitors and investigates findings across all covered accounts and active supported AWS Regions in your organization. To facilitate this functionality, AWS Security Incident Response automatically creates a service-linked role in all covered member accounts within your AWS Organizations.

If you [onboard](#) to AWS Security Incident Response in the AWS Management Console, Security Incident Response automatically creates the `AWSServiceRoleForSecurityIncidentResponse_Triage` service-linked role in your AWS Organizations management account and in all accounts that are in scope. If you onboarding using the API/CLI, then you must create the role manually. For more information, see [Enable Security Incident Response and configure your incident response team using the API/CLI](#).

If you experience onboarding issues or need help enabling Amazon GuardDuty or Security Hub CSPM, [create an AWS Support case](#) for assistance.

 Note

If you have questions about Amazon GuardDuty suppression rules, alert triaging configurations, or proactive response workflows, you can create an AWS supported case with the case type **Investigations and Inquiries** to consult with the AWS Security Incident Response team. For more information, see [Create an AWS supported case](#).

Understanding Automatic Archiving with Proactive Response

When you enable proactive response and alert triaging, AWS Security Incident Response automatically monitors and triages security findings from Amazon GuardDuty and Security Hub CSPM. As part of this auto-triage workflow, findings are automatically archived based on the following criteria:

Automatic archiving behavior:

- **Benign findings:** When the auto-triage process determines that a finding is benign (not a true security threat), AWS Security Incident Response automatically archives the finding in Amazon GuardDuty and creates suppression rules to prevent similar findings from generating alerts in the future.
- **Suppression rules:** The service creates suppression and auto-archive rules in both Amazon GuardDuty and Security Hub CSPM for findings that match your environment's known-good patterns, such as expected IP addresses, IAM entities, and normal operational behaviors.
- **Reduced alert volume:** Organizations using SIEM technology see significantly reduced Amazon GuardDuty finding volumes over time as the service learns your environment and automatically archives benign findings. This improves efficiency for both the AWS Security Incident Response service and your SIEM.

Viewing archived findings:

You can review automatically archived findings and the suppression rules created by AWS Security Incident Response:

1. Navigate to the Amazon GuardDuty console
2. Choose **Findings**
3. Select **Archived** from the findings filter
4. Review the suppression rules by selecting the down arrow next to each rule

Important considerations:

- Archived findings are retained in Amazon GuardDuty for 90 days and can be viewed at any time during that period
- You can modify or delete suppression rules at any time through the Amazon GuardDuty console
- The auto-triage process continuously adapts to your environment, improving accuracy over time and reducing false positives

Containment: In the event of a security incident, AWS Security Incident Response can execute containment actions to quickly mitigate the impact, such as isolating compromised hosts or rotating credentials. Security Incident Response doesn't enable containment capabilities by default. To execute these containment actions, you must first grant the necessary permissions to

the service. This can be done by deploying an [AWS CloudFormation StackSet](#), which creates the required roles.

Validating your AWS Security Incident Response configuration

After you complete onboarding, you can validate that enrollment, detection sources, AWS Identity and Access Management (IAM) permissions, containment, and notifications are configured correctly before a real security event occurs. This section provides step-by-step verification procedures using both the AWS Management Console and the AWS CLI.

Topics

- [Before you validate](#)
- [Step 1: Verify enrollment and membership](#)
- [Step 2: Verify detection sources and triage](#)
- [Step 3: Verify the automated finding pipeline](#)
- [Step 4: Verify notifications and incident response team](#)
- [Step 5: Verify containment readiness \(optional\)](#)
- [Step 6: Confirm ongoing operation](#)
- [Validation checklist](#)
- [Billing verification](#)
- [Troubleshooting](#)
- [Related resources](#)

Before you validate

Prerequisites for validating your Security Incident Response configuration

To complete these validation steps, make sure that you have the following:

- Console or AWS Command Line Interface (AWS CLI) access to your **delegated administrator account** (the account you designated during onboarding)
- The AWS Region where you activated your subscription
- Your membership ID (if validating using the AWS CLI)

Confirm log readiness

AWS Security Incident Response doesn't enable log sources on your behalf. During an investigation, engineers rely on logs that are already present in your environment. Before validating your setup, confirm the following logs are enabled in all covered accounts and AWS Regions. Without these logs, Security Incident Response engineers have limited visibility during investigations. Enable them before proceeding.

- **AWS CloudTrail:** management events trail (required)
- **Amazon VPC Flow Logs** (recommended)
- **Amazon S3 server access logging** for sensitive buckets (recommended)
- **Amazon Route 53 Resolver DNS query logging** (recommended)

Verify GuardDuty is enabled

Use the following command to verify that Amazon GuardDuty is active in your accounts:

```
aws guardduty list-detectors
```

A non-empty response confirms GuardDuty is enabled in the current AWS Region. Repeat this step for each active Region, or verify across your organization through the GuardDuty delegated administrator account.

Note

AWS Security Incident Response costs don't include GuardDuty usage costs. See the [GuardDuty pricing page](#) for details.

Step 1: Verify enrollment and membership

Using the AWS Security Incident Response console

1. Sign in to the delegated administrator account.
2. Open the [AWS Security Incident Response console](#).
3. Confirm that your membership status shows **Active**. A status of *Pending* indicates onboarding is incomplete.

4. Under **Account scope**, verify that the OUs you intended to cover are listed. Coverage is selected at the organizational unit (OU) level, not at the individual account level. All accounts within a selected OU (including child OUs) are covered.
5. Confirm that the **Region** listed matches where your workloads run. Region selection is locked at registration and can't be changed after setup.

Using the AWS CLI

Run the following command from your delegated administrator account:

```
aws security-ir list-memberships
```

The preceding command returns your membership ID and status.

To get full membership details including your incident response team configuration, run the following command:

```
aws security-ir get-membership --membership-id membership-id
```

Use the command output to verify the following information.

- Membership status is Active
- The incident response team members listed match your intended stakeholders
- At least two incident response team members are configured (required)

Verify the delegated administrator

To confirm that the correct account is registered as the delegated administrator for Security Incident Response, run the following command:

```
aws organizations list-delegated-administrators \  
--service-principal security-ir.amazonaws.com
```

Note

Best practice: Use the same delegated administrator account that you set for other AWS security services (such as AWS Security Hub CSPM and GuardDuty). The [AWS Security Reference Architecture](#) recommends using the Security Tooling account.

Step 2: Verify detection sources and triage

AWS Security Incident Response monitors security findings from GuardDuty and third-party tools through Security Hub CSPM. The service uses a service-linked role to ingest findings through Amazon EventBridge rules deployed to your accounts during onboarding.

Verify the Triage service-linked role

The `AWSServiceRoleForSecurityIncidentResponse_Triage` service-linked role must exist in your management account and all in-scope member accounts.

To verify, run the following command in the management and in-scope member accounts:

```
aws iam get-role --role-name AWSServiceRoleForSecurityIncidentResponse_Triage
```

A successful response confirms the role exists. If you receive a `NoSuchEntity` error, do one of the following:

- **If you onboarded using the console:** The role should have been created automatically. Contact AWS Support.
- **If you onboarded using the API or AWS CLI:** See [Enable Security Incident Response using the API/CLI](#) for instructions on manually creating the role.

Verify the primary service-linked role

The `AWSServiceRoleForSecurityIncidentResponse` role should also exist in your delegated administrator account. To verify that the role exists, run the following command:

```
aws iam get-role --role-name AWSServiceRoleForSecurityIncidentResponse
```

Verify proactive response and EventBridge rules

In the AWS Security Incident Response console, confirm that **Proactive response** shows as enabled. When enabled, the service does the following:

- Ingests findings from GuardDuty and Security Hub CSPM through EventBridge rules
- Automatically triages findings using customer-specific context (known IPs, expected IAM entities)
- Creates proactive investigation cases when confirmed security issues are identified
- Archives GuardDuty findings determined to be benign (viewable in the GuardDuty console under **Archived findings**)

Verify EventBridge rules are deployed in member accounts

To verify that EventBridge rules are deployed in member accounts, complete the following steps.

1. Open the Amazon EventBridge console in a covered member account.
2. Choose **Rules**.
3. Confirm that rules with SIR in their name are present and **Enabled**.

If the rules are missing, re-run the proactive response setup from the Security Incident Response console or contact AWS Support.

Verify third-party integrations (if applicable)

If you use third-party detection tools (such as CrowdStrike Falcon, Trend Micro Cloud One, or Fortinet Lacework FortiCNAPP), verify that their findings are flowing through Security Hub CSPM:

1. Open the [AWS Security Hub CSPM console](#).
2. Go to **Integrations**.
3. Confirm your third-party vendor integration shows as **Accepting findings**.

Note

You don't need to enable Security Hub CSPM standards or controls. Only the vendor integrations are required for Security Incident Response to ingest third-party findings.

Step 3: Verify the automated finding pipeline

This step confirms that the EventBridge pipeline is active and findings are reaching automated triage.

About GuardDuty sample findings

GuardDuty's built-in **Generate sample findings** feature produces findings marked as samples. Automated triage filters sample findings to prevent noise; they don't flow through the full triage pipeline and can't be used to validate your Security Incident Response configuration. **Don't use them for this step.**

Validate with the GuardDuty test domain

The GuardDuty documentation provides a test domain (guardduty2activityb.com) that generates a real finding without requiring real-world security events. Querying this domain from an Amazon EC2 instance in a covered account produces a finding that Security Incident Response ingests and processes.

To generate a test finding:

1. Connect to an Amazon EC2 instance in a covered account using Systems Manager Session Manager or SSH.
2. Run the following command:

```
dig guardduty2activityb.com
```

3. Open the GuardDuty console, then choose **Findings**. The finding appears within approximately 5 minutes.

What to expect:

- Automated triage processes the finding and determines it isn't indicative of a genuine security event.
- The finding is **archived** in GuardDuty. To view it, select **Archived** from the **Status** filter.
- If you use Security Hub CSPM, the finding's workflow status changes to SUPPRESSED.
- **No proactive case is created:** this is correct behavior. A case is only opened when automated triage identifies activity that warrants human investigation.

Note

If the test finding doesn't appear in the GuardDuty archived list within 15 minutes, see [Troubleshooting](#). If no Amazon EC2 instance is available, proceed to Step 4 and return to this test when your environment is ready.

Step 4: Verify notifications and incident response team

Verify your incident response team

In the Security Incident Response console, review your configured incident response team members. Each member receives immediate email notifications when a case is created.

Or, run the following command to verify using the AWS CLI:

```
aws security-ir get-membership --membership-id membership-id
```

Confirm that:

- All intended stakeholders are listed
- Email addresses are correct
- Each member's communication preferences are set appropriately (all communication options are enabled by default — if a member isn't receiving notifications, verify their preferences haven't been cleared)

Understanding case watchers

Case watchers are stakeholders who are granted access to view a specific case. Key details:

- **Watchers are per case, not per account.** Adding a watcher to one case doesn't grant them access to any other case. You must explicitly add watchers to each case where you want them to have visibility.
- **Watchers have view-only access.** They can view case details and receive notifications for case updates, but can't perform containment or remediation actions on resources.
- **Up to 30 stakeholders** can be added per individual case.
- Each case includes a pre-scoped IAM policy that grants access only to that specific case, maintaining least-privilege access.

This per-case scoping is particularly important when granting access to external parties such as managed detection and response (MDR) partners or third-party investigation teams who should only see the specific case they're involved in.

Verify notification delivery with a test case

The most effective way to validate end-to-end notification flow is to create a reactive (self-managed) test case:

1. In the Security Incident Response console, create a new **self-managed case**.
2. In the case title and description, clearly state: **"This is a configuration validation test, there is no real security event."**
3. Verify that all configured incident response team members receive the email notification.
4. Close the case after confirming notifications were received.

Important

Creating a test case may trigger a response from Security Incident Response engineers if you request AWS-supported engagement. Clearly mark your case as a test to avoid unnecessary escalation. Use this step once to confirm the channel is working, then close the case promptly.

What to expect from case notifications

When a case is created (either proactively by the service or reactively by your team), all configured incident response team members receive an email notification containing the case details.

Verify EventBridge integration (if configured)

If you configured EventBridge to route case events to third-party platforms (such as ServiceNow, Jira, Slack, or PagerDuty), verify that your test case triggers the expected notification in those systems.

Step 5: Verify containment readiness (optional)

Note

Containment is optional and isn't enabled by default. The containment infrastructure described in this section is only required if you choose to enable containment; it isn't needed for Security Incident Response to monitor your environment, investigate findings, or open cases.

If you haven't enabled containment

Nothing to validate here. Security Incident Response provides guidance and investigation during security events but doesn't take automated containment actions unless you explicitly authorize it.

If you have enabled containment

Check containment status in the console. Verify whether containment actions are shown as **Authorized**. Supported containment actions include runbooks for:

- Affected Amazon S3 buckets
- Affected Amazon EC2 instances
- Affected IAM principals

Verify the CloudFormation StackSet is deployed. Containment requires IAM roles (AWSSecurityIncidentResponseContainment and AWSSecurityIncidentResponseContainmentExecution) in your covered accounts. For instructions on deploying these roles, see [Deploy containment and EC2 Triage roles](#). To verify the StackSet is deployed:

1. Open AWS CloudFormation in your management account.
2. Choose **StackSets**.
3. Confirm the Security Incident Response containment StackSet shows SUCCEEDED in all target accounts.

If the StackSet isn't deployed, containment authorization in the console doesn't result in actual containment actions being taken.

Confirm your containment preference. Security Incident Response supports three containment levels:

- **Approval Required** (default): no containment action without your explicit case-by-case authorization.
- **Contain Confirmed**: proactive containment of resources confirmed as affected.
- **Contain Suspected**: proactive containment of resources with high likelihood of being affected.

To submit or update your preference, create an AWS Support case with case type **Technical: Security Incident Response Service / Other**.

If you want EC2 Triage: Deploy the **Containment with EC2 Triage** CloudFormation template. This allows Security Incident Response engineers to collect investigative data from Amazon EC2 instances using AWS Systems Manager.

Step 6: Confirm ongoing operation

After completing initial validation, use these indicators to confirm that Security Incident Response is continuously operating as expected.

The absence of cases is normal

Security Incident Response creates a proactive case only when automated triage identifies activity that warrants human investigation. When triage determines a finding is benign, it archives the finding without creating a case or contacting your team. A deployment with no open cases and a consistent flow of archived GuardDuty findings is operating as intended.

If you see no cases *and* no archived findings after your environment has been active for several days, the pipeline may not be connected; verify Steps 2 and 3.

Note

Proactive cases with no customer response for 5 days are automatically closed.

Archived findings and suppression rules as health signals

As Security Incident Response processes findings over time, it creates two observable artifacts:

- **Archived findings:** findings that automated triage determined to be benign. These accumulate over time and are visible in the GuardDuty console under **Findings**, then select **Archived**.
- **GuardDuty suppression rules:** for finding types confirmed as expected activity in your environment, Security Incident Response deploys named suppression rules (prefixed with SIRTriage-). These are the clearest ongoing signal that automated triage is actively working. View them in the GuardDuty console under **Suppression rules**.

Your incident response team is notified when a suppression rule is created. If a rule was created in error, contact AWS Support to request a rollback. Archived findings are retained in GuardDuty for 90 days.

Monthly activity report

Security Incident Response sends a monthly activity report to your incident response team summarizing findings processed, triage outcomes, and any cases that were opened. If your team hasn't received a report after your first full calendar month of operation, verify that incident response team members have communications enabled. For any other issues related to the monthly report, contact your Account Team or open a Support Case with case type: **Technical: Security Incident Response Service / Other** and include the following information:

- Your organization name
- The reporting month/year you expected (for example, "May 2026")
- Your Security Incident Response Membership ID if known
- The account IDs covered by your Security Incident Response membership

What to expect from Security Incident Response engineers

When you create an AWS-supported case or the service proactively creates one, Security Incident Response engineers acknowledge new cases within **15 minutes**. This 15-minute acknowledgment SLO applies to all AWS-supported case types; both active security events and investigations. The initial acknowledgment confirms your case is being reviewed; the full assessment timeline may vary based on case severity and complexity.

For proactive cases (auto-created when the triage service identifies a confirmed security issue), the service creates the case after automated triage confirms the issue, and your incident response team is notified when the case is opened.

Validation checklist

Use this checklist to confirm your configuration is complete:

- Log sources enabled: CloudTrail management events (required), Amazon VPC Flow Logs, Amazon S3 access logging, DNS query logging (recommended)
- GuardDuty is enabled in all accounts and active Regions
- Membership status is **Active** in the Security Incident Response console
- Region is correct (locked at registration)
- Delegated administrator account is correct (Security Tooling account recommended)
- Account scope covers intended OUs
- `AWSServiceRoleForSecurityIncidentResponse_Triage` exists in management account
- `AWSServiceRoleForSecurityIncidentResponse_Triage` exists in in-scope member accounts
- `AWSServiceRoleForSecurityIncidentResponse` exists in delegated administrator account
- Third-party integrations (if applicable) show as accepting findings in Security Hub CSPM
- EventBridge rules with SIR in the name are present and enabled in member accounts
- Incident response team members are configured with correct contact information and communications enabled
- Test case created and email notifications received by all team members
- Test domain finding (`guarddutyactivityb.com`) archived within 15 minutes
- Containment StackSet deployed successfully (if containment enabled)
- Containment preference submitted (if containment enabled)
- EventBridge integrations (if configured) are delivering events to third-party platforms
- Archived findings visible in GuardDuty after first week of operation

Billing verification

Enterprise Support and Unified Operations customers: Security Incident Response is included at no additional cost as part of your support plan. You don't see Security Incident Response charges in AWS Cost Explorer or the AWS Cost and Usage Report.

All other customers: Pricing is based on the number of security findings ingested. The first 10,000 findings per month are free. For details, see [AWS Security Incident Response pricing](#).

Troubleshooting

Symptom	Likely cause	Resolution
Membership status is Pending	Onboarding not completed	Complete all setup steps. See Getting started .
<code>list-memberships</code> returns empty	CLI Region doesn't match subscription Region	Specify the Region where you activated: <code>--region <i>region</i></code>
Triage SLR not found in management account	Onboarded via API/CLI without creating it	Create manually: <code>aws iam create-service-linked-role --aws-service-name "triage.security-ir.amazonaws.com"</code>
Member accounts missing from coverage	SLR not deployed to member account	Re-run proactive response setup from the Security Incident Response console
EventBridge rules not present in an account	Proactive response setup incomplete	Re-run setup or check for StackSet failures in CloudFormation
GuardDuty sample findings not processed	Sample findings are filtered by automated triage (expected)	Check archived findings in GuardDuty
Test domain finding not archived after 15 min	EventBridge rules missing or disabled; GuardDuty not enabled	Verify Steps 2 and 3
No cases after extended period	All findings archived by triage (expected), or pipeline not connected	Check archived findings in GuardDuty. If none exist, verify EventBridge rules and proactive response.
No GuardDuty findings being triaged	GuardDuty not enabled or not generating findings	Verify GuardDuty is enabled: <code>aws guardduty list-detectors</code>

Symptom	Likely cause	Resolution
Service not processing findings	Automated triage determined that the detected activity is expected	Review GuardDuty Archived findings and Security Hub CSPM SUPPRESSED findings
Team members not receiving notifications	Incorrect email, communications disabled, or email in spam	Verify email addresses and communication preferences; check spam folders
Containment actions not executing	StackSet not deployed or preference not submitted	Verify StackSet status in CloudFormation and confirm preference submitted via AWS Support

Related resources

- [Onboarding prerequisites](#)
- [Step 1: Enable AWS Security Incident Response](#)
- [Using service-linked roles](#)
- [Contain](#)
- [Considerations and recommendations for using AWS Security Incident Response with AWS Organizations](#)
- [Enable Security Incident Response and configure your incident response team using the API/CLI](#)
- [AWS Security Incident Response pricing](#)
- [Amazon GuardDuty pricing](#)

User tasks

Contents

- [Security Incident Response dashboard](#)
- [Managing my Incident Response Team](#)
- [Cases](#)
- [Managing Cases](#)
- [Cancel Membership](#)

Security Incident Response dashboard

On the AWS Security Incident Response console, the dashboard provides you with an overview of your incident response team, your proactive response status, and a four-week rolling count of cases.

Incident Response Team

Select **View incident response team** to access details of your incident response teammates.

My Cases

The **My Cases** section of the dashboard shows the number of opened and closed AWS supported cases, along with self-managed cases assigned to you within a defined period. It also shows the mean time it took to resolve the closed cases in hours.

Managing my Incident Response Team

Your incident response teams contains stakeholders for the incident response process. You can configure up to ten stakeholders as part of your membership.

Examples for internal stakeholders include members of your incident response team, security analysts, application owners, and your security leadership team.

Examples for external stakeholders include individuals from independent software vendors (ISV) and managed service providers (MSP) that you want to include in an incident response process.

Note

Setting up your incident response team does not automatically grant teammates access to service resources such as membership and cases. You can use AWS managed policies for AWS Security Incident Response to grant read and write access to resources. [Click here to learn more.](#)

Your incident response teammates specified on a membership level will be automatically added to any case. You can add or remove individual teammates at any time after a case has been created.

The incident response team will receive an email notification on the events listed in [communication preferences](#).

Communication preferences

Configure your communication preferences to control how you receive notifications and interact with the incident response system during security incidents.

Manage Team Communication Preferences

You can configure communication preferences for individuals in your incident response team from the dashboard page.

Follow these steps to manage team member communication settings:

1. Navigate to the incident response team page from your dashboard
2. Do one of the following:
 - To update an existing team member: Select the teammate whose communication preferences you want to modify, then choose **Edit**
 - To add a new team member: Choose **Add**
3. At the bottom of the form you will see Communications
 - a. Select the checkboxes for communications you want to receive
 - b. Clear the checkboxes for communications you do not want to receive

Communication Options

Your communication preferences control how you interact with the incident response system and how notifications are delivered to you during security incidents.

Note

These preferences apply to all future communications within the Security Incident Response system. You can modify these settings at any time by repeating the steps above.

Account association to AWS Organizations

When you enable AWS Security Incident Response, you will be given the option of selecting your entire organization or specific organizational units (OUs). If specific OUs are selected, your membership will only cover the accounts that fall under those selected OUs. If the entire organization is selected, then your membership will cover all the accounts within your organization.

For more detail, please see [Managing AWS Security Incident Response accounts with AWS Organizations](#).

Managing Your Membership Coverage

You can change your membership coverage option at any time, including switching from organization-wide coverage to specific OUs.

Updating OU Associations

To manage your membership coverage:

1. Navigate to the Account association settings page
2. Select **Add OUs** to select the OUs you want to associate with your membership
3. Select the OUs you want to associate with your membership
4. Click **Update Association** to save the OU association on your membership

After updating your associations, you can return to the same page and remove any OUs that you would like to disassociate from your membership. This flexibility applies even if you initially

selected your entire organization—you can later update your membership to cover only specific OUs without canceling and re-enabling the service.

For more information, please see [Managing membership with organizational units \(OUs\)](#).

Important Considerations

Accounts directly under the root: When selecting specific OUs for your membership, accounts that are directly under the organization root (not part of any OU) will not be associated with your membership. To include these accounts in your membership coverage, you must first add them to an OU, then associate that OU with your membership.

Note

AWS Security Incident Response is continuously improving the OU association user experience to make the process more intuitive and self-explanatory.

Monitoring and investigation

AWS Security Incident Response reviews and triages security alerts from Amazon GuardDuty and AWS Security Hub CSPM, then configures suppression rules based on your environment to prevent unnecessary alerts. The Security Incident Response Engineering team investigates findings and quickly escalates and guides your team to rapidly contain potential issues. If desired, you can grant AWS Security Incident Response permission to implement containment actions on your behalf.

AWS Security Incident Response aligns to the NIST 800-61r2 [Computer Security event Handling Guide](#) for Security event Response. By aligning to this industry standard, AWS Security Incident Response provides a consistent approach to security event management and adhere to best practices in securing and responding to security events in your AWS environment.

When AWS Security Incident Response identifies a security alert or you request security assistance, Security Incident Response Engineering investigates. The team collects log events and service data such as GuardDuty alerts, triages and analyzes that data, performs remediation and containment activities, and provides post-incident reporting.

Contents

- [Prepare](#)
- [Detect and Analyze](#)

Prepare

The AWS Security Incident Response team investigates and partners with you throughout the security event response lifecycle. It is recommended that you set up this team and assign the necessary permissions before a security event occurs.

Detect and Analyze

Reporting an event

You can raise a security event through the AWS Security Incident Response portal. It's important not to wait during a security event. AWS Security Incident Response uses automated and manual techniques to investigate security events, analyze logs, and look for anomalous patterns. Your partnership and understanding of your environment accelerates this analysis.

Enabling supported sources of detection

Note

AWS Security Incident Response service costs do not include usage and other costs and fees associated with supported sources of detection or use of other AWS services. Please refer to individual feature or service pages for cost details.

Amazon GuardDuty

To enable GuardDuty across your organization, please see the [Setting up GuardDuty](#) section of the [Amazon GuardDuty User Guide](#).

AWS highly recommends that you enable GuardDuty in all supported AWS Regions. This enables GuardDuty to generate findings about unauthorized or unusual activity even in regions that you are not actively using. For more information, reference [Amazon GuardDuty Regions and endpoints](#)

Enabling GuardDuty provides AWS Security Incident Response access to critical threat detection data, enhancing its ability to identify and respond to potential security issues in your AWS environment.

AWS Security Hub CSPM

AWS Security Hub CSPM can ingest security findings from several AWS services and supported third-party security solutions. These integrations can help AWS Security Incident Response monitor and investigate findings coming from other detection tools.

To enable Security Hub CSPM with Organizations integration please refer to the [AWS Security Hub CSPM User Guide](#).

There are multiple ways of enabling integrations on Security Hub CSPM. For third-party product integrations, you may need to purchase the integration from the AWS Marketplace, and then configure the integration. The integration information provides links to complete these tasks. Learn more about [how to enable AWS Security Hub CSPM integrations](#).

AWS Security Incident Response can monitor and investigate findings from the following tools when they're integrated with AWS Security Hub CSPM:

- [CrowdStrike – CrowdStrike Falcon](#)
- [Lacework – Lacework](#)
- [Trend Micro – Cloud One](#)

By enabling these integrations, you can significantly enhance the scope and effectiveness of AWS Security Incident Response's monitoring and investigation capabilities.

Detection

With [Proactive Response](#), AWS Security Incident Response ingests findings from Amazon GuardDuty and AWS Security Hub CSPM through Amazon EventBridge rules that are deployed to your accounts during onboarding.

Analysis: Automated triage

AWS Security Incident Response automatically triages security findings. The triage process determines whether detected activity represents expected behavior, by analyzing data from multiple sources including the finding payload, AWS service metadata, AWS logging and monitoring data (such as AWS CloudTrail and VPC Flow Logs), AWS threat intelligence, and context that you are invited to provide about your AWS and on-premises environments.

If automated triage determines that the detected activity is expected, the system takes no further investigative action.

Analysis: Incident response security investigation

AWS Security Incident Response Engineering is a global, always-available team of security professionals with expertise in AWS and security incident response. If automated triage cannot determine that the activity is expected, AWS Security Incident Response Engineering is engaged to perform a security investigation. If the event was ingested from Security Hub, a note is posted to the related finding stating that AWS Security Incident Response Engineering's investigation is underway.

AWS Security Incident Response Engineering conducts a hands-on security investigation by analyzing additional service metadata and threat intelligence, reviewing insights from past findings and investigations in your environment, and applying incident response expertise. Depending on your Containment preferences (see [Contain](#)) AWS Security Incident Response Engineering may engage your organization's Incident Response team through a Security Incident Response case in the AWS Security Incident Response console to verify whether the detected activity is expected and authorized [Responding to an AWS generated case](#).

As part of a security investigation, AWS Security Incident Response can also collect investigative information from within Amazon Elastic Compute Cloud instances using EC2 Triage. When enabled, this capability allows AWS Security Incident Response responders to execute AWS Systems Manager Run Command on Amazon EC2 instances to gather investigative data, inspect running processes, and analyze system state — without requiring direct access to the instance.

EC2 Triage supports the following operating systems:

Linux

- Amazon Linux 2, Amazon Linux 2023
- Ubuntu 18.04, 20.04, 22.04, 24.04
- Red Hat Enterprise Linux (RHEL) 7.x, 8.x, 9.x
- CentOS 7.x, 8.x
- SUSE Linux Enterprise Server (SLES) 12.x, 15.x
- Debian 10, 11, 12

Windows

- Windows Server 2012 R2
- Windows Server 2016, 2019, 2022

To use EC2 Triage, you must deploy the **Containment with EC2 Triage** CloudFormation template to your accounts. For more information, see [Deploy containment and EC2 Triage roles](#). The target Amazon EC2 instances must have [SSM Agent](#) installed and running, and must be online and managed by AWS Systems Manager. For setup information, see [Setting up Systems Manager for Amazon EC2 instances](#).

Communicate

AWS Security Incident Response keeps you informed during security investigations by engaging with your Incident Response team through a Security Incident Response case. Multiple AWS Security Incident Response Engineering members may support an investigation. Communication may include: acknowledgment or notification of the creation of a security investigation; establishing a call bridge; analysis of artifacts such as log files; requests for confirmation of expected activity; and sharing of investigation results.

When AWS Security Incident Response proactively engages your Incident Response team, a case is created in your AWS Security Incident Response Membership account, which centralizes communication for all Organizational accounts in one place. These cases contain the "[Proactive case]" prefix in their title, which identifies them as initiated by AWS Security Incident Response. By actively engaging and providing timely responses to these communications, your Incident Response team can assist AWS Security Incident Response to do the following:

- Ensure rapid response to genuine security incidents.
- Understand your environment and expected behaviors.
- Reduce false positive detections over time.

The effectiveness of AWS Security Incident Response improves with your collaboration and results in a more effectively monitored and secure AWS environment.

Updating findings

Updating Findings

AWS Security Incident Response manages findings differently depending on their source and triage outcome.

Amazon GuardDuty findings

AWS Security Incident Response archives Amazon GuardDuty findings only when triage determines that the detected activity is benign or associated with expected activity. Archiving behavior depends on the triage outcome category of each finding.

Findings that are archived:

- **Benign/Expected Activity (automated triage):** Activity determined by automated triage to be benign or associated with expected activity.
- **Benign/Expected Activity (manual investigation):** Activity confirmed as benign or associated with expected activity after further analysis by AWS Security Incident Response.

Findings that aren't archived:

- **Unconfirmed Activity:** Findings determined to require customer engagement and pending customer confirmation on whether the activity is expected or benign.
- **Inappropriate/Unintended Activity:** Findings determined to represent confirmed inappropriate or unintended activity that requires customer review or action.
- **Posture Related:** Finding relates to your security posture (for example, overly permissive policies, configuration, or missing encryption). These aren't threat findings, but they're retained without archiving by design.

Findings that aren't archived remain visible in the GuardDuty console with their current status. The absence of archiving for these finding categories doesn't indicate that AWS Security Incident Response took no action — it reflects the design intent that these findings remain available for your review.

You can view archived findings in the GuardDuty console by selecting **Archived** on the status drop-down menu. For more information about working with archived findings, see [Working with findings](#) in the *Amazon GuardDuty User Guide*.

AWS Security Hub CSPM findings

When Security Hub CSPM findings are ingested, the system updates each finding with a note indicating that automated triage has begun. The workflow state changes from NEW to NOTIFIED, which removes the finding from the default Security Hub CSPM findings view. If triage determines that a finding is benign or associated with expected activity, the system adds a note to the finding and updates the workflow state to SUPPRESSED.

Service tuning

Service Tuning

When your account service quotas permit, AWS Security Incident Response attempts to deploy an [Amazon GuardDuty suppression rule](#) or an [AWS Security Hub CSPM automation rule](#). These rules suppress future findings matching the type and source of known authorized activity (for example, source IP address, ASN, identity principal, or resource). AWS Security Hub CSPM rules are deployed with priority 10, which allows you to override these automations with self-defined rules if needed.

In this way, AWS Security Incident Response tunes detection sources based on expected behavior in your AWS environment. Your Incident Response Team is notified of modifications to these rule-sets, and changes are rolled-back upon request.

AI Investigative Agent

Overview

The AI-powered investigation agent works alongside customers and AWS Security Incident Response engineers to expedite security investigations. When a customer creates an AWS supported case, the agent automatically activates in parallel with Security Incident Response engineer engagement, reducing resolution time from days to hours.

During customer escalations, Security Incident Response cases might be created by you or proactively by AWS Security Incident Response. When a new AWS supported case is created, the investigative agent automatically triggers. You can manage all cases through the console, API, or Amazon EventBridge integrations.

Key benefits

- **Parallel investigation** – The agent works simultaneously with responders—providing both AI-powered automation and human expertise.
- **Automated evidence gathering** – Eliminates manual log analysis by automatically querying AWS CloudTrail, IAM, Amazon EC2, and Cost Explorer.
- **Natural language interface** – Describe security concerns in plain language without needing expertise in AWS log formats.
- **Faster response** – Investigation summaries available within minutes in the Investigation tab.
- **Full auditability** – All agent actions are logged in AWS CloudTrail under the `AWSServiceRoleForSupport` role.

⚠ Important

This feature is only available for AWS-supported cases. Self-managed cases do not include AI investigation capabilities.

How it works

The AI investigation agent follows a structured workflow when analyzing AWS supported security cases:

Investigation workflow

1. **Case creation** – Customer creates an AWS supported case in the Security Incident Response console describing the security concern.
2. **Parallel activation**
 - Security Incident Response engineers engage with the case.
 - Simultaneously, the AI agent begins its investigation workflow.
3. **Contextual questions (optional)** – The agent may ask clarifying questions to gather specific details:
 - Affected AWS account IDs
 - Involved IAM principals (users, roles, access keys)
 - Specific resource identifiers (S3 buckets, EC2 instances, ARNs)
 - Timeframe of suspicious activity
4. **Evidence gathering** – The agent automatically queries AWS data sources:
 - *AWS CloudTrail* – API calls and activities associated with the incident
 - *IAM* – User and role permissions, policy changes, and new identity creation
 - *Amazon EC2 Instance APIs* – Information about compute resources if involved
 - *Cost Explorer* – Cost and usage metrics for unusual resource consumption
5. **Analysis and correlation** – The agent correlates evidence across services, identifies patterns, and builds a timeline of events.
6. **Summary generation** – Within minutes, the agent presents a comprehensive investigation summary in the Investigation tab.

Note

All fields are optional. If no answer is provided within 10 minutes, the investigation starts automatically. In some cases, if sufficient information is already available, the agent may skip the optional questions entirely.

Accessing investigation results

To view the AI analysis:

1. Navigate to your case in the Security Incident Response console.
2. Select the **Investigation** tab.
3. Review the investigation summary with findings, timeline, and context.

The AI investigative agent summary is automatically posted as a comment in the case's **Communication** section, making it easy to review alongside other case updates.

Data access and permissions

The AI investigation agent uses the `AWSServiceRoleForSupport` Service-Linked Role to access AWS resources. This role provides read-only permissions necessary for evidence gathering.

All actions performed by the agent are logged in AWS CloudTrail, allowing customers to audit exactly what data was accessed during the investigation. In AWS CloudTrail logs, these actions are attributed to `AWSServiceRoleForSupport`.

Prerequisites

Before using the AI-powered investigation capabilities, ensure the following:

Required setup

- **AWS Security Incident Response enabled** – The service must be enabled through the AWS Organizations management account.
- **AWSsupported case type** – AI investigation is only available for AWS supported cases (not self-managed cases).
- **AWSServiceRoleForSupport** – This service-linked role is automatically created and provides necessary permissions for the investigation agent.

Required permissions

To create AWS supported cases and access investigation results, the IAM principal needs the following permissions:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "security-ir:CreateCase",
        "security-ir:GetCase",
        "security-ir:ListCases",
        "security-ir:UpdateCase"
      ],
      "Resource": "*"
    }
  ]
}
```

Using the investigative agent

The AI investigation agent activates automatically when creating an AWS-supported case.

To monitor AI investigation progress

1. Open your case in the AWS Security Incident Response console.
2. Choose the **Investigation** tab.
3. View the investigation status (*In Progress* or *Completed*).
4. Once completed, review the comprehensive investigation summary with findings, timeline, and recommendations.

Responsible AI disclosure

Investigation summaries are generated using AWS Generative AI capabilities. You are responsible for evaluating AI-generated recommendations in your specific context, implementing appropriate oversight mechanisms, verifying findings independently, and maintaining human oversight of all security decisions.

Use of customer data

AI Investigative Agent does not use customer data for model training, and it does not share customer data with third parties.

Contain

When AWS Security Incident Response identifies an active threat in your environment, containment is the immediate priority: stop the threat actor from causing further damage while preserving evidence for investigation. The service runs containment through reversible, automated actions that isolate compromised resources without destroying them. To enable these capabilities, you must first configure the required permissions and preferences. See [Deploy containment and EC2 Triage roles](#).

Containment decision-making

An essential part of containment is deciding whether to shut down a system, isolate a resource from the network, revoke access, or end sessions. AWS Security Incident Response provides the containment strategy, informs you of potential impact, and guides you on implementing the solution only after you have considered and agreed to the risks involved.

These decisions become easier when you have predetermined strategies and procedures. The service uses a combination of your containment preferences (configured during onboarding), the nature of the threat, and real-time analysis to determine the appropriate response.

Supported containment actions

AWS Security Incident Response runs containment actions on your behalf to reduce the time a threat actor has to cause damage. All supported containment actions are reversible. The service can restore the resource to its pre-containment state after the incident is resolved. The containment actions map to three resource types:

Amazon EC2 containment (`AWSSupport-ContainEC2Instance`) performs a reversible network containment of an Amazon Elastic Compute Cloud (Amazon EC2) instance. The instance stays running and intact, but the automation isolates it from new network activity and prevents it from communicating with resources inside or outside your Amazon VPC by replacing the instance's security groups with a restrictive containment security group. Existing tracked connections aren't shut down as a result of changing security groups. Only future traffic is blocked.

IAM containment (`AWSSupport-ContainIAMPrincipal`) performs a reversible containment of an AWS Identity and Access Management (IAM) user or role. The principal remains in IAM, but the automation isolates it from communicating with resources in your account by attaching a deny-all

policy. This effectively revokes the principal's ability to take actions while preserving it for forensic review.

Amazon S3 containment (AWSSupport-ContainS3Resource) performs a reversible containment of an Amazon Simple Storage Service (Amazon S3) bucket. Objects remain in the bucket, but the automation isolates the bucket or object by modifying its access policies to deny all external access.

Developing your containment strategy

Consider containment strategies for each major event type that fit within your risk appetite. Document clear criteria to help with decision-making during an event. Criteria to consider include the following:

- Potential damage to resources
- Preservation of evidence and regulatory requirements
- Service unavailability (for example, network connectivity or services provided to external parties)
- Time and resources needed to implement the strategy
- Effectiveness of the strategy (partial versus full containment)
- Permanence of the solution (reversible versus irreversible)
- Duration of the solution (emergency workaround, temporary workaround, or permanent solution)

Apply security controls that lower risk and allow time to define and implement a more effective containment strategy.

Staged containment approach

AWS Security Incident Response uses a staged approach to achieve efficient and effective containment, involving short-term and long-term strategies based on the resource type. Short-term containment focuses on immediately stopping the active threat (isolating a network, revoking credentials), while long-term containment addresses the root cause to prevent recurrence after the immediate danger passes.

How containment relates to the incident lifecycle

Containment sits between detection/analysis and eradication in the incident lifecycle. After automated triage identifies a confirmed or suspected threat and a case is created, the service

determines whether containment action is warranted based on your preferences and the severity of the event. After a resource is contained, AWS Security Incident Response engineers continue the investigation, share findings with you, and guide you through eradication and recovery. After the incident is fully resolved, the containment actions are reversed and normal operations resume.

Eradicate

During the eradication phase, it is important to identify and address all affected accounts, resources, and instances - such as by deleting malware, removing compromised user accounts, and mitigating any discovered vulnerabilities - to apply uniform remediation across the environment.

It is a best practice to use a phased approach to eradication and recovery, and to prioritize remediation steps. The purpose of the early phases is to increase the overall security quickly (days to weeks) with high-value changes to prevent future events. The later phases can focus on longer-term changes (for example, infrastructure changes), and ongoing work to keep the enterprise as secure as possible. Each case is unique and AWS Security Incident Response engineers will work with you to assess necessary actions.

Consider the following:

- Can you re-image the system and harden it with patches or other countermeasures to prevent or reduce the risk of attacks?
- Can you replace the infected system with a new instance or resource, enabling a clean baseline while terminating the infected item?
- Have you removed all malware and other artifacts left behind by the unauthorized use, and hardened the affected systems against further attacks?
- Is there a requirement for forensics on the impacted resources?

Recover

AWS Security Incident Response provides you guidance to help restore systems to normal operation, confirm they are functioning properly, and remediate any vulnerabilities to prevent similar events in the future. AWS Security Incident Response does not directly help with recovery of systems. Key considerations include:

- Are the affected systems patched and hardened against the recent attack?
- What is the feasible timeline to restore the systems to production?
- What tools will you use to test, monitor, and verify the restored systems?

Monthly report

AWS Security Incident Response emails a monthly report to all contacts on your Incident Response team. To update who receives these reports, modify the contact list in the AWS Security Incident Response console. Reports are delivered in PDF format and include the metrics described in [Case metrics](#). You can expect delivery within one to two weeks after the month ends. The email subject line is: AWS Security Incident Response Monthly Report - (*Month Year*). You receive one report per organization defined in AWS Organizations.

Case metrics

- Cases created
 - Dimension name: Type
 - Dimension values: AWS supported, self supported
 - Unit: Count
 - Description: The number of cases created.
- Cases closed
 - Dimension name: Type
 - Dimension values: AWS supported, self-managed
 - Unit: Count
 - Description: A measure of the total number of cases closed.
- Opened cases
 - Dimension name: Type
 - Dimension values: AWS supported, self supported
 - Unit: Count
 - Description: The number of open cases.

Triaging metrics

- Findings received
 - Unit: Count
 - Description: The number of findings sent to triaging.
- Findings archived
 - Unit: Count

- **Description:** The number of findings archived after processed without manual investigation.
- **Findings Manually investigated**
 - **Unit:** Count
 - **Description:** The number of findings with manual investigation performed.
- **Investigations archived**
 - **Unit:** Count
 - **Description:** The number of manual investigations resulting in false positive and sent for archiving
- **Investigations escalated**
 - **Unit:** Count
 - **Description:** The number of manual investigations resulting in a security incident

Cases

AWS Security Incident Response allows you to create two types of cases - AWS supported or self-managed cases.

Topics

- [Create an AWS supported case](#)
- [Create a self-managed case](#)
- [Working with AWS Security Incident Response engineers](#)
- [Responding to an AWS generated case](#)

Create an AWS supported case

You can create an AWS supported case for AWS Security Incident Response through the Console, the API, or the AWS Command Line Interface. AWS supported cases allow you to receive support from Security Incident Response engineers.

Important

Demo/simulation-cases are closing after a period of 90 days.

Note

AWS Security Incident Response engineers will respond to your case within 15 minutes. Response time is for a first response from AWS Security Incident Response engineers. AWS Security Incident Response makes every reasonable effort to respond to your initial request within this time frame. This response time does not apply to subsequent responses.

Note

You can create AWS supported cases not only for active security incidents and investigations, but also for inquiries about AWS Security Incident Response capabilities. This includes questions about GuardDuty suppression rules, alert triaging configurations, proactive response workflows, and general guidance on security posture. Select the **Investigations and Inquiries** case type for these purposes.

When to contact AWS Security Incident Response

You can contact AWS Security Incident Response for various purposes depending on your needs. The following table describes the different scenarios and the appropriate contact method for each.

Scenario	When to Use	Response Time	Case Type
Active Security Incident	You are experiencing an urgent security incident requiring immediate incident response support and services	15 minutes (first response)	Active Security Incident
Investigation	You have a perceived security incident and need support with log analysis and secondary confirmation of incident response investigation	15 minutes (first response)	Investigations and Inquiries

Scenario	When to Use	Response Time	Case Type
Inquiries and Guidance	You have questions about Amazon GuardDuty findings, suppression rules, alert triaging configurations, proactive response workflows , or general security posture related to AWS Security Incident Response capabilities	15 minutes (first response)	Investigations and Inquiries
Onboarding Issues	You are experiencing technical issues during the onboarding process for AWS Security Incident Response	Varies by support plan	AWS Support case

For all AWS-supported cases (Active Security Incident and Investigations and Inquiries), AWS Security Incident Response engineers will respond within 15 minutes for the first response. This response time applies only to the initial contact and does not apply to subsequent responses.

The following example covers use of the console.

1. Sign into AWS Security Incident Response via the AWS Management Console.
2. Choose **Create Case**
3. Choose **Resolve case with AWS**
4. Select the type of request
 - a. **Active Security Incident:** This type is for urgent incident response support and services.
 - b. **Investigations and Inquiries:** Use this type for perceived security incidents where AWS Security Incident Response engineers can support in log analysis and secondary confirmation of incident response investigation. You can also use this type for inquiries about GuardDuty findings, suppression rules, alert triaging configurations, proactive response workflows, and general security posture questions related to AWS Security Incident Response capabilities.
5. Set the start date estimate to the date of your earliest indicator of the incident. For example, when you experienced abnormal behavior for the first time or when you received the first related security alert.

6. Define a title for the case
7. Provide a detailed description of the case. Consider the following aspects which can help incident responders with the case resolution:
 - a. What happened?
 - b. Who discovered and reported the incident?
 - c. Who is affected by the case?
 - d. What is the known impact?
 - e. What is the urgency for this case?
 - f. Add one or multiple AWS account IDs that are in scope of the case.
8. Add optional case details:
 - a. Select the main services that are impacted from the drop-down list.
 - b. Select the main regions that are impacted from the drop-down list.
 - c. Add one or many threat actor IP addresses that you identified as part of this case.
9. Add optional additional incident responders to the case that will receive notifications. To add an individual, do the following:
 - a. Add an email address.
 - b. Add an optional first and last name.
 - c. Choose **Add new** to add another individual.
 - d. To remove an individual, choose the **Remove** option for an individual.
 - e. Choose **Add** to add all listed individuals to the case.
 - i. You can select multiple individuals and choose **Remove** to delete them from the list.
10. Add optional tags to the case.
 - a. To add a tag, do the following:
 - b. Choose **Add new tag**.
 - c. For **Key**, enter the name of the tag.
 - d. For **Value**, enter the value of the tag.
 - e. To remove a tag, choose the **Remove** option for that tag.

After a AWS supported case has been created, the AWS Security Incident Response engineers and your incident response team are immediately notified.

1. Open the AWS Security Incident Response console at console.aws.amazon.com/.
2. Choose **Cases** from the navigation pane.
3. Choose **Create case**.
4. For **Case type**, select **AWS-supported case**.
5. Provide case details including title, incident start date, and affected AWS account ID.
6. In the **Describe the security event** section, provide a thorough description of the incident.
7. Provide additional information about affected AWS services, regions, and other relevant details.
8. Choose **Create case**.

After case creation, both the Security Incident Response engineers and AI agent begin working simultaneously.

To respond to AI clarifying questions (optional)

1. Navigate to the **Investigation** tab in your case.
2. Review any clarifying questions presented by the AI agent.
3. Respond to the questions or choose **Skip** if you prefer not to answer.
4. Choose **Submit** to continue. All fields are optional.

Responsible AI disclosure

Investigation summaries are generated using AWS Generative AI capabilities. You are responsible for evaluating AI-generated recommendations in your specific context, implementing appropriate oversight mechanisms, verifying findings independently, and maintaining human oversight of all security decisions.

Create a self-managed case

You can create a self-managed case for AWS Security Incident Response through the Console, API, or AWS Command Line Interface. This type of case *DOES NOT* engage the AWS Security Incident Response engineers. The following example covers use of the console.

1. Sign into AWS Security Incident Response via the AWS Management Console at <https://console.aws.amazon.com/security-ir/>.
2. Choose **Create Case**.
3. Choose **Resolve case with my own incident response team**.

4. Set the start date estimate to the date of your earliest indicator of the incident. For example, when you experienced abnormal behavior for the first time or when you received the first related security alert.
5. Define a title for the case. It is recommended to include the data into the case title as suggested when selecting the **Generate Title** option.
6. Enter AWS account IDs that are part of the case. To add an account ID, do the following:
 - a. Enter the 12-digit account ID and choose **Add account**.
 - b. To remove an account, choose **Remove** next to the account you want to remove from the case.
7. Provide a detailed description of the case.
 - a. Consider the following aspects which can help incident responders with the case resolution:
 - i. What happened?
 - ii. Who discovered and reported the incident?
 - iii. Who is affected by the case?
 - iv. What is the known impact?
 - v. What is the urgency for this case?
8. Add optional case details:
 - a. Select the main services that are impacted from the drop-down list.
 - b. Select the main regions that are impacted from the drop-down list.
 - c. Add one or many threat actor IP addresses that you identified as part of this case.
9. Add optional additional incident responders to the case that will receive notifications. To add an individual, do the following:
 - a. Add an email address.
 - b. Add an optional first and last name.
 - c. Choose **Add new** to add another individual.
 - d. To remove an individual, choose the **Remove** option for an individual.
 - e. Choose **Add** to add all listed individuals to the case. You can select multiple individuals and choose **Remove** to delete them from the list.
10. Add optional tags to the case. To add a tag, do the following:
 - a. Choose **Add new tag**.
 - b. For **Key**, enter the name of the tag.
 - c. For **Value**, enter the value of the tag.

- d. To remove a tag, choose the **Remove** option for that tag.

The incident response team will be notified by e-mail after the case is created.

Working with AWS Security Incident Response engineers

After you open a security incident case, the AWS Security Incident Response engineers begin working on your incident. This section explains what to expect during the investigation and how to collaborate effectively with our team.

What to expect from AWS Security Incident Response engineers

When you open an AWS supported case, a Security Incident Response engineer is assigned to your incident. Your assigned responder will:

- Review the initial information you provided in the case
- Analyze relevant AWS service logs and security findings
- Identify the scope and impact of the security incident
- Develop an investigation and response plan tailored to your situation

Response timeline: The service level objective (SLO) for acknowledgment of new cases by AWS Security Incident Response engineers is within 15 minutes. The initial assessment timeline might vary based on case severity and complexity. If AWS Security Incident Response engineers don't receive a response or critical information from you within 5 business days, the case is closed.

Investigation workflow

AWS Security Incident Response engineers follow a structured incident response process aligned with the NIST 800-61r2 framework. During your investigation, you can expect the following phases:

1. **Initial triage** - Security Incident Response engineers review your case details and confirm the incident scope
2. **Investigation** - Security Incident Response engineers analyze logs, identify indicators of compromise, and determine root cause
3. **Containment** - Security Incident Response engineers recommend actions to limit the incident's impact

4. **Eradication and recovery** - Security Incident Response engineers help you remove threats and restore normal operations
5. **Post-incident review** - Security Incident Response engineers provide findings and recommendations to prevent future incidents

Throughout these phases, your Security Incident Response engineer keeps you informed through case updates and may request additional information or actions from you.

Information Security Incident Response engineers may request

To investigate your incident effectively, AWS Security Incident Response engineers may ask you to provide:

- **Timeline details** - When you first detected the incident and any relevant events leading up to it
- **Affected resources** - Specific AWS account IDs, services, regions, and resource ARNs involved
- **Access information** - Details about who has access to affected resources and any recent access changes
- **Business context** - How the affected resources are used and the potential business impact
- **Logs and evidence** - Additional logs, screenshots, or artifacts that may help the investigation
- **Authorization** - Approval to perform specific containment or remediation actions on your behalf

Your Security Incident Response engineer will explain why each piece of information is needed and how it helps the investigation.

Communication best practices

Effective communication accelerates incident resolution. Follow these practices when working with AWS Security Incident Response engineers:

- **Respond promptly** to information requests from your Security Incident Response engineer
- **Provide complete information** even if you're uncertain about its relevance
- **Ask questions** if you don't understand a recommendation or need clarification
- **Update the case** with any new developments or changes to the incident
- **Designate a primary contact** from your team to coordinate with Security Incident Response engineers

** Important**

If AWS Security Incident Response engineers don't receive a response to critical information requests within 5 business days, the team works toward case closure. You can reopen a case if new information becomes available.

Your role during the investigation

While AWS Security Incident Response engineers lead the investigation, your participation is essential. You're responsible for the following actions:

- Providing timely responses to information requests
- Implementing recommended containment and remediation actions in your AWS environment
- Authorizing Security Incident Response engineers to take actions on your behalf (if you enabled proactive response)
- Coordinating with your internal teams (security, legal, compliance) as needed
- Making business decisions about incident response priorities and trade-offs

AWS Security Incident Response engineers provide expertise and recommendations, but you maintain control over your AWS resources and make final decisions about response actions.

Case closure

AWS Security Incident Response engineers close your case when:

- The incident has been contained and remediated
- All investigation findings have been shared with you
- No further Security Incident Response engineer assistance is required
- You request case closure

Before closing a case, your Security Incident Response engineer provides a summary of findings, actions taken, and recommendations for improving your security posture.

If you need additional assistance after case closure, you can open a new case or contact AWS Support.

Responding to an AWS generated case

AWS Security Incident Response might create an outbound notification or case when you need to act on or be aware of something that potentially impacts your account or resources. This only occurs if you enabled the proactive response and alert triaging workflows as part of your subscription.

These notifications appear as Security Incident Response cases with the prefix "[Proactive case]" in the AWS Security Incident Response console. To view and manage these cases, complete the following steps:

- Open the Security Incident Response console at <https://console.aws.amazon.com/security-ir/>
- Choose **Cases**.
- You see all cases, including those with the "[Proactive case]" prefix.

You can update, resolve, and reopen these cases as needed. You can communicate directly with the AWS Security Incident Response team through these cases, ensuring efficient handling of potential security issues.

Managing Cases

Contents

- [Changing the case status](#)
- [Changing the resolver](#)
- [Action Items](#)
- [Edit a case](#)
- [Communications](#)
- [Permissions](#)
- [Attachments](#)
- [Tags](#)
- [Case activities](#)
- [Closing a case](#)

Changing the case status

A case is in one of the following states:

- **Submitted:** This is the initial status of a case. Cases in this status have been submitted by a requested, but are not yet being worked on.
- **Detection and Analysis:** This status indicates an incident responder has started work on the case. This phase includes data gathering, triaging the event, and performing analysis to create data driven conclusions.
- **Containment, Eradication and Recovery:** In this status the incident responder has identified suspicious activity that requires additional effort to remove. The incident responder will provide recommendations to you for business risk analysis and additional actions. If you have enabled the opt-in features for the service, then an AWS incident responder will seek your consent to perform containment actions with SSM documents in the impacted account(s).
- **Post-incident activities:** In this status the primary security event has been contained. The focus now is to recover and return business operations to normal. A summary and root cause analysis is provided if the resolver for the case is AWS-supported.
- **Closed:** This is the final status of the workflow. Cases in a closed status indicate work has been completed. Closed cases cannot be reopened, so ensure all actions are complete before transitioning to this status.

Choose **Action/Update Status** to change the status of the case for self-managed cases. For AWS supported cases, the status is set by the AWS Security Incident Response engineers.

Changing the resolver

For self-managed cases, your incident response team can request help from AWS. Choose **Get help from AWS** to change the resolver for this case to AWS. Once the case is updated to AWS supported, the status is changed to **Submitted**. The existing case history will be available to AWS Security Incident Response engineers. Once you have requested help from AWS you will not be able to change it back to self-managed.

Action Items

An AWS Security Incident Response engineer working on the case may request actions from your internal team.

Action items that appear after a case has been created include:

- Request to provide permissions for an incident responder to access a case
- Request to provide more information about the case

Action items when a case is ready to close:

- Request to review the case report
- Request to close the case

Edit a case

Choose **Edit** to change the details of a case.

For AWS supported and self-managed cases:

You can change the following case details after a case has been created:

- Title
- Description

For AWS supported cases only:

You can change the additional fields:

- **Request type:**
 - **Active Security Incident:** This type is for urgent incident response support and services.
 - **Investigations:** Investigations allow you to get support for perceived security incidents where the AWS Security Incident Response engineers can support in log dive and secondary confirmation of the security event.
- **Start date estimate:** Change this field if you received indicators for this case that pre-date the initial provided start date. Consider providing additional details in regards to the newly detected indicator in the description field or add a comment in the communications tab.

Communications

AWS Security Incident Response engineers can add comments to document their activities when working on a case. Different AWS Security Incident Response engineers can work on a case at the same time. They are represented as **AWS Responder** within the communication log.

Permissions

The permissions tab lists all individuals that will be notified for any change to the case. You can add and remove individuals from the list until the case is closed.

Note

Individual cases allow you to include up to 30 total stakeholders. Additional permission configuration is required to grant case-level access to these stakeholders.

Provide access to a case in the console

To provide access to the case in the AWS Management Console, you can copy the IAM permission policy template and add this permission to a user or role.

Adding the IAM policy to a user or a role:

1. Copy the IAM permission policy.
2. Open IAM in the via <https://console.aws.amazon.com/iam/>.
3. In the navigation pane, choose **User** or **Roles**.
4. Select a user or role to open the details page.
5. In the permissions tab, choose **Add permissions**.
6. Choose **Attach policy**.
7. Select the appropriate [AWS Security Incident Response managed policy](#).
8. Choose **Add policy**.

Attachments

Your incident responders can add attachments to a case that help other incident responders with their investigation for self-managed cases.

Note

If you choose an AWS supported case, AWS cannot view attachments. All details for AWS supported cases must be shared via case comments or through you providing a screenshare using your preferred communications technology.

Choose **Upload** to select a file from your computer to be added to the case.

 Note

Any uploaded attachments are deleted seven days after a case has been Closed.

Tags

A tag is an optional label that you can assign to your cases to hold metadata about that resource. Each tag is a label consisting of a key and an optional value. You can use tags to search, allocate costs, and authenticate permissions for the resource.

To add a tag, do the following:

1. Choose **Add new tag**.
2. For **Key**, enter the name of the tag.
3. For **Value**, enter the value of the tag.

To remove a tag, choose the **Remove** option for that tag.

Case activities

Audit trails provide detailed chronological records of all case activities. They provide important information in post-event activities and help to identify potential improvements. The time, user, action, and details of any case change are logged in the case audit trail.

Closing a case

For AWS supported cases, choose **Close Case** on the case details page to permanently close the case at any status. A case typically reaches the status **Ready to Close** before it is permanently closed. If you close a case prematurely at any other status than **Ready to Close**, you are requesting that AWS Security Incident Response engineers will stop working on this AWS supported case.

If your incident response team is the responder, select **Action/Close Case** on the case details page.

Note

The "Ready to Close" status signifies that a case can be permanently closed and that there is no additional work to be done on a case.

A case cannot be re-opened again after it has been permanently closed. All information will be available read-only. To prevent accidental closure, you will be asked to confirm that you want to close the case.

Cancel Membership

A role having the CancelMembership permission for AWS Security Incident Response can cancel the membership from the console, the API, or AWS Command Line Interface.

Important

After you cancel your membership, you can't view historic case data. When you cancel a membership, your membership is deleted immediately and you won't have further access to the cases on the membership. Any resources or investigations that are Active or ready to close are terminated upon membership cancellation.

When you cancel a membership:

Your membership is deleted and you won't have further access to the cases on the membership.

Important

If you resubscribe to the service, a new membership is created and the case resources that lived under the prior membership are only accessible if you downloaded them prior to cancellation.

After the membership has been canceled, everyone in the membership incident response team is notified by email.

** Important**

If you created a membership using a delegated administrator account and you use the AWS Organizations API to remove the delegated administrator designation from the account, the membership is terminated immediately.

** Important**

After you cancel your membership, the service-linked roles `AWSServiceRoleForSecurityIncidentResponse` and `AWSServiceRoleForSecurityIncidentResponse_Triage` are not automatically deleted. You must manually delete these roles from all accounts that were within the scope of the AWS Security Incident Response service. For instructions, see [Deleting a service-linked role](#) in the *IAM User Guide*.

Tagging AWS Security Incident Response resources

A *tag* is a metadata label that you assign or that AWS assigns to an AWS resource. Each tag consists of a *key* and a *value*. For tags that you assign, you define the key and value. For example, you might define the key as `stage` and the value for one resource as `test`.

Tags help you do the following:

- Identify and organize your AWS resources. Many AWS services support tagging, so you can assign the same tag to resources from different services to indicate that the resources are related.
- Track your AWS costs. You activate these tags on the AWS Billing dashboard. AWS uses the tags to categorize your costs and deliver a monthly cost allocation report to you. For more information, see [Use cost allocation tags](#) in the [AWS Billing User Guide](#).
- Control access to your AWS resources. For more information, see [Controlling access using tags](#) in the [IAM User Guide](#).

Refer to the [AWS Security Incident Response API reference for tagging](#).

Using AWS CloudShell to work with AWS Security Incident Response

AWS CloudShell is a browser-based, pre-authenticated shell that you can launch directly from the AWS Management Console. You can run AWS CLI commands against AWS services (including AWS Security Incident Response) using your preferred shell (Bash, PowerShell or Z shell). And you can do this without needing to download or install command line tools.

You [launch AWS CloudShell from the AWS Management Console](#), and the AWS credentials you used to sign in to the console are automatically available in a new shell session. This pre-authentication of AWS CloudShell users allows you to skip configuring credentials when interacting with AWS services such as Security Incident Response using AWS CLI version 2 (pre-installed on the shell's compute environment).

Contents

- [Obtaining IAM permissions for AWS CloudShell](#)
- [Interacting with Security Incident Response using AWS CloudShell](#)

Obtaining IAM permissions for AWS CloudShell

Using the access management resources provided by AWS Identity and Access Management, administrators can grant permissions to IAM users so they can access AWS CloudShell and use the environment's features.

The quickest way for an administrator to grant access to users is through an AWS managed policy. An [AWS managed policy](#) is a standalone policy that's created and administered by AWS. The following AWS managed policy for CloudShell can be attached to IAM identities:

- `AWSCloudShellFullAccess`: Grants permission to use AWS CloudShell with full access to all features.

If you want to limit the scope of actions that an IAM user can perform with AWS CloudShell, you can create a custom policy that uses the `AWSCloudShellFullAccess` managed policy as a template. For more information about limiting the actions that are available to users in CloudShell, see [Managing AWS CloudShell access and usage with IAM policies](#) in the *AWS CloudShell User Guide*.

Note

Your IAM identity also requires a policy that grants permission to make calls to Security Incident Response.

Interacting with Security Incident Response using AWS CloudShell

After you launch AWS CloudShell from the AWS Management Console, you can immediately start to interact with Security Incident Response using the command line interface.

Note

When using AWS Command Line Interface in AWS CloudShell, you don't need to download or install any additional resources. Moreover, because you're already authenticated within the shell, you don't need to configure credentials before making calls.

Working with AWS CloudShell and Security Incident Response

1. From the AWS Management Console, launch CloudShell by choosing the following options available on the navigation bar:
 - Choose the CloudShell icon.
 - Start typing "cloudshell" in the Search box and then choose the CloudShell option.
2. Use the standard AWS Command Line Interface to interact with AWS Security Incident Response. For a complete reference of available CLI commands, see the [AWS CLI Command Reference for AWS Security Incident Response](#).

Logging AWS Security Incident Response API calls using AWS CloudTrail

AWS Security Incident Response is integrated with AWS CloudTrail, a service that provides a record of actions taken by a user, role, or an AWS service in Security Incident Response. CloudTrail captures all API calls for Security Incident Response as events. The calls captured include calls from the Security Incident Response console and code calls to the Security Incident Response API operations. If you create a trail, you can enable continuous delivery of CloudTrail events to an Amazon S3 bucket, including events for Security Incident Response. If you don't configure a trail, you can still view the most recent events in the CloudTrail console in **Event history**. Using the information collected by CloudTrail, you can determine the request that was made to Security Incident Response, the IP address from which the request was made, who made the request, when it was made, and additional details.

To learn more about CloudTrail, see the [AWS CloudTrail User Guide](#).

Security Incident Response information in CloudTrail

CloudTrail is enabled on your AWS account when you create the account. When activity occurs in Security Incident Response, that activity is recorded in a CloudTrail event along with other AWS service events in **Event history**. You can view, search, and download recent events in your AWS account. For more information, see [Viewing events with CloudTrail Event history](#).

For an ongoing record of events in your AWS account past 90 days, create a trail or a [CloudTrail Lake](#) event data store.

CloudTrail trails

A *trail* enables CloudTrail to deliver log files to an Amazon S3 bucket. All trails created using the AWS Management Console are multi-Region. You can create a single-Region or a multi-Region trail by using the AWS CLI. Creating a multi-Region trail is recommended because you capture activity in all AWS Regions in your account. If you create a single-Region trail, you can view only the events logged in the trail's AWS Region. For more information about trails, see [Creating a trail for your AWS account](#) and [Creating a trail for an organization](#) in the *AWS CloudTrail User Guide*.

You can deliver one copy of your ongoing management events to your Amazon S3 bucket at no charge from CloudTrail by creating a trail, however, there are Amazon S3 storage charges. For

more information about CloudTrail pricing, see [AWS CloudTrail Pricing](#). For information about Amazon S3 pricing, see [Amazon S3 Pricing](#).

CloudTrail Lake event data stores

CloudTrail Lake lets you run SQL-based queries on your events. CloudTrail Lake converts existing events in row-based JSON format to [Apache ORC](#) format. ORC is a columnar storage format that is optimized for fast retrieval of data. Events are aggregated into *event data stores*, which are immutable collections of events based on criteria that you select by applying [advanced event selectors](#). The selectors that you apply to an event data store control which events persist and are available for you to query. For more information about CloudTrail Lake, see [Working with AWS CloudTrail Lake](#) in the *AWS CloudTrail User Guide*.

CloudTrail Lake event data stores and queries incur costs. When you create an event data store, you choose the [pricing option](#) you want to use for the event data store. The pricing option determines the cost for ingesting and storing events, and the default and maximum retention period for the event data store. For more information about CloudTrail pricing, see [AWS CloudTrail Pricing](#).

All Security Incident Response actions are logged by CloudTrail and are documented in the [AWS Security Incident Response API Reference](#). For example, calls to the `CreateMembership`, `CreateCase` and `UpdateCase` actions generate entries in the CloudTrail log files.

Every event or log entry contains information about who generated the request. The identity information helps you determine the following:

- Whether the request was made with root or AWS Identity and Access Management (IAM) user credentials.
- Whether the request was made with temporary security credentials for a role or federated user.
- Whether the request was made by another AWS service.

For more information, see the [CloudTrail userIdentity element](#).

Understanding Security Incident Response log file entries

A trail is a configuration that enables delivery of events as log files to an Amazon S3 bucket that you specify. CloudTrail log files contain one or more log entries. An event represents a single request from any source and includes information about the requested action, the date and time of

the action, request parameters, and so on. CloudTrail log files aren't an ordered stack trace of the public API calls, so they don't appear in any specific order.

The following example shows a CloudTrail log entry that demonstrates the CreateCase action.

```
{
  "eventVersion": "1.09",
  "userIdentity": {
    "type": "AssumedRole",
    "principalId": "AROAA00000000000000000000:user",
    "arn": "arn:aws:sts::123412341234:assumed-role/Admin/user",
    "accountId": "123412341234",
    "accessKeyId": "****",
    "sessionContext": {
      "sessionIssuer": {
        "type": "Role",
        "principalId": "AROAA00000000000000000000",
        "arn": "arn:aws:iam::123412341234:role/Admin",
        "accountId": "123412341234",
        "userName": "Admin"
      },
      "attributes": {
        "creationDate": "2024-10-13T06:32:53Z",
        "mfaAuthenticated": "false"
      }
    }
  },
  "eventTime": "2024-10-13T06:40:45Z",
  "eventSource": "security-ir.amazonaws.com",
  "eventName": "CreateCase",
  "awsRegion": "us-east-1",
  "sourceIPAddress": "1.2.3.4",
  "userAgent": "aws-cli/2.17.23 md/awscrt#0.20.11 ua/2.0 os/macos#23.6.0 md/arch#x86_64 lang/python#3.11.9 md/pyimpl#CPython cfg/retry-mode#standard md/installer#exe md/prompt#off md/command#security-ir.create-case",
  "requestParameters": {
    "impactedServices": [
      "Amazon GuardDuty"
    ],
    "impactedAccounts": [],
    "clientToken": "testToken112345679",
    "resolverType": "Self",
    "description": "****",
    "engagementType": "Investigation",
  }
}
```

```

    "watchers": [
      {
        "email": "****",
        "name": "****",
        "jobTitle": "****"
      }
    ],
    "membershipId": "m-r1abcdabcd",
    "title": "****",
    "impactedAwsRegions": [
      {
        "region": "ap-southeast-1"
      }
    ],
    "reportedIncidentStartDate": 1711553521,
    "threatActorIpAddresses": [
      {
        "ipAddress": "****",
        "userAgent": "browser"
      }
    ]
  },
  "responseElements": {
    "caseId": "0000000001"
  },
  "requestID": "2db4b08d-94a9-457a-9474-5892e6c8191f",
  "eventID": "b3fa3990-db82-43be-b120-c81262cc2f19",
  "readOnly": false,
  "resources": [
    {
      "accountId": "123412341234",
      "type": "AWS::SecurityResponder::Case",
      "ARN": "arn:aws:security-ir:us-east-1:123412341234:case/*"
    }
  ],
  "eventType": "AwsApiCall",
  "managementEvent": true,
  "recipientAccountId": "123412341234",
  "eventCategory": "Management"
}

```

Managing AWS Security Incident Response accounts with AWS Organizations

AWS Security Incident Response is integrated with AWS Organizations. The AWS Organizations management account for the organization can designate an account as the delegated administrator for AWS Security Incident Response. This action enables AWS Security Incident Response as a trusted service in AWS Organizations. For information about how these permissions are granted, see [Using AWS Organizations with other AWS services](#).

The following sections will walk you through various tasks that you may perform as a delegated Security Incident Response administrator account.

Contents

- [Considerations and recommendations for using AWS Security Incident Response with AWS Organizations](#)
- [Enabling trusted access for AWS Account Management](#)
- [Permissions required to designate a delegated Security Incident Response administrator account](#)
- [Managing membership with organizational units \(OUs\) for AWS Security Incident Response](#)
- [Adding members to AWS Security Incident Response](#)
- [Removing members from AWS Security Incident Response](#)

Considerations and recommendations for using AWS Security Incident Response with AWS Organizations

The following considerations and recommendations can help you understand how a delegated Security Incident Response administrator account operates in AWS Security Incident Response:

Delegated administrator account for AWS Security Incident Response.

You can designate one member account as the delegated Security Incident Response administrator account. For example, if you designate a member account **111122223333** in **Europe (Ireland)**, you can't designate another member account **555555555555** in **Canada (Central)**. It is required that you use the same account as delegated Security Incident Response administrator account in all other Regions.

You set up your delegated Security Incident Response administrator account in a specific AWS Region.

You designate a delegated Security Incident Response administrator account in one AWS Region during the initial setup. Although the setup is regional, AWS Security Incident Response provides organization-wide coverage across all supported AWS Regions. Security findings from Amazon GuardDuty and AWS Security Hub CSPM are ingested from all supported AWS Regions, and cases are centrally managed in the Region where you activated your subscription. The delegated Security Incident Response administrator account and member accounts must be added through AWS Organizations.

It's not recommended to set your organization's management account as the delegated Security Incident Response administrator account.

Your organization's management account can be the delegated Security Incident Response administrator account. However, the AWS security best practices follow the principle of least privilege and doesn't recommend this configuration.

Removing a delegated Security Incident Response administrator account from a live subscription cancels the subscription immediately.

If you remove a delegated Security Incident Response administrator account, AWS Security Incident Response removes all the member accounts associated with this delegated Security Incident Response administrator account. AWS Security Incident Response will no longer be enabled for all the member accounts.

Enabling trusted access for AWS Account Management

Enabling trusted access for AWS Security Incident Response allows the delegated administrator of the management account to modify the information and metadata (for example, primary or alternate contact details) specific to each member account in AWS Organizations.

Use the following procedure to enable trusted access for AWS Security Incident Response in your organization.

Minimum permissions

To perform these tasks, you must meet the following requirements:

- You can perform this only from the organization's management account.

- Your organization must have [all features enabled](#).

Console

To enable trusted access for AWS Security Incident Response

1. Sign in to the [AWS Organizations console](#). You must sign in as an IAM user, assume an IAM role, or sign in as the root user (not recommended) in the organization's management account.
2. Choose **Services** in the navigation pane.
3. Choose **AWS Security Incident Response** in the list of services.
4. Choose **Enable trusted access**.
5. In the **Enable trusted access for AWS Security Incident Response** dialog box, type **enable** to confirm it, and then choose **Enable trusted access**.

API/CLI

To enable trusted access for AWS Account Management

After running the following command, you can use credentials from the organization's management account to call Account Management API operations that use the `--accountId` parameter to reference member accounts in an organization.

- AWS CLI: [enable-aws-service-access](#)

The following example enables trusted access for AWS Security Incident Response in the calling account's organization.

```
$ aws organizations enable-aws-service-access \
                                --service-principal security-
ir.amazonaws.com
```

This command produces no output if it's successful.

Permissions required to designate a delegated Security Incident Response administrator account

You can choose to set up your AWS Security Incident Response membership using delegated administrator for AWS Organizations. For information about how these permissions are granted, see [Using AWS Organizations with other AWS services](#).

Note

AWS Security Incident Response automatically enables the AWS Organizations trusted relationship when using the console for setup and management. If you use the CLI/SDK then you have to manually enable this by using the [EnableAWSServiceAccess API](#) to trust `security-ir.amazonaws.com`.

As the AWS Organizations manager, before you designate the delegated Security Incident Response administrator account for your organization, verify that you can perform the following AWS Security Incident Response actions: `security-ir:CreateMembership` and `security-ir:UpdateMembership`. These actions allow you to designate the delegated Security Incident Response administrator account for your organization by using AWS Security Incident Response. You must also ensure that you are allowed to perform the AWS Organizations actions that help you retrieve information about your organization.

To grant these permissions, include the following statement in an AWS Identity and Access Management (IAM) policy for your account:

```
{
  "Sid": "PermissionsForSIRAdmin",
  "Effect": "Allow",
  "Action": [
    "security-ir:CreateMembership",
    "security-ir:UpdateMembership",
    "organizations:EnableAWSServiceAccess",
    "organizations:RegisterDelegatedAdministrator",
    "organizations:ListDelegatedAdministrators",
    "organizations:ListAWSServiceAccessForOrganization",
    "organizations:DescribeOrganizationalUnit",
    "organizations:DescribeAccount",
```

```

        "organizations:DescribeOrganization",
        "organizations:ListAccounts",
        "iam:CreateServiceLinkedRole",
        "iam:GetPolicy"
    ],
    "Resource": "*"
}

```

If you want to designate your AWS Organizations management account as the delegated Security Incident Response administrator account, your account will also need the IAM action: `CreateServiceLinkedRole`. Review [Considerations and recommendations for using AWS Security Incident Response with AWS Organizations](#) before you proceed to add the permissions.

To continue with designating your AWS Organizations management account as the delegated Security Incident Response administrator account, add the following statement to the IAM policy and replace **111122223333** with the AWS account ID of your AWS Organizations management account:

```

{
  "Sid": "PermissionsToEnableSecurityIncidentResponse"
  "Effect": "Allow",
  "Action": [
    "iam:CreateServiceLinkedRole"
  ],
  "Resource": "arn:aws:iam::111122223333:role/aws-service-role/security-ir.amazonaws.com/AWSServiceRoleForSecurityIncidentResponse",
  "Condition": {
    "StringLike": {
      "iam:AWSServiceName": "security-ir.amazonaws.com"
    }
  }
}

```

Managing membership with organizational units (OUs) for AWS Security Incident Response

AWS Security Incident Response supports membership coverage for individual organizational units (OUs). You can update your membership to cover specific OUs at any time. All accounts within the selected OUs, including accounts under child OUs, will be covered by your membership.

When updating your membership association, updates can be applied for up to 5 OUs at a time. If you wish to make changes to more than 5 OUs, complete association changes in batches of 5 OUs until all updates are completed.

Console

1. Open the Security Incident Response console at <https://console.aws.amazon.com/security-ir/>

To sign in, use the management credentials for your AWS Organizations organization.

2. Navigate to **Manage membership** > Accounts
3. Click **Update association**
4. Select **Choose organizational units (OUs)**
5. Select **Add OUs** or **Remove OUs**
6. Select up to 5 OUs you wish to update. You cannot add and remove OUs at the same time.

Note

All accounts and child OUs under a selected OU will be associated.

7. Click **Update association**

8.

Note

If you wish to make changes to more than 5 OUs, repeat steps 5 and 6 until all OUs have been associated.

To learn more about making OU changes within your AWS organization, please see [Managing organizational units \(OUs\) with AWS Organizations](#).

Adding members to AWS Security Incident Response

There is a one to one relationship with AWS Organizations and your AWS Security Incident Response membership. As accounts are added (or removed) from your Organizations or organizational units (OUs), these changes will be reflected in the covered accounts for your AWS Security Incident Response membership.

To add an account to your membership, follow one of the options for [Managing accounts in an organization with AWS Organizations](#).

You may also add additional OUs to your membership at any time — see [Managing membership with organizational units \(OUs\)](#).

Removing members from AWS Security Incident Response

To remove an account from your membership, you can remove a member account from your organization, move accounts out of your selected OUs, or remove OUs from your membership.

To remove an account from your membership, follow the procedures for [removing a member account from an organization](#).

To move accounts out of your OUs, follow the procedures for [Moving accounts to an organizational unit \(OU\) or between the root and OUs with AWS Organizations](#).

To remove OU from your membership, follow the procedures for [Managing membership with organizational units \(OUs\)](#).

Amazon EventBridge

Using Amazon EventBridge, you can to react, monitor, and orchestrate events associated with AWS Security Incident Response cases and memberships. You can either route these events via Rules (for fan-out scenarios to one or more targets) or through Pipes (for point-to-point integrations with enhanced filtering, enrichment, and transformation capabilities).

You can create integrations between Security Incident Response and third-party tooling or aggregate data to analyze using generative AI and other AWS tooling. For example, when Security Incident Response proactively creates a case, you can use EventBridge automations to trigger systems to notify stakeholders. Additionally, if you manage multiple AWS environments, you can use the Amazon EventBridge integration to monitor AWS Security Incident Response memberships to ensure all environments maintain a strong security posture.

For more information you can review the [What is Amazon EventBridge?](#)

Note

For the latest updates on Amazon EventBridge integration with AWS Security Incident Response, including ITSM integrations, see [AWS Security Incident Response now supports ITSM integrations](#) on the AWS What's New page.

Contents

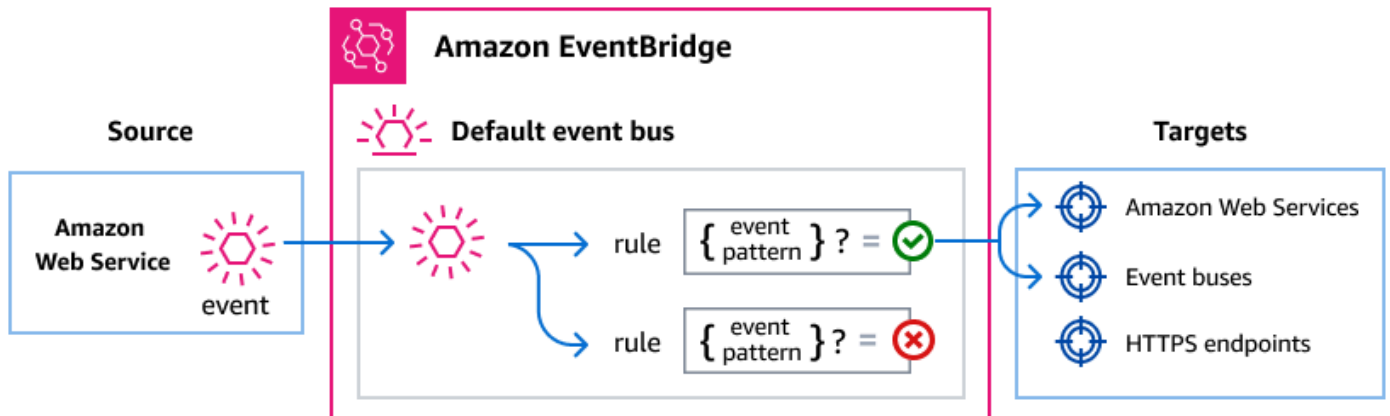
- [Managing Security Incident Response events using Amazon EventBridge](#)
- [Using AWS Security Incident Response Events](#)
- [Tutorial: Sending Amazon Simple Notification Service alerts for Membership Updated events](#)

Managing Security Incident Response events using Amazon EventBridge

Amazon EventBridge is a serverless service that uses events to connect application components together, making it easier for you to build scalable event-driven applications. Event-driven architecture is a style of building loosely-coupled software systems that work together by emitting and responding to events. Events represent a change in a resource or environment.

Here's how it works:

As with many AWS services, Security Incident Response generates and sends events to the EventBridge default event bus. (The default event bus is automatically provisioned in your AWS account.) An event bus is a router that receives events and delivers them to zero or more destinations, or *targets*. Rules you specify for the event bus evaluate events as they arrive. Each rule checks whether an event matches the rule's *event pattern*. If the event does match, the event bus sends the event to the specified target(s).



Delivering Security Incident Response events using EventBridge rules

To have the EventBridge default event bus send Security Incident Response events to a target, you must create a rule. Each rule contains an event pattern, which EventBridge matches against each event received on the event bus. If the event data matches the specified event pattern, EventBridge delivers that event to the rule's target(s).

For comprehensive instructions on creating event bus rules, see [Creating rules that react to events](#) in the *Amazon EventBridge User Guide*.

Creating event pattern that match Security Incident Response events

Each event pattern is a JSON object that contains:

- A `source` attribute that identifies the service sending the event. For Security Incident Response events, the source is `"aws.security-ir"`.
- (Optional): A `detail-type` attribute that contains an array of the event types to match.
- (Optional): A `detail` attribute containing any other event data on which to match.

For example, the following event pattern matches against all Case Updated by AWS Security Incident Response Service events for a specified AWS account:

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T03:45:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "updatedBy": "security-ir.amazonaws.com"
  }
}
```

For more information on writing event patterns, see [Event patterns](#) in the *EventBridge User Guide*.

Security Incident Response events detail reference

All events from AWS services have a common set of fields containing metadata about the event, such as the AWS service that is the source of the event, the time the event was generated, the account and region in which the event took place, and others. For definitions of these general fields, see [Event structure reference](#) in the *Amazon EventBridge User Guide*.

In addition, each event has a `detail` field that contains data specific to that particular event. The reference below defines the detail fields for the various Security Incident Response events.

When using EventBridge to select and manage Security Incident Response events, it's useful to keep the following in mind:

- The `source` field for all events from Security Incident Response is set to `"aws.security-ir"`.
- The `detail-type` field specifies the event type.

For example, `"Case Updated"`.

- The `detail` field contains the data that is specific to that particular event.

For information on constructing event patterns that enable rules to match Security Incident Response events, see [Event patterns](#) in the *Amazon EventBridge User Guide*.

For more information on events and how EventBridge processes them, see [EventBridge events](#) in the *Amazon EventBridge User Guide*.

Common Fields: All AWS Security Incident Response events include these standard Amazon EventBridge fields

- *version*: EventBridge event format version
- *id*: Unique identifier for the event
- *detail-type*: Human-readable description of the event type
- *source*: Always "aws.security-ir" for Security Incident Response events
- *account*: AWS account ID where the event occurred
- *time*: ISO 8601 timestamp when the event occurred
- *region*: AWS Region where the resource exists
- *resources*: Array containing the ARN of the affected resource

Detail Fields: The `detail` object contains Security Incident Response-specific information

- *caseId*: Unique identifier for the case (case events only)
- *membershipId*: Unique identifier for the membership (membership events only)
- *updatedBy*: Who performed the update (case and comment update events only)
- *createdBy*: Who created the entity (case and comment creation events only)

Actor Values: The `updatedBy` and `createdBy` fields can contain

- *AWS Responder*: Action performed by an AWS security responder
- *security-ir.amazonaws.com*: Action performed automatically by the service
- *Account ID*: Action performed by the customer (e.g., "111122223333")

Resource ARN values: AWS Security Incident Response resources use these ARN formats

- *Cases*: `arn:aws:security-ir:{region}:{account-id}:case/{case-id}`
- *Memberships*: `arn:aws:security-ir:{region}:{account-id}:membership/{membership-id}`

Case Events

Case Created by AWS Responder

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Created",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T00:00:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "createdBy": "AWS Responder"
  }
}
```

Case Created by Service

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Created",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T00:00:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
```

```
"caseId": "1234567890",
"createdBy": "security-ir.amazonaws.com"
}
}
```

Case Created by Customer

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Created",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T00:00:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "createdBy": "111122223333"
  }
}
```

Case Updated by AWS Responder

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T01:30:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
```

```
      "updatedBy": "AWS Responder"
    }
  }
}
```

Case Updated by AWS Customer

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T02:15:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "updatedBy": "111122223333"
  }
}
```

Case Updated by AWS Security Incident Response Service

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T03:45:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "updatedBy": "security-ir.amazonaws.com"
  }
}
```

```
}  
}
```

Case Closed

```
{  
  "version": "0",  
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",  
  "detail-type": "Case Closed",  
  "source": "aws.security-ir",  
  "account": "111122223333",  
  "time": "2023-05-15T14:22:00Z",  
  "region": "us-west-2",  
  "resources": [  
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"  
  ],  
  "detail": {  
    "caseId": "1234567890"  
  }  
}
```

Case Comment Events

Case Comment Added by AWS Responder

```
{  
  "version": "0",  
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",  
  "detail-type": "Case Comment Added",  
  "source": "aws.security-ir",  
  "account": "111122223333",  
  "time": "2023-05-12T04:30:00Z",  
  "region": "us-west-2",  
  "resources": [  
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"  
  ],  
  "detail": {  
    "caseId": "1234567890",  
    "createdBy": "AWS Responder"  
  }  
}
```

```
}  
}
```

Case Comment Added by Customer

```
{  
  "version": "0",  
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",  
  "detail-type": "Case Comment Added",  
  "source": "aws.security-ir",  
  "account": "111122223333",  
  "time": "2023-05-12T02:15:00Z",  
  "region": "us-west-2",  
  "resources": [  
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"  
  ],  
  "detail": {  
    "caseId": "1234567890",  
    "createdBy": "111122223333"  
  }  
}
```

Case Comment Added by AWS Security Incident Response Service

```
{  
  "version": "0",  
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",  
  "detail-type": "Case Comment Added",  
  "source": "aws.security-ir",  
  "account": "111122223333",  
  "time": "2023-05-12T02:15:00Z",  
  "region": "us-west-2",  
  "resources": [  
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"  
  ],  
  "detail": {  
    "caseId": "1234567890",  
    "createdBy": "security-ir.amazonaws.com"  
  }  
}
```

```
}
```

Case Comment Updated by Customer

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Comment Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T02:45:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "updatedBy": "111122223333"
  }
}
```

Case Comment Updated by AWS Security Incident Response Service

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Comment Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T02:45:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "updatedBy": "security-ir.amazonaws.com"
  }
}
```

Case Comment Updated by AWS Responder

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Case Comment Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-05-12T02:45:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:case/1234567890"
  ],
  "detail": {
    "caseId": "1234567890",
    "updatedBy": "AWS Responder"
  }
}
```

Membership Events

Membership Created

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Membership Created",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-04-01T10:00:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:membership/
m-1234567890abcdef0"
  ],
  "detail": {
    "membershipId": "m-1234567890abcdef0"
  }
}
```

```
}
```

Membership Updated

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Membership Updated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-04-15T16:30:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:membership/
m-1234567890abcdef0"
  ],
  "detail": {
    "membershipId": "m-1234567890abcdef0"
  }
}
```

Membership Cancelled

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Membership Closed",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-06-30T23:59:59Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:membership/
m-1234567890abcdef0"
  ],
  "detail": {
    "membershipId": "m-1234567890abcdef0"
  }
}
```

Membership Terminated

```
{
  "version": "0",
  "id": "a1b2c3d4-5678-90ab-cdef-EXAMPLE11111",
  "detail-type": "Membership Terminated",
  "source": "aws.security-ir",
  "account": "111122223333",
  "time": "2023-07-01T00:00:00Z",
  "region": "us-west-2",
  "resources": [
    "arn:aws:security-ir:us-west-2:111122223333:membership/m-123456s7890abcdef0"
  ],
  "detail": {
    "membershipId": "m-1234567890abcdef0"
  }
}
```

Using AWS Security Incident Response Events

You can create EventBridge rules to match these events and trigger automated actions. Here are some example use cases:

Match all AWS Security Incident Response events:

```
{
  "source": ["aws.security-ir"]
}
```

Match only case events:

```
{
  "source": ["aws.security-ir"],
```

```
    "detail-type": [  
      "Case Created",  
      "Case Updated",  
      "Case Closed",  
      "Case Comment Added",  
      "Case Comment Updated"  
    ]  
  }  
}
```

Match cases updated by AWS Responders:

```
{  
  "source": ["aws.security-ir"],  
  "detail-type": ["Case Updated"],  
  "detail": {  
    "updatedBy": ["AWS Responder"]  
  }  
}
```

Match events for a specific case:

```
{  
  "source": ["aws.security-ir"],  
  "detail": {  
    "caseId": ["1234567890"]  
  }  
}
```

Tutorial: Sending Amazon Simple Notification Service alerts for Membership Updated events

In this tutorial, you configure an Amazon EventBridge event rule that only captures events where the your subscription enters a Membership Updated status.

Prerequisites

This tutorial assumes that you have a working subscription and active AWS accounts in your membership.

Topics

- [Tutorial: Create and subscribe to an Amazon SNS topic](#)
- [Tutorial: Register an event rule](#)
- [Tutorial: Test your rule](#)
- [Alternate rule: Security Incident Response Case Updates](#)

Tutorial: Create and subscribe to an Amazon SNS topic

For this tutorial, you configure an Amazon SNS topic to serve as an event target for your new event rule.

To create an Amazon SNS topic

1. Open the Amazon SNS console at <https://console.aws.amazon.com/sns/v3/home>.
2. Choose **Topics, Create topic**.
3. For **Type**, choose **Standard**.
4. For **Name**, enter **MembershipUpdated** and choose **Create topic**.
5. On the **MembershipUpdated** screen, choose **Create subscription**.
6. For **Protocol**, choose **Email**.
7. For **Endpoint**, enter an email address that you currently have access to and choose **Create subscription**.
8. Check your email account, and wait to receive a subscription confirmation email message. When you receive it, choose **Confirm subscription**.

Tutorial: Register an event rule

Next, register an event rule that captures only Membership Updated events.

To register your EventBridge rule

1. Open the Amazon EventBridge console at <https://console.aws.amazon.com/events/>.

2. In the navigation pane, choose **Rules**.
3. Choose **Create rule**.
4. Enter a name and description for the rule.

 Note

A rule can't have the same name as another rule in the same Region and on the same event bus.

5. For **Event bus**, choose the event bus that you want to associate with this rule. If you want this rule to match events that come from your account, select **AWS default event bus**. When an AWS service in your account emits an event, it always goes to your account's default event bus.

 Note

This should be setup in your AWS Organizations or delegated administrator account you created the AWS Security Incident Response membership in.

6. For **Rule type**, choose **Rule with an event pattern**.
7. Choose **Next**.
8. For **Event source**, choose **Other**.
9. For **Event pattern**, select **Custom patterns (JSON editor)**.
10. Paste the following event pattern into the text area.

```
{
  "source": ["aws.security-ir"],
  "detail-type": ["Membership Updated"]
}
```

This code defines an EventBridge rule that matches any event where your service membership is updated or modified. For more information about event patterns, see [Events and Event Patterns](#) in the *Amazon EventBridge User Guide*.

11. Choose **Next**.
12. For **Target types**, choose **AWS service**.
13. For **Select a target**, choose **SNS topic**, and for **Topic**, choose **MembershipUpdated**.

14. (Optional) For **Additional settings**, do the following:

- a. For **Maximum age of event**, enter a value between one minute (00:01) and 24 hours (24:00).
- b. For **Retry attempts**, enter a number between 0 and 185.
- c. For **Dead-letter queue**, choose whether to use a standard Amazon SQS queue as a dead-letter queue. EventBridge sends events that match this rule to the dead-letter queue if they are not successfully delivered to the target. Do one of the following:
 - Choose **None** to not use a dead-letter queue.
 - Choose **Select an Amazon SQS queue in the current AWS account to use as the dead-letter queue** and then select the queue to use from the dropdown.
 - Choose **Select an Amazon SQS queue in an other AWS account as a dead-letter queue** and then enter the ARN of the queue to use. You must attach a resource-based policy to the queue that grants EventBridge permission to send messages to it. For more information, see [Granting permissions to the dead-letter queue](#) in the *Amazon EventBridge User Guide*.

15. Choose **Next**.

16. (Optional) Enter one or more tags for the rule. For more information, see [Amazon EventBridge tags](#) in the *Amazon EventBridge User Guide*.

17. Choose **Next**.

18. Review the details of the rule and choose **Create rule**.

Tutorial: Test your rule

To test your rule, submit an update to your AWS Security Incident Response membership. If your rule is configured correctly, you should receive an email message within a few minutes with the event text.

Alternate rule: Security Incident Response Case Updates

To create an event rule that monitors for all case updates, repeat these tutorials with the following alterations:

1. In [Tutorial: Create and subscribe to an Amazon SNS topic](#), use *CaseUpdates* as the topic name.
2. In [Tutorial: Register an event rule](#), use the following pattern in the JSON editor:

```
{
  "source": ["aws.security-ir"],
  "detail-type": [
    "Case Created",
    "Case Updated",
    "Case Closed",
    "Case Comment Added",
    "Case Comment Updated"
  ]
}
```

Troubleshooting

When you experience issues related to performing an action specific to AWS Security Incident Response, consult the topics in this section.

An ERROR is a status of an operation denoting a fault in some or all of the operations. Alternatively, you receive warnings when an issue occurs but the task still completes.

Contents

- [Issues](#)
- [Errors](#)
- [Support](#)

Issues

Not sending requests from the correct context.

All calls to AWS Security Incident Response APIs must originate from an IAM principal in the service delegated administrator or membership account. Ensure that you are operating from the correct IAM principal in the AWS account that is your organization's AWS Security Incident Response delegated administrator or membership account.

Errors

AccessDeniedException

You do not have sufficient access to perform this action.

Please work with your AWS administrator to ensure that you have permission to assume an IAM Role in your AWS Security Incident Response delegated administrator or membership account. Also check the role has a an IAM policy that permits the requested action. For more information see [AWS Security Incident Response IAM](#).

ConflictException

The request causes an inconsistent state.

Please check that any case attachment file names or default response team members that you have specified are unique. Also check that your AWS Security Incident Response service

membership has not already been configured. Open the Security Incident Response console at <https://console.aws.amazon.com/security-ir/> and navigate to Membership Details.

InternalServerErrorException

An unexpected error occurred during the processing of the request. Please try again in a few minutes. If the issue persists, [raise a case with Support](#).

ResourceNotFoundException

The request references a resource that does not exist.

One or more of the resources specified in your request does not exist. Please check that all given resource ARNs or IDs are correct. This applies to AWS Organizations IDs, account IDs, IAM roles, memberships, cases, response team members, cases, case responders, case attachments, and case comments.

ThrottlingException

The request was denied due to request throttling.

Too many requests have been made by your IAM principal to that API function in a specified period. Wait a minute and try again. If the issue persists, please consider implementing an exponential backoff and retry algorithm.

ValidationException

The input fails to satisfy the constraints specified by an AWS service.

One or more of the data fields in your request did not meet validation and/or logical combination requirements. Please check that all resource ARNs complete, and that text values meet size and format constraints from the [AWS Security Incident Response API Reference Guide](#). Also check that any value updates are permitted. For example, changing a case from AWS supported to self-managed is not possible.

Support

If you need additional assistance, contact [Support Center](#) for troubleshooting purposes. Please have the following information available:

- The AWS Region that you used

- The AWS account ID of the membership
- Your source content, if applicable and available
- Any other details about the problem that might assist with troubleshooting

Security

Topics

- [Data Protection in AWS Security Incident Response](#)
- [Inter-network traffic privacy](#)
- [Identity and Access Management](#)
- [Troubleshooting AWS Security Incident Response identity and access](#)
- [Using service roles](#)
- [Using service-linked roles](#)
- [AWS Managed Policies](#)
- [Incident response](#)
- [Compliance validation](#)
- [Logging and monitoring in AWS Security Incident Response](#)
- [Resilience](#)
- [Infrastructure security](#)
- [Configuration and vulnerability analysis](#)
- [Cross-service confused deputy prevention](#)

Data Protection in AWS Security Incident Response

The AWS [shared responsibility model](#) applies to data protection for the AWS Security Incident Response service. As described in this model, AWS is responsible for protecting the infrastructure that runs the services offered in the AWS Cloud. You are responsible for maintaining control over your content that is hosted on this infrastructure. You are also responsible for the security configuration and management tasks for the AWS services that you use. For more information about data privacy, see the [Data Privacy FAQ](#). For information about data protection in Europe, see the [AWS Shared Responsibility Model and GDPR](#) blog post on the *AWS Security Blog*.

For data protection purposes, AWS security best practices state that you should protect AWS account credentials and set up individual users with AWS IAM Identity Center or AWS Identity and Access Management (IAM). This way, each user is given only the permissions necessary to fulfill their job duties. We also recommend that you secure your data in the following ways:

- Use multi-factor authentication (MFA) with each account.

- Use SSL/TLS to communicate with AWS resources. We require TLS 1.2 and recommend TLS 1.3.
- Set up API and user activity logging with AWS CloudTrail.
- Use AWS encryption solutions, along with all default security controls within AWS services.
- FIPS 140-3 is currently not supported by the service.

Never put confidential or sensitive information, such as your email addresses, into tags or free-form text fields such as a **Name** field. This includes when you work with AWS Support or other AWS services using the console, API, AWS Command Line Interface, or AWS SDKs. Any data that you enter tags or free-form text fields used for names might be used for billing or diagnostic logs. If you provide a URL to an external server, we **strongly** recommend that you do not include credentials information in the URL to validate your request to that server.

Topics

- [Data encryption](#)
- [Data collection and usage](#)
- [Data residency and regional behavior](#)
- [Data access and permissions](#)

Data encryption

AWS Security Incident Response protects your data using encryption at rest and in transit. All data is encrypted using industry-standard encryption protocols to help you meet security and compliance requirements.

Topics

- [Encryption at rest](#)
- [Encryption in transit](#)
- [Key management](#)

Encryption at rest

Data is encrypted at rest using transparent server-side encryption. This helps reduce the operational burden and complexity involved in protecting sensitive data. With encryption at rest, you can build security-sensitive applications that meet encryption compliance and regulatory requirements.

Encryption in transit

Data gathered and accessed by AWS Security Incident Response is exclusively over a Transport Layer Security (TLS) protected channel.

Key management

AWS Security Incident Response implements integrations with AWS KMS to provide encryption at rest for case and attachment data.

AWS Security Incident Response does not support customer managed keys.

Data collection and usage

AWS Security Incident Response works with three distinct categories of data, each with different collection methods, storage patterns, and regional behavior. Understanding these categories is essential for evaluating how Security Incident Response fits within your compliance requirements.

Topics

- [Case investigation data](#)
- [Security findings data](#)
- [Investigative agent processing](#)
- [Understanding metadata sensitivity](#)

Case investigation data

When you open a security incident case, Security Incident Response collects logs and metadata from your AWS environment to support the investigation. This case-specific data includes API logs, VPC Flow Logs, Amazon Route 53 DNS queries, Amazon S3 access events, resource metadata (names, tags, and configuration details), and case information such as comments and investigation notes.

Important

Security Incident Response collects information about your environment's activity patterns and resource configurations. It does not collect the actual contents of your Amazon S3 buckets, database records, or application data. Security Incident Response collects the "who did what and when" rather than the underlying data itself.

This case investigation data is collected on-demand for specific incidents and remains associated with your case. Security Incident Response retains this data for 90 days by default to allow you to review investigation history, support ongoing or follow-up investigations, and meet audit and compliance documentation requirements. If you require data deletion before the 90-day period expires, contact AWS Support to request early deletion.

Security findings data

Security Incident Response continuously ingests security findings metadata from Amazon GuardDuty and AWS Security Hub CSPM across all supported AWS Regions where you have enabled these services. This findings data includes resource identifiers, finding types, severity levels, affected resources, and detection timestamps. Unlike case investigation data, findings data is ingested automatically and continuously to enable Security Incident Response to correlate threats across your entire AWS environment.

The findings data does not include the detailed logs or raw data that generated the findings—only the metadata about what was detected, where it was detected, and the severity of the detection. This metadata enables Security Incident Response to identify patterns, correlate related security events across Regions, and provide comprehensive threat analysis.

Investigative agent processing

The Security Incident Response investigative agent, powered by Amazon Bedrock, processes metadata from your case investigation data and findings data to generate insights, identify patterns, and recommend response actions. This processing occurs in Amazon Bedrock's global region as part of the agent's analysis workflow.

Important

The investigative agent processes metadata transiently and doesn't store this data persistently in Amazon Bedrock's global Region. The metadata is used only for generating investigation insights and isn't retained after processing completes.

Understanding metadata sensitivity

While Security Incident Response doesn't collect your application data, the metadata it collects across all three categories can reveal sensitive information about your environment and potentially your users. Consider the following examples:

- Resource names such as `patient-database-prod` or `financial-records-2026` indicate the purpose and sensitivity of resources.
- DNS queries like `user12345.internal.app.com` may contain user identifiers or internal system information.
- API call patterns can reveal business processes and operational workflows.

Organizations in regulated industries should evaluate whether this metadata falls under their compliance requirements, even though it isn't the regulated data itself.

Data residency and regional behavior

The three categories of data in Security Incident Response have different storage locations and regional movement patterns. Understanding these patterns is critical for organizations with data residency requirements.

Topics

- [Case investigation data storage and movement](#)
- [Security findings data storage and movement](#)
- [Investigative agent processing location](#)
- [Regional availability](#)

Case investigation data storage and movement

Case investigation data remains in the AWS Region where you open the security incident case. When you create a case in a specific Region, all logs, metadata, and case information collected for that investigation are stored in that Region. This data doesn't move to other Regions.

For standard AWS Regions (Regions available by default), case investigation data stays in the Region where the case was created throughout the investigation lifecycle and the 90-day retention period.

For AWS opt-in Regions (such as Middle East (Bahrain), Africa (Cape Town), or Asia Pacific (Hong Kong)), case investigation data also remains in the Region where the case was created. However, if you enable Security Incident Response in an opt-in Region, all case data from that Region automatically replicates to the US East (N. Virginia) Region (us-east-1) for centralized case management and analysis.

** Important**

If you operate in opt-in Regions, your case investigation data automatically flows to us-east-1. Organizations with strict data residency requirements must evaluate whether this cross-Region replication is compatible with their compliance obligations. Data never flows between different opt-in Regions, and data from non-opt-in Regions never replicates to opt-in Regions.

Security findings data storage and movement

Security findings metadata traverses Regions regardless of where the findings originate. Security Incident Response ingests findings from Amazon GuardDuty and AWS Security Hub CSPM across all Regions where you have enabled these services and correlates this metadata across Regions to identify distributed threats and attack patterns.

For standard AWS Regions, findings metadata from all Regions is accessible for correlation and analysis. This cross-Region movement enables Security Incident Response to detect threats that span multiple Regions, such as an attacker moving laterally across your infrastructure.

For AWS opt-in Regions, findings metadata follows the same replication pattern as case investigation data. Findings from opt-in Regions replicate to commercial AWS Regions (Regions other than the AWS GovCloud (US) Regions and the China Regions) for centralized analysis alongside findings from other Regions.

The findings metadata includes only resource identifiers, finding types, and severity information—not the detailed logs or raw data that generated the findings. This metadata enables threat correlation while minimizing the volume of data that crosses Region boundaries.

Investigative agent processing location

The Security Incident Response investigative agent processes metadata in Amazon Bedrock's global region, regardless of which Region your case or findings data originates from. This processing is transient—the agent analyzes the metadata to generate insights and recommendations but does not store the metadata persistently in the Amazon Bedrock infrastructure.

When the agent completes its analysis, the generated insights and recommendations are stored with your case investigation data in the Region where the case was created. The metadata used for processing is not retained in Amazon Bedrock global Region after the analysis completes.

Regional availability

For information about which Regions support Security Incident Response, see [AWS Regional Services](#).

Data access and permissions

Two groups can access your AWS Security Incident Response data:

- **Your authorized users** — IAM users and roles that you grant Security Incident Response permissions.
- **AWS incident responders** — AWS employees and vetted contractors who investigate your cases.

Topics

- [AWS incident responder access](#)
- [Access logging and auditability](#)
- [Controlling access with IAM](#)

AWS incident responder access

AWS operates Security Incident Response as a "follow the sun" service, providing 24/7 coverage through incident responders located in the Americas, Europe, and Asia-Pacific. When you open a security incident case, the responder assigned to your case may be located in any of these regions. All AWS incident responders undergo background checks and complete security training before gaining access to customer data.

Important

The geographic location of the incident responder handling your case may vary based on when you open the case and responder availability. Organizations with requirements about who can access their data should evaluate whether this global access model is compatible with their policies.

Access logging and auditability

Every access to your Security Incident Response data is logged. You can audit who accessed your data, what data was accessed, and when the access occurred. These audit logs support your compliance and security monitoring requirements.

Controlling access with IAM

You control which users and roles in your AWS account can access Security Incident Response through IAM policies. For information about configuring IAM permissions for Security Incident Response, see [Identity and Access Management](#).

Inter-network traffic privacy

Traffic between service and on-premises clients and applications

You have two connectivity options between your private network and AWS:

- An AWS Site-to-Site VPN connection. For more information, see [What is AWS Site-to-Site VPN?](#) in the *AWS Site-to-Site VPN User Guide*.
- An Direct Connect connection. For more information, see [What is Direct Connect?](#) in the *Direct Connect User Guide*.

Access to AWS Security Incident Response via the network is through AWS published APIs. Clients must support Transport Layer Security (TLS) 1.2. We recommend TLS 1.3. Clients must also support cipher suites with Perfect Forward Secrecy (PFS), such as Ephemeral Diffie-Hellman (DHE) or Elliptic Curve Diffie-Hellman Ephemeral (ECDHE). Most modern systems such as Java 7 and later support these modes. Additionally, you must sign requests using an access key ID and a secret access key that are associated with an IAM principal, or you can use the [AWS Security Token Service \(STS\)](#) to generate temporary security credentials to sign requests.

Traffic between AWS resources in the same Region

An Amazon Virtual Private Cloud (Amazon VPC) endpoint for AWS Security Incident Response is a logical entity within a VPC that allows connectivity only to AWS Security Incident Response. The Amazon VPC routes requests to AWS Security Incident Response and routes responses back to the VPC. For more information, see [VPC endpoints](#) in the *Amazon VPC User Guide*. For example policies

that you can use to control access from VPC endpoints, see [Using IAM policies to control access to DynamoDB](#).

 Note

Amazon VPC endpoints are not accessible via AWS Site-to-Site VPN or Direct Connect.

Identity and Access Management

AWS Identity and Access Management (IAM) is an AWS service that helps an administrator control access to AWS resources. IAM administrators control *authenticated* (signed in) and *authorized* (have permissions) principals to use AWS Security Incident Response resources. IAM is an AWS service that you can use with no additional charge.

Topics

- [Authenticating with identities](#)
- [How AWS Security Incident Response Works with IAM](#)

Audience

How you use AWS Identity and Access Management (IAM) differs, depending on the work that you do in AWS Security Incident Response.

Security Administrators

These users are suggested to use the [AWSSecurityIncidentResponseFullAccess](#) managed policy to ensure they have read and write access to membership and case resources.

Case Watchers

These individuals do not have authoritative access to all cases but individual cases that you grant explicit permission for.

Incident Response Team members

Members of the team can be given both full membership and case access. It is recommended that not all individuals have authoritative action on service membership but should have access to any and all cases that are created and managed through the service. For more information, refer to [AWS Security Incident Response managed policies](#).

Authenticating with identities

Authentication is how you sign in to AWS using your identity credentials. You must be *authenticated* (signed in to AWS) as the AWS account root user, as an IAM user, or by assuming an IAM role.

You can sign in to AWS as a federated identity by using credentials provided through an identity source. AWS IAM Identity Center (IAM Identity Center) users, your company's single sign-on authentication, and your Google or Facebook credentials are examples of federated identities. When you sign in as a federated identity, your administrator previously set up identity federation using IAM roles. When you access AWS by using federation, you are indirectly assuming a role.

Depending on the type of user you are, you can sign in to the AWS Management Console or the AWS access portal. For more information about signing in to AWS, see [How to sign in to your AWS account](#) in the *AWS Sign-In User Guide*.

If you access AWS programmatically, AWS provides a software development kit (SDK) and a command line interface (CLI) to cryptographically sign your requests by using your credentials. If you don't use AWS tools, you must sign requests yourself. For more information about using the recommended method to sign requests yourself, see [Signing AWS API requests](#) in the *IAM User Guide*.

Regardless of the authentication method that you use, you may be required to provide additional security information. For example, AWS recommends that you use multi-factor authentication (MFA) to increase the security of your account. To learn more, see [Multi-factor authentication](#) in the *AWS IAM Identity Center User Guide* and [Using multi-factor authentication \(MFA\) in AWS](#) in the *IAM User Guide*.

AWS account root user

When you create an AWS account, you begin with one sign-in identity that has complete access to all AWS services and resources in the account. This identity is called the AWS account *root user* and is accessed by signing in with the e-mail address and password that you used to create the account. Never use the root user for your everyday tasks and take steps to safeguard your root user credentials. Only use them to perform tasks that only the root user can perform. For the complete list of tasks that require you to sign in as the root user, see [Tasks that require root user credentials](#) in the *IAM User Guide*.

Federated identity

It is best practice to require human users, including those that need administrator access, to use federation with an identity provider to access AWS services by using temporary credentials.

A *federated identity* is a user from your enterprise user directory, a web identity provider, the AWS Directory Service, the Identity Center directory, or any user that accesses AWS services by using credentials provided through an identity source. When federated identities access AWS accounts, they assume roles, and the roles provide temporary credentials.

For centralized access management, we recommend that you use AWS IAM Identity Center. You can create users and groups in IAM Identity Center, or you can connect and synchronize to a set of users and groups in your own identity source for use across all your AWS accounts and applications. For information about IAM Identity Center, see [What is IAM Identity Center?](#) in the *AWS IAM Identity Center User Guide*.

IAM users and groups

An [IAM user](#) is an identity within your AWS account that has specific permissions for a single person or application. We recommend relying on temporary credentials instead of creating IAM users who have long-term credentials such as passwords and access keys. If you have a specific use case that requires long-term credentials with IAM users, we recommend that you rotate access keys. For more information, see [Rotate access keys regularly for use cases that require long-term credentials](#) in the *IAM User Guide*.

An [IAM group](#) is an identity that specifies a collection of IAM users. You can't sign in as a group. You can use groups to specify permissions for multiple users at a time. Groups make permissions easier to manage for large sets of users. For example, you could have a group named *IAMAdmins* and give that group permissions to administer IAM resources.

Users are different from roles. A user is uniquely associated with one person or application, but a role is intended to be assumable by anyone who needs it. Users have permanent long-term credentials, but roles provide temporary credentials. To learn more, see [When to create an IAM user \(instead of a role\)](#) in the *IAM User Guide*.

IAM roles

An [IAM role](#) is an identity within your AWS account that has specific permissions. It is similar to an IAM user, but is not associated with a specific person. You can temporarily assume an IAM role in the AWS Management Console by [switching roles](#). You can assume a role by calling an AWS CLI or AWS API operation or by using a custom URL. For more information about methods for using roles, see [Using IAM roles](#) in the *IAM User Guide*.

IAM roles with temporary credentials are useful in the following situations:

- **Federated user access** – To assign permissions to a federated identity, you create a role and define permissions for the role. When a federated identity authenticates, the identity is associated with the role and is granted the permissions that are defined by the role. For information about roles for federation, see [Creating a role for a third-party Identity Provider](#) in the *IAM User Guide*. If you use IAM Identity Center, you configure a permission set. To control what your identities can access after they authenticate, IAM Identity Center correlates the permission set to a role in IAM. For information about permissions sets, see [Permission sets](#) in the *AWS IAM Identity Center User Guide*.
- **Temporary IAM user permissions** – An IAM user or role can assume an IAM role to temporarily take on different permissions for a specific task.
- **Cross-account access** – You can use an IAM role to allow someone (a trusted principal) in a different account to access resources in your account. Roles are the primary way to grant cross-account access. However, with some AWS services, you can attach a policy directly to a resource (instead of using a role as a proxy). To learn the difference between roles and resource-based policies for cross-account access, see [Cross account resource access in IAM](#) in the *IAM User Guide*.
- **Cross-service access** – Some AWS services use features in other AWS services. For example, when you make a call in a service, it's common for that service to run applications in Amazon EC2 or store objects in Amazon S3. A service might do this using the calling principal's permissions, using a service role, or using a service-linked role.
 - **Service role** – A service role is an [IAM role](#) that a service assumes to perform actions on your behalf. An IAM administrator can create, modify, and delete a service role from within IAM. For more information, see [Creating a role to delegate permissions to an AWS service](#) in the *IAM User Guide*.
 - **Service-linked role** – A service-linked role is a type of service role that is linked to an AWS service. The service can assume the role to perform an action on your behalf. Service-linked roles appear in your AWS account and are owned by the service. An IAM administrator can view, but not edit the permissions for service-linked roles.
- **Applications running on Amazon EC2** – You can use an IAM role to manage temporary credentials for applications that are running on an EC2 instance and making AWS CLI or AWS API requests. This is preferable to storing access keys within the EC2 instance. To assign an AWS role to an EC2 instance and make it available to its applications, you create an instance profile that is attached to the instance. An instance profile contains the role and enables programs that are running on the EC2 instance to get temporary credentials. For more information, see [Using an](#)

[IAM role to grant permissions to applications running on Amazon EC2 instances](#) in the *IAM User Guide*.

To learn whether to use IAM roles or IAM users, see [When to create an IAM role \(instead of a user\)](#) in the *IAM User Guide*.

How AWS Security Incident Response Works with IAM

AWS Identity and Access Management (IAM) is an AWS service that helps an administrator securely control access to AWS resources. IAM administrators control who can be *authenticated* (signed in) and *authorized* (have permissions) to use AWS Security Incident Response resources. IAM is an AWS service that you can use with no additional charge.

IAM features that you can use with AWS Security Incident Response	
<u>IAM feature</u>	<u>Service alignment</u>
Identity-based policies	Yes
Resource-based policies	No
Policy actions	Yes
Policy resources	Yes
Policy conditions keys	Yes (global)
ACLs	No
ABAC (tags in policies)	Yes
Temporary credentials	Yes
Forward access sessions (FAS)	Yes
Service roles	No
Service-linked roles	Yes

Topics

- [Identity-based policies for AWS Security Incident Response](#)
- [Policy condition keys for AWS Security Incident Response](#)
- [Access control lists \(ACLs\) in AWS Security Incident Response](#)

Identity-based policies for AWS Security Incident Response

Identity-based policies are JSON permissions policy documents that you can attach to an identity, such as an IAM user, group of users, or role. These policies control what actions users and roles can perform, on which resources, and under what conditions. To learn how to create an identity-based policy, see [Creating IAM policies](#) in the *IAM User Guide*.

With IAM identity-based policies, you can specify allowed or denied actions and resources as well as the conditions under which actions are allowed or denied. You can't specify the principal in an identity-based policy because it applies to the user or role to which it is attached. To learn about all of the elements that you can use in a JSON policy, see [IAM JSON policy elements reference](#) in the *IAM User Guide*.

Topics

- [Identity-based policy examples](#)
- [Policy best practices](#)
- [Using the AWS Security Incident Response console](#)
- [Allow users to view their own permissions](#)
- [Resource-Based Policies](#)
- [Policy Actions](#)

Identity-based policy examples

By default, users and roles don't have permission to create or modify AWS Security Incident Response resources. They also can't perform tasks by using the AWS Management Console, AWS Command Line Interface (AWS CLI), or AWS API. An IAM administrator can create IAM policies to grant users permission to perform actions on the resources they need. The administrator can then add the IAM policies to roles, and users can assume the roles.

To learn how to create an IAM identity-based policy by using these example JSON policy documents, see [Creating IAM policies](#) in the *IAM User Guide*.

For details about actions and resource types defined by AWS Security Incident Response, including the format of the ARNs for each of the resource types, see *Actions, resources, and condition keys for AWS Security Incident Response* in the *Service Authorization Reference*.

Policy best practices

Identity-based policies determine whether someone can create, access, or delete AWS Security Incident Response resources in your account. These actions can incur costs for your AWS account. When you create or edit identity-based policies, follow these guidelines and recommendations:

Get started with AWS managed policies and move toward least-privilege permissions – To get started granting permissions to your users and workloads, use the *AWS managed policies* that grant permissions for many common use cases. They are available in your AWS account. We recommend that you reduce permissions further by defining AWS customer managed policies that are specific to your use cases. For more information, see [AWS managed policies](#) or [AWS managed policies for job functions](#) in the *IAM User Guide*.

Apply least-privilege permissions – When you set permissions with IAM policies, grant only the permissions required to perform a task. You do this by defining the actions that can be taken on specific resources under specific conditions, also known as *least-privilege permissions*. For more information about using IAM to apply permissions, see [Policies and permissions in IAM](#) in the *IAM User Guide*.

Use conditions in IAM policies to further restrict access – You can add a condition to your policies to limit access to actions and resources. For example, you can write a policy condition to specify that all requests must be sent using SSL. You can also use conditions to grant access to service actions if they are used through a specific AWS service, such as AWS CloudFormation. For more information, see [IAM JSON policy elements: Condition](#) in the *IAM User Guide*.

Use IAM Access Analyzer to validate your IAM policies to ensure secure and functional permissions – IAM Access Analyzer validates new and existing policies so that the policies adhere to the IAM policy language (JSON) and IAM best practices. IAM Access Analyzer provides more than 100 policy checks and actionable recommendations to help you author secure and functional policies. For more information, see [IAM Access Analyzer policy validation](#) in the *IAM User Guide*.

Require multi-factor authentication (MFA) – If you have a scenario that requires IAM users or a root user in your AWS account, turn on MFA for additional security. To require MFA when API operations are called, add MFA conditions to your policies. For more information, see [Configuring MFA-protected API access](#) in the *IAM User Guide*.

For more information about best practices in IAM, see [Security best practices in IAM](#) in the *IAM User Guide*.

Using the AWS Security Incident Response console

To access <https://console.aws.amazon.com/security-ir/>, you must have a minimum set of permissions. These permissions must allow you to list and view details about the AWS Security Incident Response resources in your AWS account. If you create an identity-based policy that is more restrictive than the minimum required permissions, the console won't function as intended for entities (users or roles) with that policy.

You don't need to allow minimum console permissions for users that are making calls only to the AWS CLI or the AWS API. Instead, allow access to only the actions that match the API operation that they're trying to perform.

Attach the AWS Security Incident Response Access or ReadOnly AWS managed policy to ensure that users and roles can use the service console. For more information, see [Adding permissions to a user](#) in the *IAM User Guide*.

Allow users to view their own permissions

This example shows how you might create a policy that allows IAM users to view the inline and managed policies that are attached to their user identity. This policy includes permissions to complete this action on the console or programmatically using the AWS CLI or AWS API.

Resource-Based Policies

Resource-based policies within AWS Security Incident Response

Supports resource-based policies: No

Resource-based policies are JSON policy documents that you attach to a resource. Examples of resource-based policies are *IAM role trust policies* and *Amazon S3 bucket policies*. In services that support resource-based policies, service administrators can use them to control access to a specific resource. For the resource where the policy is attached, the policy defines what actions a specified principal can perform on that resource and under what conditions. You must [specify a principal](#) in a resource-based policy. Principals can include accounts, users, roles, federated users, or AWS services.

For more information, refer to [Cross account resource access in IAM](#) in the *IAM User Guide*.

Policy Actions

Policy actions for AWS Security Incident Response

Support policy actions: Yes

Administrators can use AWS JSON policies to specify who has access to what. That is, which **principal** can perform **actions** on what **resources**, and under what **conditions**.

The Action element of a JSON policy describes the actions that you can use to allow or deny access in a policy. Policy actions usually have the same name as the associated AWS API operation. There are some exceptions, such as *permission-only actions* that don't have a matching API operation. There are also some operations that require multiple actions in a policy. These additional actions are called *dependent actions*.

Include actions in a policy to grant permissions to perform the associated operation.

To see a list of AWS Security Incident Response actions, see Actions defined by AWS Security Incident Response in the *Service Authorization Reference*.

Policy actions in AWS Security Incident Response use the following prefix before the action:

AWS Security Incident Response -identity

To specify multiple actions in a single statement, separate them with commas.

"Action": ["AWS Security Incident Response -identity:action1", "AWS Security Incident Response -identity:action2"]

Policy resources for Amazon AWS Security Incident Response

Supports policy resources: Yes Administrators can use AWS JSON policies to specify who has access to what. That is, which **principal** can perform **actions** on what **resources**, and under what **conditions**.

The Resource JSON policy element specifies the object or objects to which the action applies. Statements must include either a Resource or a NotResource element. As a best practice, specify a resource using its [Amazon Resource Name \(ARN\)](#). You can do this for actions that support a specific resource type, known as *resource-level permissions*.

For actions that don't support resource-level permissions, such as listing operations, use a wildcard (*) to indicate that the statement applies to all resources.

"Resource": "*"

Policy condition keys for AWS Security Incident Response

Supports service-specific policy condition keys: No

Administrators can use AWS JSON policies to specify who has access to what. That is, which **principal** can perform **actions** on what **resources**, and under what **conditions**.

The Condition element (or Condition *block*) lets you specify conditions in which a statement is in effect. The Condition element is optional. You can create conditional expressions that use [condition operators](#), such as equals or less than, to match the condition in the policy with values in the request.

If you specify multiple Condition elements in a statement, or multiple keys in a single Condition element, AWS evaluates them using a logical AND operation. If you specify multiple values for a single condition key, AWS evaluates the condition using a logical OR operation. All of the conditions must be met before the statement's permissions are granted.

You can also use placeholder variables when you specify conditions. For example, you can grant an IAM user permission to access a resource only if it is tagged with their IAM user name. For more information, see [IAM policy elements: variables and tags](#) in the *IAM User Guide*.

AWS supports global condition keys and service-specific condition keys. To see all AWS global condition keys, see [AWS global condition context keys](#) in the *IAM User Guide*.

Access control lists (ACLs) in AWS Security Incident Response

Supports ACLs: No

Access control lists (ACLs) control which principals (account members, users, or roles) have permissions to access a resource. ACLs are similar to resource-based policies, although they do not use the JSON policy document format.

Attribute-based access control (ABAC) with AWS Security Incident Response

Supports ABAC (tags in policies): Yes

Attribute-based access control (ABAC) is an authorization strategy that defines permissions based on attributes. In AWS, these attributes are called *tags*. You can attach tags to IAM entities (users or roles) and to many AWS resources. Tagging entities and resources is the first step of ABAC. Then you design ABAC policies to allow operations when the principal's tag matches the tag on the

resource that they are trying to access. ABAC is helpful in environments that are growing rapidly and helps with situations where policy management becomes cumbersome.

To control access based on tags, you provide tag information in the [condition element](#) of a policy using the `AWS:ResourceTag/key-name`, `AWS:RequestTag/key-name`, or `AWS:TagKeys` condition keys. If a service supports all three condition keys for every resource type, then the value is **Yes** for the service. If a service supports all three condition keys for only some resource types, then the value is **Partial**. For more information about ABAC, see [What is ABAC?](#) in the *IAM User Guide*. To view a tutorial with steps for setting up ABAC, see [Use attribute-based access control \(ABAC\)](#) in the *AWS Identity and Access Management User Guide*.

Temporary credentials with AWS Security Incident Response

Supports temporary credentials: Yes

AWS services don't work when you sign in using temporary credentials. For additional information, including which AWS services work with temporary credentials, see [AWS services that work with IAM](#) in the *AWS Identity and Access Management User Guide*. You are using temporary credentials if you sign in to the AWS Management Console using any method except a user name and password. For example, when you access AWS using your company's single sign-on (SSO) link, that process automatically creates temporary credentials. You also automatically create temporary credentials when you sign in to the console as a user and then switch roles. For more information about switching roles, see [Switching to a role \(console\)](#) in the *IAM User Guide*.

You can manually create temporary credentials using the AWS CLI or AWS API. You can then use those temporary credentials to access AWS. AWS recommends that you dynamically generate temporary credentials instead of using long-term access keys. For more information, see [Temporary security credentials in IAM](#).

Forward access sessions for AWS Security Incident Response

Supports forward access sessions (FAS): Yes

When you use an IAM user or role to perform actions in AWS, you are considered a principal. When you use some services, you might perform an action that then initiates another action in a different service. FAS uses the permissions of the principal calling an AWS service, combined with the requesting AWS service to make requests to downstream services. FAS requests are only made when a service receives a request that requires interactions with other AWS services or resources to complete. In this case, you must have permissions to perform both actions. For policy details when making FAS requests, see [Forward access sessions](#).

Troubleshooting AWS Security Incident Response identity and access

Use the following information to help you diagnose and fix common issues that you might encounter when working with AWS Security Incident Response and IAM.

Topics

- I am not authorized to perform an action
- I am not authorized to perform `iam:PassRole`
- I want to allow people outside of my AWS account to access my AWS Security Incident Response resources

I am not authorized to perform an action

If you receive an error that you're not authorized to perform an action, your policies must be updated to allow you to perform the action.

The following example error occurs when the `mateojackson` IAM user tries to use the console to view details about a fictional `my-example-widget` resource but doesn't have the fictional AWS Security Incident Response `:GetWidget` permissions.

User: `arn:AWS:iam::123456789012:user/mateojackson` is not authorized to perform: AWS Security Incident Response `:GetWidget` on resource: *my-example-widget*

In this case, the policy for the `mateojackson` user must be updated to allow access to the `my-example-widget` resource by using the AWS Security Incident Response `:GetWidget` action.

If you need help, contact your AWS administrator. Your administrator is the person who provided you with your sign-in credentials.

I am not authorized to perform `iam:PassRole` If you receive an error that you're not authorized to perform the `iam:PassRole` action, your policies must be updated to allow you to pass a role to AWS Security Incident Response .

Some AWS services allow you to pass an existing role to that service instead of creating a new service role or service-linked role. To do this, you must have permissions to pass the role to the service.

The following example error occurs when an IAM user named marymajor tries to use the console to perform an action in AWS Security Incident Response . However, the action requires the service to have permissions that are granted by a service role. Mary does not have permissions to pass the role to the service.

User: arn:AWS:iam::123456789012:user/marymajor is not authorized to perform: iam:PassRole

In this case, Mary's policies must be updated to allow her to perform the iam:PassRole action. If you need help, contact your AWS administrator. Your administrator is the person who provided you with your sign-in credentials.

I want to allow people outside of my AWS account to access my AWS Security Incident Response resources

You can create a role that users in other accounts or people outside of your organization can use to access your resources. You can specify who is trusted to assume the role.

To learn more, consult the following:

- To learn whether Amazon AWS Security Incident Response supports these features, see *How AWS Security Incident Response works with IAM*.
- To learn how to provide access to your resources across AWS accounts that you own, see [Providing access to an IAM user in another AWS account that you own](#) in the *IAM User Guide*.
- To learn how to provide access to your resources to third-party AWS accounts, see [Providing access to AWS accounts owned by third parties](#) in the *IAM User Guide*.
- To learn how to provide access through identity federation, see [Providing access to externally authenticated users \(identity federation\)](#) in the *IAM User Guide*.
- To learn the difference between using roles and resource-based policies for cross-account access, see [Cross account resource access in IAM](#) in the *IAM User Guide*.

Using service roles

Supports service roles: No

A service role is an [IAM role](#) that a service assumes to perform actions on your behalf. An IAM administrator can create, modify, and delete a service role from within IAM. For more information, see [Creating a role to delegate permissions to an AWS service](#) in the *IAM User Guide*.

Using service-linked roles

Service-linked roles for AWS Security Incident Response

Topics

- [AWS SLR: AWSServiceRoleForSecurityIncidentResponse](#)
- [AWS SLR: AWSServiceRoleForSecurityIncidentResponse_Triage](#)
- [Supported regions for AWS Security Incident Response service-linked roles](#)
- [Expected CreateServiceLinkedRole events in AWS CloudTrail](#)

Supports service-linked roles: Yes

A service-linked role is a type of service role that is linked to an AWS service. The service can assume the role to perform an action on your behalf. Service-linked roles appear in your AWS account and are owned by the service. An AWS Identity and Access Management administrator can view, but not edit the permissions for service-linked roles.

A service-linked role makes setting up AWS Security Incident Response easier because you don't have to manually add the necessary permissions. AWS Security Incident Response defines the permissions of its service-linked roles, and unless defined otherwise, only AWS Security Incident Response can assume its roles. The defined permissions include the trust policy and the permissions policy, and that permissions policy cannot be attached to any other IAM entity.

For information about other services that support service-linked roles, see [AWS services that work with IAM](#) and look for the services that have **Yes** in the Service-linked roles column. Choose a Yes with a link to view the service-linked role documentation for that service.

AWS SLR: AWSServiceRoleForSecurityIncidentResponse

AWS Security Incident Response uses the service-linked role (SLR) named `AWSServiceRoleForSecurityIncidentResponse` – AWS Security Incident Response policy to identify accounts subscribed, create cases, and tag related resources.

Permissions

The `AWSServiceRoleForSecurityIncidentResponse` service-linked role trusts the following service to assume the role:

- `security-ir.amazonaws.com`

Attached to this role is the AWS managed policy named [AWSSecurityIncidentResponseServiceRolePolicy](#). The service uses the role to perform actions on the following resources:

- *AWS Organizations*: Allows the service to lookup membership accounts for use with the service.
- *CreateCase*: Allows the service create service cases on behalf of membership accounts.
- *ListCases*: Allows the service's AI agent to view cases for the purposes of security investigation.
- *UpdateCase*: Allows the service's AI agent to update case metadata.
- *CreateCaseComment*: Allows the service's AI agent to post its results as a case comment.
- *ListComments*: Allows the service's AI agent to view case comments needed to perform automated investigations.
- *TagResource*: Allows the service tag resources configured as part of the service.

Managing the role

You don't need to manually create a service-linked role. When you onboard to AWS Security Incident Response in the AWS Management Console, the AWS CLI, or the AWS API, the service creates the service-linked role for you.

If you delete this service-linked role, and then need to create it again, you can use the same process to recreate the role in your account. When you onboard to the service it creates the service-linked role for you again.

You must configure permissions to allow an IAM entity (such as a user, group, or role) to create, edit, or delete a service-linked role. For more information, see [Service-linked role permissions](#) in the *IAM User Guide*.

AWS SLR: AWSServiceRoleForSecurityIncidentResponse_Triage

AWS Security Incident Response uses the service-linked role (SLR) named `AWSServiceRoleForSecurityIncidentResponse_Triage` – AWS Security Incident Response policy to continuously monitor your environment for security threats, tune security services to reduce alert noise, and gather information to investigate potential incidents.

Permissions

The `AWSServiceRoleForSecurityIncidentResponse_Triage` service-linked role trusts the following service to assume the role:

- `triage.security-ir.amazonaws.com`

Attached to this role is the AWS managed policy

[AWSSecurityIncidentResponseTriageServiceRolePolicy](#). The service uses the role to perform actions on the following resources:

- *Events*: Allows the service to create an Amazon EventBridge managed rule. This rule is the infrastructure required in your AWS account to deliver events from your account to the service. This action is performed on any AWS resource managed by `triage.security-ir.amazonaws.com`.
- *Amazon GuardDuty*: Allows the service to tune security services to reduce alert noise, gather information to investigate potential incidents, and initiate GuardDuty malware scans.
- *AWS Security Hub CSPM*: Allows the service to list enabled standards and product integrations, list organization members and admin accounts, and tune security services to reduce alert noise and gather information to investigate potential incidents.
- *AWS Identity and Access Management*: Allows the service to retrieve role information for the `AWSServiceRoleForAmazonGuardDutyMalwareProtection` service-linked role to verify whether GuardDuty MalwareProtection is configured.
- *AWS Security Incident Response*: Allows the service to create and update cases and tag resources, restricted to resources tagged with `SecurityIncidentResponseManaged=true`. Allows the service to read membership information (`GetMembership`, `ListMemberships`).

Managing the role

If you [onboard](#) to AWS Security Incident Response in the AWS Management Console, Security Incident Response automatically creates the `AWSServiceRoleForSecurityIncidentResponse_Triage` service-linked role in your AWS Organizations management account and in all accounts that are in scope. If you onboarding using the API/CLI, then you must create the role manually. For more information, see [Enable Security Incident Response and configure your incident response team using the API/CLI](#).

If you delete this service-linked role, and then need to create it again, you can use the API/CLI to recreate the role in your account.

You must configure permissions to allow an IAM entity (such as a user, group, or role) to create, edit, or delete a service-linked role. For more information, see [Service-linked role permissions](#) in the *IAM User Guide*.

Supported regions for AWS Security Incident Response service-linked roles

AWS Security Incident Response supports using service-linked roles in all of the regions where the service is available.

- US East (Ohio)
- US West (Oregon)
- US East (Virginia)
- Europe (Frankfurt)
- Europe (Ireland)
- Europe (London)
- Europe (Milan)
- Europe (Paris)
- Europe (Spain)
- Europe (Stockholm)
- Europe (Zurich)
- Asia Pacific (Hong Kong)
- Asia Pacific (Hyderabad)
- Asia Pacific (Jakarta)
- Asia Pacific (Melbourne)
- Asia Pacific (Mumbai)
- Asia Pacific (Seoul)
- Asia Pacific (Singapore)
- Asia Pacific (Sydney)
- Asia Pacific (Tokyo)
- Canada (Central)
- Middle East (Bahrain)
- Middle East (UAE)
- South America (São Paulo)
- Africa (Cape Town)

Expected CreateServiceLinkedRole events in AWS CloudTrail

To deliver new features and to make sure that required resources remain correctly configured, AWS Security Incident Response periodically updates the service's underlying infrastructure. Each update triggers a deployment that creates the required service-linked role. If the role already exists, the `CreateServiceLinkedRole` call returns an exception that indicates the role is already present. This exception is expected and handled by the service, and the deployment continues normally.

As a result, you might see `InvalidInputException` entries for `CreateServiceLinkedRole` in your CloudTrail event history. These entries are expected behavior, have no impact on your accounts, and require no action.

AWS Managed Policies

An AWS managed policy is a standalone policy that is created and administered by AWS. AWS managed policies are designed to provide permissions for many common use cases so that you can start assigning permissions to users, groups, and roles.

To add permissions to users, groups, and roles, it is easier to use AWS managed policies than to write policies yourself. It takes time and expertise to [create IAM customer managed policies](#) that provide your team with only the permissions they need. To get started quickly, you can use our AWS managed policies. These policies cover common use cases and are available in your AWS account. For more information about AWS managed policies, see [AWS managed policies](#) in the *IAM User Guide*.

AWS services maintain and update their associated AWS managed policies. You can't change the permissions in AWS managed policies. Services occasionally add additional permissions to an AWS managed policy to support new features. This type of update affects all identities (users, groups, and roles) where the policy is attached. Services are most likely to update an AWS managed policy when a new feature is launched or when new operations become available. Services do not remove permissions from an AWS managed policy, so policy updates won't break your existing permissions.

Additionally, AWS supports managed policies for job functions that span multiple services. For example, the **ReadOnlyAccess** AWS managed policy provides read-only access to all AWS services and resources. When a service launches a new feature, AWS adds read-only permissions for new operations and resources. For a list and descriptions of job function policies, see [AWS managed policies for job functions](#) in the *IAM User Guide*.

Topics

- [AWS managed policy: AWSSecurityIncidentResponseServiceRolePolicy](#)
- [AWS managed policy: AWSSecurityIncidentResponseFullAccess](#)
- [AWS managed policy: AWSSecurityIncidentResponseReadOnlyAccess](#)
- [AWS managed policy: AWSSecurityIncidentResponseCaseFullAccess](#)
- [AWS managed policy: AWSSecurityIncidentResponseTriageServiceRolePolicy](#)
- [AWS Security Incident Response updates to SLRs and managed policies](#)

AWS managed policy: AWSSecurityIncidentResponseServiceRolePolicy

AWS Security Incident Response uses the AWSSecurityIncidentResponseServiceRolePolicy AWS managed policy. This AWS managed policy is attached to the [AWSServiceRoleForSecurityIncidentResponse](#) service-linked role. The policy provides access for AWS Security Incident Response to identify accounts subscribed, create cases, update cases, create case comments, list cases, list case comments, and tag related resources.

Important

Do not store personally identifiable information (PII) or other confidential or sensitive information in tags. AWS Security Incident Response uses tags to provide you with administration services. Tags are not intended to be used for private or sensitive data

Permissions details

The service uses this policy to perform actions on the following resources:

- *AWS Organizations*: Allows the service to lookup membership accounts for use with the service.
- *CreateCase*: Allows the service create service cases on behalf of membership accounts.
- *ListCases*: Allows the service's AI agent to view cases for the purposes of security investigation.
- *UpdateCase*: Allows the service's AI agent to update case metadata.
- *CreateCaseComment*: Allows the service's AI agent to post its results as a case comment.
- *ListComments*: Allows the service's AI agent to view case comments needed to perform automated investigations.
- *TagResource*: Allows the service tag resources configured as part of the service.

You can view the permissions associated with this policy in AWS managed policies for [AWSSecurityIncidentResponseServiceRolePolicy](#).

AWS managed policy: AWSSecurityIncidentResponseFullAccess

AWS Security Incident Response uses the AWSSecurityIncidentResponseAdmin AWS managed policy. This policy grants full access to service resources and access to related AWS services. You can use this policy with your IAM principals to quickly add permissions for AWS Security Incident Response.

Important

Do not store personally identifiable information (PII) or other confidential or sensitive information in tags. AWS Security Incident Response uses tags to provide you with administration services. Tags are not intended to be used for private or sensitive data

Permissions details

The service uses this policy to perform actions on the following resources:

- *IAM principal read-only access:* Grants a service user the ability to perform read-only actions against existing AWS Security Incident Response resources.
- *IAM principal write access:* Grants a service user the ability to update, modify, delete, and create AWS Security Incident Response resources.

You can view the permissions associated with this policy in AWS managed policies for [AWSSecurityIncidentResponseFullAccess](#).

AWS managed policy: AWSSecurityIncidentResponseReadOnlyAccess

AWS Security Incident Response uses the AWSSecurityIncidentResponseReadOnlyAccess AWS managed policy. The policy grants read-only access to service case resources. You can use this policy with your IAM principals to quickly add permissions for AWS Security Incident Response.

** Important**

Do not store personally identifiable information (PII) or other confidential or sensitive information in tags. AWS Security Incident Response uses tags to provide you with administration services. Tags are not intended to be used for private or sensitive data

Permissions details

The service uses this policy to perform actions on the following resources:

- *IAM principal read-only access:* Grants a service user the ability to perform read-only actions against existing AWS Security Incident Response resources.

You can view the permissions associated with this policy in AWS managed policies for [AWSSecurityIncidentResponseReadOnlyAccess](#).

AWS managed policy: AWSSecurityIncidentResponseCaseFullAccess

AWS Security Incident Response uses the AWSSecurityIncidentResponseCaseFullAccess AWS managed policy. The policy grants full access to service case resources. You can use this policy with your IAM principals to quickly add permissions for AWS Security Incident Response.

** Important**

Do not store personally identifiable information (PII) or other confidential or sensitive information in tags. AWS Security Incident Response uses tags to provide you with administration services. Tags are not intended to be used for private or sensitive data

Permissions details

The service uses this policy to perform actions on the following resources:

- *IAM principal case read-only access:* Grants a service user the ability to perform read-only actions against existing AWS Security Incident Response cases.
- *IAM principal case write access:* Grants a service user the ability to update, modify, delete, and create AWS Security Incident Response cases.

You can view the permissions associated with this policy in AWS managed policies for [AWSSecurityIncidentResponseCaseFullAccess](#).

AWS managed policy:

AWSSecurityIncidentResponseTriageServiceRolePolicy

AWS Security Incident Response uses the `AWSSecurityIncidentResponseTriageServiceRolePolicy` AWS managed policy. This AWS managed policy is attached to the [AWSServiceRoleForSecurityIncidentResponse_Triage](#) service-linked role.

The policy provides access to AWS Security Incident Response to continuously monitor your environment for security threats, tune security services to reduce alert noise, and gather information to investigate potential incidents. You can't attach this policy to your IAM entities.

Important

Do not store personally identifiable information (PII) or other confidential or sensitive information in tags. AWS Security Incident Response uses tags to provide you with administration services. Tags are not intended to be used for private or sensitive data

Permissions details

The service uses this policy to perform actions on the following resources:

- *Events*: Allows the service to create an Amazon EventBridge managed rule. This rule is the infrastructure required in your AWS account to deliver events from your account to the service. This action is performed on any AWS resource managed by `triage.security-ir.amazonaws.com`.
- *Amazon GuardDuty*: Allows the service to tune security services to reduce alert noise, gather information to investigate potential incidents, and initiate GuardDuty malware scans.
- *AWS Security Hub CSPM*: Allows the service to list enabled standards and product integrations, list organization members and admin accounts, and tune security services to reduce alert noise and gather information to investigate potential incidents.
- *AWS Identity and Access Management*: Allows the service to retrieve role information for the `AWSServiceRoleForAmazonGuardDutyMalwareProtection` service-linked role to verify whether GuardDuty MalwareProtection is configured.

- **AWS Security Incident Response:** Allows the service to create and update cases and tag resources, restricted to resources tagged with `SecurityIncidentResponseManaged=true`. Allows the service to read membership information (`GetMembership`, `ListMemberships`).

You can view the permissions associated with this policy in AWS managed policies for [AWSSecurityIncidentResponseTriageServiceRolePolicy](#).

AWS Security Incident Response updates to SLRs and managed policies

View details about updates to AWS Security Incident Response SLRs and managed policies roles since this service began tracking these changes.

Change	Description	Date
Updated – AWSSecurityIncidentResponseReadOnlyAccess	The policy now includes the <code>security-ir:ListInvestigations</code> action.	April 22, 2026
Updated – AWSSecurityIncidentResponseFullAccess	The policy now uses <code>security-ir:*</code> instead of listing explicit <code>security-ir</code> actions. Eight new AWS Organizations permissions were added (<code>organizations:ListAWSServiceAccessForOrganization</code> , <code>organizations:ListRoots</code> , <code>organizations:ListOrganizationalUnitsForParent</code> , <code>organizations:ListAccountsForParent</code> , <code>organizations:ListChildren</code> , <code>organizations:DescribeOrganizationalUnit</code> , <code>organizations:ListAccounts</code> , and <code>organizations:DescribeAccount</code>) to support the console's account picker when updating associations. The MFA condition has been removed.	April 22, 2026
Updated – AWSSecurityIncidentResponseFullAccess	The policy now includes two new actions: <code>security-ir:ListInvestigations</code> and <code>security-ir:ListMemberships</code> .	April 22, 2026

Change	Description	Date
tResponseCaseFullAccess	<code>ir:SendFeedback</code> . The MFA condition has been removed.	
Updated – AWSSecurityIncidentResponseTriageServiceRolePolicy	The policy now allows the service to modify GuardDuty filters that are tagged with <code>SecurityIncidentResponseManaged=true</code> , to update detector configurations, and to initiate GuardDuty malware scans. It allows the service to create and manage rules that automatically act on Security Hub CSPM findings, and to understand organizational structure.	March 27, 2026
Updated – AWSSecurityIncidentResponseServiceRolePolicy	The policy now performs actions on the following resources: <code>ListCases</code>: Allows the service’s AI agent to view cases for the purposes of security investigation <code>UpdateCase</code>: Allows the service’s AI agent to update case metadata. <code>CreateCaseComment</code>: Allows the service’s AI agent to post its results as a case comment <code>ListComments</code>: Allows the service’s AI agent to view case comments needed to perform automated investigations	November 2025

Change	Description	Date
Updated – AWSSecurityIncidentResponseServiceRolePolicy	The policy now includes two new actions for "organizations:DescribeAccount" , "organizations:ListDelegatedAdministrators" and a new condition: <pre>"Condition": { "StringEquals": { "aws:ResourceAccount": "\${aws:PrincipalAccount}" } }</pre>	November 2025
Updates to SLR adding permissions to support service entitlements.	AWSSecurityIncidentResponseTriageServiceRolePolicy has been updated to add security-ir:GetMembership, security-ir:ListMemberships, security-ir:UpdateCase, guardduty:ListFilters, guardduty:UpdateFilter, guardduty:DeleteFilter, and guardduty:GetAdministratorAccount permissions. guardduty:GetAdministratorAccount was added to facilitate management of GuardDuty Auto-Archival filters in delegated accounts.	June 02, 2025

Change	Description	Date
New SLR – AWSServiceRoleForSecurityIncidentResponse New managed policy – AWSSecurityIncidentResponseServiceRolePolicy.	New service linked role and attached policy allowing service access into your AWS Organizations accounts to identify membership.	December 1, 2024
New SLR – AWSServiceRoleForSecurityIncidentResponse_Triage New managed policy – AWSSecurityIncidentResponseTriageServiceRolePolicy	New service linked role and attached policy allowing service access into your AWS Organizations accounts to perform triage of security events.	December 1, 2024
New managed policy – AWSSecurityIncidentResponseFullAccess	AWS Security Incident Response add a new SLR to attach to IAM principals for read and write actions for the service.	December 1, 2024

Change	Description	Date
New managed policy role – AWSSecurityIncidentResponseReadOnlyAccess	AWS Security Incident Response add a new SLR to attach to IAM principals for read actions	December 1, 2024
New managed policy role – AWSSecurityIncidentResponseCaseFullAccess	AWS Security Incident Response add a new SLR to attach to IAM principals for read and write actions for service cases.	December 1, 2024
Started tracking changes.	Started tracking changes for AWS Security Incident Response SLRs and managed policies	December 1, 2024

Incident response

Security and Compliance is a shared responsibility between AWS and the customer. This shared model can help relieve the customer's operational burden as AWS operates, manages and controls the components from the host operating system and virtualization layer down to the physical security of the facilities in which the service operates. The customer assumes responsibility and management of the guest operating system (including updates and security patches), other associated application software as well as the configuration of the AWS provided security group firewall. For additional information refer to the [AWS shared responsibility model](#).

By establishing a security baseline that meets the objectives for your applications running in the cloud, you're able to detect deviations that you can respond to. Since security incident response can be a complex topic, we encourage you to review the following resources so that you are better able to understand the impact that incident response and your choices have on your corporate goals: [AWS Security Best Practices](#) whitepaper, and the [Security Perspective of the AWS Cloud Adoption Framework](#) (CAF) white paper.

Compliance validation

Third-party auditors assess the security and compliance of AWS Security Incident Response as part of multiple AWS compliance programs. These include SOC, PCI, FedRAMP, and others.

AWS Security Incident Response is currently in scope for the following compliance programs.

Topics

- [AWS services in scope](#)
- [Healthcare compliance \(HITRUST CSF\)](#)
- [HIPAA eligibility](#)

AWS services in scope

Compliance program	Description
SOC 1, 2, 3	System and Organization Controls — independent audit reports covering security, availability, processing integrity, confidentiality, and privacy controls.
ISO 27001, 27017, 27018, 27701, 22301, 20000-1, 9001	International standards for information security management, cloud security controls, PII protection, privacy information management, business continuity, IT service management, and quality management.
CSA STAR CCM v4.0	Cloud Security Alliance Security Trust Assurance and Risk — third-party assessment of cloud-specific security controls.
C5 (Germany)	Cloud Computing Compliance Criteria Catalogue — German Federal Office for Information Security (BSI) baseline security standard.
FedRAMP Moderate	Federal Risk and Authorization Management Program — Class C (formerly Moderate baseline). Authorized in US East/West commercial Regions.

Compliance program	Description
DoD CC SRG	Department of Defense Cloud Computing Security Requirements Guide — Impact Level 2 (IL2). Baselined with FedRAMP Moderate authorization in US East/West commercial Regions.
HITRUST CSF	Health Information Trust Alliance Common Security Framework — certifiable framework harmonizing healthcare, privacy, and security requirements.
PCI DSS	Payment Card Industry Data Security Standard — security requirements for organizations handling cardholder data.
MTCS (Singapore)	Multi-Tier Cloud Security — Singapore's national cloud security certification standard (SS 584).
PiTuKri (Finland)	Criteria for Assessing the Information Security of Cloud Services — Finnish Traficom criteria for government cloud use.
FINMA (Switzerland)	Swiss Financial Market Supervisory Authority — regulatory workload guidance for cloud providers in Switzerland's financial sector.

For a complete list of AWS services in scope of specific compliance programs, see [AWS services in scope by compliance program](#). For general information, see [AWS compliance programs](#).

You can download third-party audit reports using AWS Artifact. For more information, see [Downloading reports in AWS Artifact](#).

Healthcare compliance (HITRUST CSF)

AWS Security Incident Response is [HITRUST CSF certified](#). The HITRUST Common Security Framework harmonizes healthcare, privacy, and security requirements into a single certifiable standard, and is widely recognized by healthcare organizations as an assurance that a service meets rigorous healthcare security control requirements. This certification demonstrates that AWS Security Incident Response aligns with the security controls expected for use in healthcare environments.

HIPAA eligibility

You can use AWS Security Incident Response to monitor and respond to security events in accounts and environments that handle electronic protected health information (ePHI), including HIPAA-designated environments. By design, AWS Security Incident Response doesn't create, receive, process, store, or transmit customer data, including ePHI, in the course of performing its function. For this reason, it isn't a [HIPAA Eligible Service](#) and isn't covered under the AWS Business Associate Agreement (BAA), and it doesn't need to be to be used alongside these workloads.

Logging and monitoring in AWS Security Incident Response

Monitoring is an important part of maintaining the reliability, availability, and performance of AWS Security Incident Response and your other AWS solutions. AWS Security Incident Response currently supports the following AWS services to monitor your organization and the activity that happens within it.

AWS CloudTrail – With CloudTrail you can capture API calls from the AWS Security Incident Response console. For example, when a user authenticates, CloudTrail can record details such as the IP address in the request, who made the request, and when it was made.

Amazon CloudWatch Metrics – With CloudWatch metrics you can monitor, report, and take automatic actions in case of an event in near real time. For example, you can create CloudWatch dashboards on the provided metrics to monitor your AWS Security Incident Response usage, or you can create CloudWatch alarms on the provided metrics to notify you on breach of a set threshold.

The namespace for the service is `AWS/Usage/ServiceName`. The metric names available are `ActiveManagedCases` and `SelfManagedCases`.

In accordance with the [AWS Service Terms](#), The AWS Security Incident Response responder team will have access to your history of CloudTrail, VPC, DNS and S3 log data. This data may be utilized during active security incidents when a case is open in the AWS Security Incident Response service portal.

Resilience

The AWS global infrastructure is built around AWS Regions and Availability Zones. Regions provide multiple physically separated and isolated Availability Zones, which are connected through low-latency, high-throughput, and highly redundant networking. With Availability Zones, you

can design and operate applications and databases that automatically fail over between zones without interruption. Availability Zones are more highly available, fault tolerant, and scalable than traditional single or multiple data center infrastructures.

For more information about AWS Regions and Availability Zones, see [AWS global infrastructure](#).

Infrastructure security

AWS Security Incident Response is protected by AWS global network security. For information about AWS security services and how AWS protects infrastructure, see [AWS Cloud Security](#). To design your AWS environment using the best practices for infrastructure security, see [Infrastructure Protection](#) in *Security Pillar AWS Well-Architected Framework*.

You use AWS published API calls to access AWS Security Incident Response through the network. Clients must support the following:

- Transport Layer Security (TLS). We require TLS 1.2 and recommend TLS 1.3.
- Cipher suites with perfect forward secrecy (PFS) such as DHE (Ephemeral Diffie-Hellman) or ECDHE (Elliptic Curve Ephemeral Diffie-Hellman). Most modern systems such as Java 7 and later support these modes.

Additionally, requests must be signed by using an access key ID and a secret access key that is associated with an IAM principal. Or you can use the [AWS Security Token Service](#) (AWS STS) to generate temporary security credentials to sign requests.

Configuration and vulnerability analysis

You are responsible for managing the service containment roles and the associated CloudFormation stack sets.

AWS handles basic security tasks, such as guest operating system (OS) and database patching, firewall configuration, and disaster recovery. These procedures have been reviewed and certified by the appropriate third parties. For more details, see the following AWS resources:

- [Shared responsibility model](#)
- [Best practices for security, identity, & compliance](#)

Cross-service confused deputy prevention

The confused deputy problem is a security issue where an entity that doesn't have permission to perform an action can coerce a more-privileged entity to perform the action. In AWS, cross-service impersonation can result in the confused deputy problem. Cross-service impersonation can occur when one service (the *calling service*) calls another service (the *called service*). The calling service can be manipulated to use its permissions to act on another customer's resources in a way it should not otherwise have permission to access. To prevent this, AWS provides tools that help you protect your data for all services with service principals that have been given access to resources in your account.

We recommend using the [AWS:SourceArn](#) and [AWS:SourceAccount](#) global condition context keys in resource policies to limit the permissions that Amazon Connect gives another service to the resource. If you use both global condition context keys, the AWS:SourceAccount value and the account in the AWS:SourceArn value must use the same account ID when used in the same policy statement.

The most effective way to protect against the confused deputy problem is to use the exact Amazon Resource Name (ARN) of the resource you want to allow. If you don't know the full ARN of the resource or if you are specifying multiple resources, use the AWS:SourceArn global context condition key with wildcards (*) for the unknown portions of the ARN. For example, `arn:AWS:servicename::region-name::your AWS account ID:*`.

For an example of an assume role policy that shows how you can prevent a confused deputy issue, see [Confused deputy prevention policy](#).

Service Quotas

AWS Security Incident Response

The AWS General Reference Guide includes the most current [AWS Security Incident Response endpoints and quotas](#).

Document history

The following table describes important additions to the AWS Security Incident Response documentation, beginning January 1, 2026. For notification about updates to this documentation, you can subscribe to the RSS feed.

Change	Description	Date
Updated Compliance validation	Updated the Compliance validation page with the current list of compliance programs that AWS Security Incident Response is in scope for, and added sections on healthcare compliance (HITRUST CSF) and HIPAA eligibility.	August 27, 2026
Added expected CreateServiceLinkedRole events explanation to Using service-linked roles	Added a section explaining that <code>InvalidInputException</code> entries for <code>CreateServiceLinkedRole</code> in AWS CloudTrail are expected behavior during periodic service infrastructure updates and require no action.	August 14, 2026
Corrected event type name in Case Comment Events	Corrected the EventBridge <code>detail-type</code> value from "Case Comment Created" to "Case Comment Added" to match the actual event emitted by the service.	August 13, 2026
Corrected EventBridge rule name in Validate your configuration	Updated the EventBridge rule name to look for in member accounts from <code>SecurityI</code>	August 13, 2026

ncidentResponse to SIR to match the actual deployed rule names.

[Updated proactive response and alert triaging page](#)

Renamed the page title from "Setup proactive response and alert triaging workflows" to "Proactive response and alert triaging" and removed the statement "However, for the management account, you must manually create the service-linked role to enable monitoring" as this is no longer applicable.

August 4, 2026

[Updated onboarding prerequisites with detection services and integration guidance](#)

Rewrote the onboarding prerequisites page with expanded guidance on detection services (Amazon GuardDuty, AWS Security Hub CSPM, AWS CloudTrail), third-party EDR integration via Security Hub CSPM, and a note that findings created before onboarding are not retroactively ingested.

July 2, 2026

[Rewrote the What is AWS Security Incident Response page](#)

Rewrote the What is page with updated content covering service overview, finding deduplication, log access, suppression rules, automated and human investigation, proactive and reactive cases, containment, integrations, and service boundaries.

July 2, 2026

[Expanded the Updating Findings section on the Detect and Analyze page](#)

Restructured the Detect and Analyze page to document the complete triage outcome taxonomy for Amazon GuardDuty findings, including categories for findings that are archived and findings that aren't archived. Relocated finding archiving content from the Detection section to the Updating Findings section.

July 2, 2026

[Consolidated onboarding documentation](#)

Rewrote the Enable AWS Security Incident Response page into a single streamlined guide covering prerequisites, membership account selection, account scope configuration, service permissions, and containment actions. Consolidated content from the Select a membership account, Setup membership details, and Associate accounts with AWS Organizations pages, which now redirect to the updated page.

July 2, 2026

[Added configuration validation guide](#)

Added a new topic with step-by-step procedures for validating AWS Security Incident Response configuration, including enrollment verification, detection source validation, automated pipeline testing, notification testing, containment readiness checks, and a troubleshooting guide.

July 2, 2026

[Fixed CLI examples in Enable Security Incident Response using the API/CLI](#)

Corrected the create-membership CLI examples by adding a missing comma delimiter between JSON objects in the `--incident-response-team` array and replacing the invalid email enum value in `communicationPreferences` with valid values.

July 1, 2026

[Revised containment documentation](#)

Consolidated the containment page with updated descriptions of supported containment actions, containment decision-making, strategy development, staged containment approach, and how containment relates to the incident lifecycle.

June 26, 2026

[Added Deploy containment and EC2 Triage roles to Onboarding guide](#)

Moved and rewrote the AWS CloudFormation StackSets documentation as a new onboarding step. Added a step-by-step procedure for creating a StackSet with service-managed permissions and updated the template descriptions for containment-only and containment with EC2 Triage options.

June 26, 2026

[Added IAM permissions requirement for delegated administrator during enablement](#)

Added a prerequisite specifying that the IAM principal used to sign in to the delegated administrator account must have AdministratorAccess permissions. Added a note at the sign-in step in the enablement procedure clarifying that insufficient permissions cause the step to fail.

June 19, 2026

[Consolidated onboarding documentation](#)

Rewrote the Enable AWS Security Incident Response page into a single streamlined guide covering prerequisites, membership account selection, account scope configuration, service permissions, and containment actions. Consolidated content from the Select a membership account, Setup membership details, and Associate accounts with AWS Organizations pages, which now redirect to the updated page.

June 17, 2026

[Added service-linked role cleanup guidance to Cancel Membership](#)

Added an important note clarifying that the `AWSServiceRoleForSecurityIncidentResponse` and `AWSServiceRoleForSecurityIncidentResponse_Triage` service-linked roles are not automatically deleted after membership cancellation. You must manually delete these roles from all accounts that were in scope.

June 17, 2026

[Renamed Post incident report to Monthly report](#)

Renamed the Post incident report section to Monthly report. Updated the section to clarify that reports are sent to all contacts on the Incident Response team, include delivery timing, and document the email subject line format.

May 13, 2026

[Updated onboarding documentation](#)

Updated the Enable AWS Security Incident Response topic to clarify that AWS Security Incident Response automatically creates the `AWSServiceRoleForSecurityIncidentResponse_Triage` service-linked role in the AWS Organizations management account when using the console. Added a link to instructions for enabling Security Incident Response using the API/CLI.

May 7, 2026

[Added Enable Security Incident Response using the API/CLI topic](#)

Added a new topic with step-by-step CLI instructions for enabling AWS Security Incident Response using the Delegated Administrator sign-up and management account sign-up methods.

May 7, 2026

[Clarified proactive response requirements for Amazon GuardDuty and third-party findings](#)

Clarified that Amazon GuardDuty is not required to use proactive response. AWS Security Incident Response can also monitor and investigate threat alerts from third-party threat detection tools using Security Hub CSPM integrations. Updated the section to accurately describe detection service requirements and the value of configuring findings ingestion.

May 5, 2026

[Added supported operating systems for EC2 Triage](#)

Added a list of supported operating systems for the EC2 Triage capability, including Linux distributions (Amazon Linux 2, Amazon Linux 2023, Ubuntu, RHEL, CentOS, SLES, and Debian) and Windows Server versions.

April 29, 2026

[Update policy description for AWSSecurityIncidentResponseReadOnlyAccess](#)

Updated policy to add security-ir:ListInvestigations action.

April 22, 2026

[Update policy description for AWSSecurityIncidentResponseFullAccess](#)

Updated policy to add AWS Organizations permissions and removed MFA condition.

April 22, 2026

[Update policy description for AWS::SecurityIncident::ResponseCaseFullAccess](#)

Updated policy to add security-ir:ListInvestigations and security-ir:SendFeedback actions and removed MFA condition.

April 22, 2026

[EC2 Triage feature for AWS Security Incident Response](#)

Added EC2 Triage capability that enables AWS Security Incident Response to collect investigative information from Amazon Elastic Compute Cloud instances using AWS Systems Manager Run Command during security investigations. Updated Detect and Analyze page to document EC2 Triage prerequisites and capabilities.

April 20, 2026

[EC2 Triage feature for AWS Security Incident Response](#)

Updated CloudFormation StackSets documentation to provide two template options: Containment only and Containment with EC2 Triage. The Containment with EC2 Triage template includes additional permissions for investigative data collection from Amazon EC2 instances.

April 20, 2026

[Data collection, Regional behavior, and compliance guidance for regulated customers](#)

Added new sections on data collection and usage, data residency and Regional behavior, and data access and permissions. Expanded the compliance validation section with shared responsibility and metadata classification guidance for customers in regulated industries.

April 17, 2026

[Updated onboarding guide](#)

Updated the onboarding guide with a new step-by-step structure, including preparation steps, prerequisites, and streamlined configuration workflows for incident response teams, case types, and tool integrations.

April 7, 2026

[Update policy description for AWS Security Incident Response Triage Service Role Policy](#)

Update policy description for AWS Security Incident Response Triage Service Role Policy to reflect changes that allow the service to improve service tuning and gather information to investigate potential incidents.

March 27, 2026

[Submit metadata](#)

Added instructions for submitting metadata through AWS Support cases.

March 27, 2026

[Submit containment preferences](#)

Added instructions for submitting containment preferences through AWS Support cases.

March 27, 2026

Containment StackSet template	Updated the containment StackSet CloudFormation template.	March 27, 2026
Clarified AWS Region considerations for delegated administrator accounts	Clarified that while you designate a delegated AWS Security Incident Response administrator account in one AWS Region during initial setup, the service provides organization-wide coverage across all supported AWS Regions.	March 20, 2026
Define containment action preferences	Updated the containment action preferences section to match current options.	March 19, 2026
Proactive Response and Alert Triaging	Removed references to proactive response and alert triaging workflow being optional.	March 3, 2026
Response Timeline	Updated response timeline to specify 15-minute SLO for case acknowledgment and 5 business days for customer response before case closure.	February 24, 2026
Communication Best Practices	Updated case closure timeline to specify 5 business days for customer response to critical information requests.	February 24, 2026
AWS CLI reference added in Interacting with Security Incident Response using AWS CloudShell	Added link to the AWS Command Line Interface Reference for AWS Security Incident Response.	February 24, 2026

RACI Matrix	Updated "Authorize CIRT containment actions" to "Authorize containment actions" in the RACI matrix.	February 13, 2026
Containment Preferences	Updated containment preference options from "No containment actions", "Containment with approval", and "Automatic containment" to "Approval Required", "Contain Confirmed", and "Contain Suspected" with revised descriptions.	February 13, 2026
Post Deployment of Security Incident Response	Added link to the AWS Security Incident Response: New Integrations and OU-Level Subscription demo.	February 4, 2026
Monitoring and Investigation	Added revised content to intro and sub sections on this page.	February 4, 2026
Detect and Analyze	Added revised content to intro and sub sections on this page.	February 4, 2026
Contain	Added revised content to this page.	February 4, 2026
AI Investigative Agent	Added Use of customer data disclaimer to this page. Disclaimer: AI Investigative Agent does not use customer data for model training, and it does not share customer data with third parties.	February 4, 2026

Change	Description	Date
Cancel Membership	Updated cancel membership page to indicate that the membership and service will end immediately upon cancellation and not as the end of the billing cycle.	November 20, 2025
AWS Managed Policies	Added update cases, create case comments, list cases, list case comments to the list of actions that the service provides.	November 19, 2025
Using service-linked roles	Added update cases, create case comments, list cases, list case comments to the list of actions that the service provides.	November 19, 2025
Communication Preferences	Created and Updated Added Communications Preferences section for new feature documentation.	November 12, 2025
Onboarding Guide Addition and Updates	Created and Updated Added onboarding guide including the following sections Added Enable Security Incident Response section. Added Authorize Security Incident Response engineers to perform threat containment actions section.	November 12, 2025

Change	Description	Date
	Added Post Deployment of Security Incident Response section.	
	Added Update the Incident Response Team section.	
	Added GuardDuty Findings and Suppression Rules section.	
	Added Amazon EventBridge section.	
	Added Integrations and External Tooling Workflow section.	
	Added External Tooling Workflow section.	

Change	Description	Date
Compliance and Billing Language Updates	Updated Removed statement that AWS Security Incident Response is not covered under any frameworks. AWS Security Incident Response is now covered under HITRUST with more to come in the future. Updated Visibility and Control to add AWS Security Incident Response Updated Cancel Membership to clarify service billing periods. Added a video to Getting Started that provides additional context for typical tasks to begin using AWS Security Incident Response.	August 15, 2025

Change	Description	Date
Updated – AWS Security Incident Response Service Role Policy	The policy now includes two new actions for "organizations:DescribeAccount" , "organizations:ListDelegatedAdministrators" and a new condition: <pre>"Condition": { "StringEquals": { "aws:ResourceAccount": "\${aws:PrincipalAccount}" } }</pre>	TBD
Feature update: subscribing to specific organizational units (OUs) or your entire AWS organization	Help panels in the user interface have been updated to reflect an update for subscribing to specific organizational units (OUs) or your entire AWS organization. New page create for Managing membership with organizational units (OUs) Pages related to AWS Organizations updated to reflect new OU management features.	August 7, 2025

Change	Description	Date
Updated service quotas	Service Quotas page updated to guide users toward the AWS General Reference Guide for AWS Security Incident Response endpoints and quotas	August 7, 2025
User feedback updates	Added hyperlinks for the service to AWS Security Incident Response Cases Update to reflect Computer Security Incident Handling Guide SP 800-61 r3 on for the Security Technical Guide	August 7, 2025
Adding page for Amazon EventBridge integration with AWS Security Incident Response.	New content section to describe how Amazon EventBridge integrates in AWS Security Incident Response.	June 26, 2025

Change	Description	Date
Updates to SLR adding permissions to support service entitlements.	AWSSecurityIncidentResponseTriageServiceRolePolicy has been updated to add security-ir:GetMembership, security-ir:ListMemberships, security-ir:UpdateCase, guardduty:ListFilters, guardduty:UpdateFilter, guardduty:DeleteFilter, and guardduty:GetAdministratorAccount permissions. guardduty:GetAdministratorAccount was added to facilitate management of GuardDuty Auto-Archival filters in delegated accounts.	June 02, 2025
Resource Updates.	Updated https://docs.aws.amazon.com/security-ir/latest/userguide/appendix-b-incident-response-resources.html#playbook-resources to reflect active workshops available for customers.	May 23, 2025
Service supports Japanese language.	Updated supported configurations to identify Japanese language support in Japan local time. English is supported globally.	May 13, 2025

Change	Description	Date
Content updates and customer feedback.	Added a note to https://docs.aws.amazon.com/security-ir/latest/userguide/select-a-membership-account.html to reflect an additional task when using a delegated administrator account as part of setup. Updated the customer experience when working with a service generated case and Detect and Analyze. Updated account cancellation details to provide better clarity on billing implications in cancelling a membership.	9 May, 2025
Adding three new supported regions.	Added three new regions to https://docs.aws.amazon.com/security-ir/latest/userguide/supported-configs.html . Mumbai, Paris, and São Paulo.	7 May, 2025

Change	Description	Date
Updated: Updates from customer comments on docs.	Spelling and grammar errors on multiple pages correct. Updated https://docs.aws.amazon.com/en_us/security-ir/latest/userguide/organizations_permissions.html to accurately reflect security-ir as the service prefix. Added a note to https://docs.aws.amazon.com/security-ir/latest/userguide/source-containment.html regarding Route53 and DNS.	February 7, 2025

Change	Description	Date
Updated: Updates from customer comments on docs.	Updated https://docs.aws.amazon.com/security-ir/latest/userguide/setup-monitoring-and-investigation-workflows.html to stackset template. Corrected entries triage.security-ir.com to triage.security-ir.amazonaws.com Added tracked connections note for AWSSupport-ContainEC2Reversible on https://docs.aws.amazon.com/security-ir/latest/userguide/contain.html. Fixed broken link on https://docs.aws.amazon.com/security-ir/latest/userguide/managing-associated-accounts.html. Added a definition for membership account at https://docs.aws.amazon.com/security-ir/latest/userguide/select-a-membership-account.html. Added a clarification note to https://docs.aws.amazon.com/en_us/security-ir/latest/userguide/using-service-linked-roles.html for AWS Organizations management accounts.	December 20, 2024

Change	Description	Date
Updated: Updates from customer comments on docs.	Removed multiple duplicate AWS AWS in text. Fixed broken links on https://docs.aws.amazon.com/security-ir/latest/userguide/sir_tagging.html and https://docs.aws.amazon.com/security-ir/latest/userguide/service-name-info-in-cloudtrail.html . Updates to https://docs.aws.amazon.com/security-ir/latest/userguide/contain.html. Removed the > from first paragraph . Replaced AWSSupport-ContainEC2Reversible with AWSSupport-ContainEC2Instance. Replaced AWSSupport-ContainIAMReversible with AWSSupport-ContainIAMPrincipal. Replaced AWSSupport-ContainS3Reversible with AWSSupport-ContainS3Resource. Updated formatting on https://docs.aws.amazon.com/en_us/security-ir/latest/userguide/issues.html When telling customers to contact security incident	December 10, 2024

Change	Description	Date
	response via a support ticket, https://docs.aws.amazon.com/security-ir/latest/userguide/understand-response-teams-and-support.html now provides options to select in the support forms. Removed CloudWatch Events and replaced with EventBridge on https://docs.aws.amazon.com/security-ir/latest/userguide/logging-and-events.html. Grammar updates on https://docs.aws.amazon.com/security-ir/latest/userguide/technique-access-containment.html. Removed publication date from https://docs.aws.amazon.com/security-ir/latest/userguide/security-incident-response-guide.html, replaced by updates in this table.	
Updated: AWS managed policies and service-linked roles.	Updates to managed policies and service-linked roles.	December 1, 2024
Service Launch	Initial service docs for service launch at re:Invent 2024	December 1, 2024